



**Cyber Security (CYBER);
CRA;
Cybersecurity requirements for password managers**

Reference

DEN/CYBER-EUS-007

Keywords

CRA, cybersecurity

ETSI

650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B
Association à but non lucratif enregistrée à la
Sous-Préfecture de Grasse (06) N° w061004871

Important notice

The present document can be downloaded from the
[ETSI Search & Browse Standards](#) application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on [ETSI deliver](#) repository.

Users should be aware that the present document may be revised or have its status changed,
this information is available in the [Milestones listing](#).

If you find errors in the present document, please send your comments to
the relevant service listed under [Committee Support Staff](#).

If you find a security vulnerability in the present document, please report it through our
[Coordinated Vulnerability Disclosure \(CVD\)](#) program.

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.
In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

Copyright Notification

No part may be reproduced or utilized in any form or by any means, electronic or mechanical, including photocopying and microfilm except as authorized by written permission of ETSI.

The content of the PDF version shall not be modified without the written authorization of ETSI.

The copyright and the foregoing restriction extend to reproduction in all media.

© ETSI 2026.
All rights reserved.

Contents

Intellectual Property Rights	14
Foreword.....	15
Modal verbs terminology.....	15
Introduction	15
1 Scope	17
2 References	18
2.1 Normative references	18
2.2 Informative references.....	18
3 Definition of terms, symbols and abbreviations.....	20
3.1 Terms.....	20
3.2 Symbols.....	22
3.3 Abbreviations	22
4 Product context.....	23
4.1 Product Functions.....	23
4.2 Product Architecture.....	24
4.3 Operational Environment	26
4.3.1 General description.....	26
4.3.2 Hardware environment	26
4.3.3 Software environment.....	26
4.3.4 Connectivity aspects	27
4.4 Distribution of Security Functions	27
4.5 Users.....	28
4.6 Use Cases	28
4.6.1 UC-1: Local Password Manager.....	28
4.6.2 UC-2: Password Manager Application with Remote-Based Resources	29
4.6.3 UC-3: Hybrid Local and Remote-Based	30
4.6.4 UC-4: Browser Extension Password Manager.....	30
4.6.5 UC-5: Enterprise Password Manager.....	31
4.6.6 UC-6: Hardware-Based Password Manager	32
5 Technical requirements for Products.....	33
5.1 Introduction - Applicability of the requirements	33
5.2 Appropriate level of cybersecurity	37
5.2.0 Introduction.....	37
5.2.1 Normal Risk.....	38
5.2.1.0 Applicability: All UC.....	38
5.2.2 High Risk.....	38
5.2.3 Critical Risk.....	38
5.3 No known exploitable vulnerabilities.....	38
5.3.0 Introduction.....	38
5.3.1 Normal Risk.....	38
5.4 Secure by default configuration.....	38
5.4.0 Introduction.....	38
5.4.1 Normal Risk.....	38
5.5 Security updates	39
5.5.0 Introduction.....	39
5.5.1 Normal Risk.....	39
5.5.2 High Risk (none).....	40
5.5.3 Critical Risk.....	40
5.6 Authentication and Access Control	40
5.6.0 Introduction.....	40
5.6.1 Normal Risk.....	40
5.6.2 High Risk	40
5.6.3 Critical Risk.....	40

5.7	Confidentiality Protection	41
5.7.0	Introduction.....	41
5.7.1	Normal Risk.....	41
5.7.2	High Risk.....	41
5.7.3	Critical Risk.....	41
5.8	Integrity Protection.....	42
5.8.0	Introduction.....	42
5.8.1	Normal Risk.....	42
5.9	Data Minimisation.....	42
5.9.0	Introduction.....	42
5.9.1	Normal Risk.....	42
5.10	Availability Protection	42
5.10.0	Introduction.....	42
5.10.1	Normal Risk.....	42
5.11	Non-interference.....	42
5.11.0	Introduction.....	42
5.11.1	Normal Risk.....	42
5.12	Attack Surface Minimisation.....	43
5.12.0	Introduction.....	43
5.12.1	Normal Risk.....	43
5.12.2	High Risk (none).....	43
5.12.3	Critical Risk.....	43
5.13	Exploit Mitigation	43
5.13.0	Introduction.....	43
5.13.1	Normal Risk.....	43
5.14	Monitoring.....	43
5.14.0	Introduction.....	43
5.14.1	Normal Risk.....	43
5.14.2	High Risk (none).....	43
5.14.3	Critical Risk.....	43
5.15	Factory Reset and Data Portability.....	44
5.15.0	Introduction.....	44
5.15.1	Normal Risk.....	44
5.15.2	High Risk.....	44
5.15.3	Critical Risk.....	44
6	Assessment criteria for compliance with technical requirements	44
6.1	Introduction to the assessment and compliance criteria	44
6.2	Appropriate level of cybersecurity	46
6.2.1	Normal Risk.....	46
6.2.1.1	ACC-SD-NORM-1	46
6.2.1.1.1	Reference.....	46
6.2.1.1.2	Objective	46
6.2.1.1.3	Preparation.....	46
6.2.1.1.4	Activities	46
6.2.1.1.5	Verdict.....	46
6.2.1.1.6	Evidence	46
6.2.1.2	ACC-SD-NORM-2	46
6.2.1.2.1	Reference.....	46
6.2.1.2.2	Objective	47
6.2.1.2.3	Preparation.....	47
6.2.1.2.4	Activities	47
6.2.1.2.5	Verdict.....	47
6.2.1.2.6	Evidence	47
6.2.1.3	ACC-SD-NORM-3	47
6.2.1.3.1	Reference.....	47
6.2.1.3.2	Objective	47
6.2.1.3.3	Preparation.....	47
6.2.1.3.4	Activities	48
6.2.1.3.5	Verdict.....	48
6.2.1.3.6	Evidence	48
6.2.2	High Risk.....	48

6.2.2.1	ACC-SD-HIGH-1	48
6.2.2.1.1	Reference.....	48
6.2.2.1.2	Objective	48
6.2.2.1.3	Preparation.....	48
6.2.2.1.4	Activities	48
6.2.2.1.5	Verdict.....	48
6.2.2.1.6	Evidence.....	49
6.2.3	Critical Risk.....	49
6.2.3.1	ACC-SD-CRIT-1	49
6.2.3.1.1	Reference.....	49
6.2.3.1.2	Objective	49
6.2.3.1.3	Preparation.....	49
6.2.3.1.4	Activities	49
6.2.3.1.5	Verdict.....	49
6.2.3.1.6	Evidence	49
6.3	No known exploitable vulnerabilities.....	50
6.3.1	Normal Risk.....	50
6.3.1.1	ACC-KEV-NORM-1	50
6.3.1.1.1	Reference.....	50
6.3.1.1.2	Objective	50
6.3.1.1.3	Preparation.....	50
6.3.1.1.4	Activities	50
6.3.1.1.5	Verdict.....	50
6.3.1.1.6	Evidence	51
6.4	Secure by default configuration.....	51
6.4.1	Normal Risk.....	51
6.4.1.0	Introduction.....	51
6.4.1.1	ACC-SD-NORM-1	51
6.4.1.1.1	Reference.....	51
6.4.1.1.2	Objective	51
6.4.1.1.3	Preparation:	51
6.4.1.1.4	Activities	51
6.4.1.1.5	Verdict.....	51
6.4.1.1.6	Evidence:.....	52
6.4.1.2	ACC-SD-NORM-2	52
6.4.1.2.1	Reference: REQ-SD-NORM-2.....	52
6.4.1.2.2	Objective	52
6.4.1.2.3	Preparation.....	52
6.4.1.2.4	Activities	52
6.4.1.2.5	Verdict.....	52
6.4.1.2.6	Evidence	52
6.5	Security updates	52
6.5.1	Normal Risk.....	52
6.5.1.1	ACC-SU-NORM-1	52
6.5.1.1.1	Reference.....	52
6.5.1.1.2	Objective	52
6.5.1.1.3	Preparation.....	53
6.5.1.1.4	Activities	53
6.5.1.1.5	Verdict.....	53
6.5.1.1.6	Evidence	53
6.5.1.2	ACC-SU-NORM-2	53
6.5.1.2.1	Reference.....	53
6.5.1.2.2	Objective	53
6.5.1.2.3	Preparation.....	53
6.5.1.2.4	Activities	54
6.5.1.2.5	Verdict.....	54
6.5.1.2.6	Evidence	54
6.5.1.3	ACC-SU-NORM-3	54
6.5.1.3.1	Reference.....	54
6.5.1.3.2	Objective	54
6.5.1.3.3	Preparation.....	54
6.5.1.3.4	Activities	54

6.5.1.3.5	Verdict	54
6.5.1.3.6	Evidence	55
6.5.1.4	ACC-SU-NORM-3	55
6.5.1.4.1	Reference	55
6.5.1.4.2	Objective	55
6.5.1.4.3	Preparation	55
6.5.1.4.4	Activities	55
6.5.1.4.5	Verdict	55
6.5.1.4.6	Evidence	55
6.5.1.5	ACC-SU-NORM-4	56
6.5.1.5.1	Reference	56
6.5.1.5.2	Objective	56
6.5.1.5.3	Preparation	56
6.5.1.5.4	Activities	56
6.5.1.5.5	Verdict	56
6.5.1.5.6	Evidence	56
6.5.2	High Risk (none)	56
6.5.3	Critical Risk	56
6.5.3.1	ACC-SU-CRIT-1	56
6.5.3.1.1	Reference	56
6.5.3.1.2	Objective	57
6.5.3.1.3	Preparation	57
6.5.3.1.4	Activities	57
6.5.3.1.5	Verdict	57
6.5.3.1.6	Evidence	57
6.5.3.2	ACC-SU-CRIT-2	57
6.5.3.2.1	Reference	57
6.5.3.2.2	Objective	57
6.5.3.2.3	Preparation	57
6.5.3.2.4	Activities	58
6.5.3.2.5	Verdict	58
6.5.3.2.6	Evidence	58
6.6	Authentication and access control	58
6.6.1	Normal Risk	58
6.6.1.1	ACC-AC-NORM-1	58
6.6.1.1.1	Reference	58
6.6.1.1.2	Objective	58
6.6.1.1.3	Preparation	58
6.6.1.1.4	Activities	59
6.6.1.1.5	Verdict	59
6.6.1.1.6	Evidence	59
6.6.1.2	ACC-AC-NORM-2	59
6.6.1.2.1	Reference	59
6.6.1.2.2	Objective	59
6.6.1.2.3	Preparation	59
6.6.1.2.4	Activities	60
6.6.1.2.5	Verdict	60
6.6.1.2.6	Evidence	60
6.6.1.3	ACC-AC-NORM-3	60
6.6.1.3.1	Reference	60
6.6.1.3.2	Objective	60
6.6.1.3.3	Preparation	60
6.6.1.3.4	Activities	60
6.6.1.3.5	Verdict	61
6.6.1.3.6	Evidence	61
6.6.1.4	ACC-AC-NORM-4	61
6.6.1.4.1	Reference	61
6.6.1.4.2	Objective	61
6.6.1.4.3	Preparation	61
6.6.1.4.4	Activities	61
6.6.1.4.5	Verdict	62
6.6.1.4.6	Evidence	62

6.6.2	High Risk	62
6.6.2.1	ACC-AC-HIGH-1	62
6.6.2.1.1	Reference	62
6.6.2.1.2	Objective	62
6.6.2.1.3	Preparation	62
6.6.2.1.4	Activities	62
6.6.2.1.5	Verdict	63
6.6.2.1.6	Evidence	63
6.6.2.2	Assessment AC-HIGH-2	63
6.6.2.2.1	Reference	63
6.6.2.2.2	Objective	63
6.6.2.2.3	Preparation	63
6.6.2.2.4	Activities	63
6.6.2.2.5	Verdict	64
6.6.2.2.6	Evidence	64
6.6.3	Critical Risks	64
6.6.3.1	Assessment ACC-AC-CRIT-1	64
6.6.3.1.1	Reference	64
6.6.3.1.2	Objective	64
6.6.3.1.3	Preparation	64
6.6.3.1.4	Activities	65
6.6.3.1.5	Verdict	65
6.6.3.1.6	Evidence	65
6.6.3.2	Assessment ACC-AC-CRIT-2	65
6.6.3.2.1	Reference	65
6.6.3.2.2	Objective	65
6.6.3.2.3	Preparation	65
6.6.3.2.4	Activities	65
6.6.3.2.5	Verdict	66
6.6.3.2.6	Evidence	66
6.6.3.3	ACC-AC-CRIT-3	66
6.6.3.3.1	Reference	66
6.6.3.3.2	Objective	66
6.6.3.3.3	Preparation	66
6.6.3.3.4	Activities	66
6.6.3.3.5	Verdict	67
6.6.3.3.6	Evidence	67
6.6.3.4	ACC-AC-CRIT-4	67
6.6.3.4.1	Reference	67
6.6.3.4.2	Objective	67
6.6.3.4.3	Preparation	67
6.6.3.4.4	Activities	67
6.6.3.4.5	Verdict	68
6.6.3.4.6	Evidence	68
6.6.3.5	ACC-AC-CRIT-5	68
6.6.3.5.1	Reference	68
6.6.3.5.2	Objective	68
6.6.3.5.3	Preparation	68
6.6.3.5.4	Activities	68
6.6.3.5.5	Verdict	69
6.6.3.5.6	Evidence	69
6.6.3.6	ACC-AC-CRIT-6	69
6.6.3.6.1	Reference	69
6.6.3.6.2	Objective	69
6.6.3.6.3	Preparation	69
6.6.3.6.4	Activities	69
6.6.3.6.5	Verdict	70
6.6.3.6.6	Evidence	70
6.7	Confidentiality protection	70
6.7.1	Normal Risk	70
6.7.1.1	ACC-CON-NORM-1	70
6.7.1.1.1	Reference	70

6.7.1.1.2	Objective	70
6.7.1.1.3	Preparation.....	70
6.7.1.1.4	Activities	70
6.7.1.1.5	Verdict.....	71
6.7.1.1.6	Evidence	71
6.7.2	High Risk.....	71
6.7.2.1	ACC-CON-HIGH-1	71
6.7.2.1.1	Reference.....	71
6.7.2.1.2	Objective	71
6.7.2.1.3	Preparation.....	71
6.7.2.1.4	Activities	71
6.7.2.1.5	Verdict.....	72
6.7.2.1.6	Evidence	72
6.7.2.2	ACC-CON-HIGH-2	72
6.7.2.2.1	Reference.....	72
6.7.2.2.2	Objective	72
6.7.2.2.3	Preparation.....	72
6.7.2.2.4	Activities	72
6.7.2.2.5	Verdict.....	72
6.7.2.2.6	Evidence	73
6.7.2.3	ACC-CON-HIGH-3	73
6.7.2.3.1	Reference.....	73
6.7.2.3.2	Objective	73
6.7.2.3.3	Preparation.....	73
6.7.2.3.4	Activities	73
6.7.2.3.5	Verdict.....	73
6.7.2.3.6	Evidence	73
6.7.3	Critical Risk.....	74
6.7.3.1	ACC-CON-CRIT-1	74
6.7.3.1.1	Reference.....	74
6.7.3.1.2	Objective	74
6.7.3.1.3	Preparation.....	74
6.7.3.1.4	Activities	74
6.7.3.1.5	Verdict.....	74
6.7.3.1.6	Evidence	74
6.8	Integrity protection.....	75
6.8.1	Normal Risk.....	75
6.8.1.1	ACC-INT-HIGH-1.....	75
6.8.1.1.1	Reference.....	75
6.8.1.1.2	Objective	75
6.8.1.1.3	Preparation.....	75
6.8.1.1.4	Activities	75
6.8.1.1.5	Verdict.....	75
6.8.1.1.6	Evidence	75
6.9	Data Minimisation.....	76
6.9.1	Normal Risk.....	76
6.9.1.1	ACC-DM-NORM-1	76
6.9.1.1.1	Reference.....	76
6.9.1.1.2	Objective	76
6.9.1.1.3	Preparation.....	76
6.9.1.1.4	Activities	76
6.9.1.1.5	Verdict.....	76
6.9.1.1.6	Evidence	76
6.10	Availability protection.....	77
6.10.1	Normal Risk.....	77
6.10.1.1	ACC-AP-NORM-1	77
6.10.1.1.1	Reference.....	77
6.10.1.1.2	Objective	77
6.10.1.1.3	Preparation.....	77
6.10.1.1.4	Activities	77
6.10.1.1.5	Verdict.....	77
6.10.1.1.6	Evidence	77

6.11	Non-interference.....	78
6.11.1	Normal Risk.....	78
6.11.1.1	Assessment REQ-IM-NORM-1	78
6.11.1.1.1	Reference.....	78
6.11.1.1.2	Objective	78
6.11.1.1.3	Preparation.....	78
6.11.1.1.4	Activities	78
6.11.1.1.5	Verdict.....	78
6.11.1.1.6	Evidence	78
6.11.1.2	ACC-IM-NORM-2.....	79
6.11.1.2.1	Reference.....	79
6.11.1.2.2	Objective	79
6.11.1.2.3	Preparation.....	79
6.11.1.2.4	Activities	79
6.11.1.2.5	Verdict.....	79
6.11.1.2.6	Evidence	79
6.12	Attack surface minimisation.....	80
6.12.1	Normal Risk.....	80
6.12.1.1	ACC-MAS-NORM-1	80
6.12.1.1.1	Reference.....	80
6.12.1.1.2	Objective	80
6.12.1.1.3	Preparation.....	80
6.12.1.1.4	Activities	80
6.12.1.1.5	Verdict.....	80
6.12.1.1.6	Evidence	80
6.12.2	High Risk (none).....	81
6.12.3	Critical Risk.....	81
6.12.3.1	ACC-MAS-CRIT-1.....	81
6.12.3.1.1	Reference.....	81
6.12.3.1.2	Objective	81
6.12.3.1.3	Preparation.....	81
6.12.3.1.4	Activities	81
6.12.3.1.5	Verdict.....	81
6.12.3.1.6	Evidence	81
6.13	Exploitation Mitigation	81
6.13.1	Normal Risk.....	81
6.13.1.1	ACC-EMM-NORM-1	81
6.13.1.1.1	Reference.....	81
6.13.1.1.2	Objective	82
6.13.1.1.3	Preparation.....	82
6.13.1.1.4	Activities	82
6.13.1.1.5	Verdict.....	82
6.13.1.1.6	Evidence	82
6.14	Monitoring.....	82
6.14.1	Normal Risk.....	82
6.14.1.1	ACC-LOG-NORM-1	82
6.14.1.1.1	Reference.....	82
6.14.1.1.2	Objective	82
6.14.1.1.3	Preparation.....	83
6.14.1.1.4	Activities	83
6.14.1.1.5	Verdict.....	83
6.14.1.1.6	Evidence	83
6.14.2	High Risk (none).....	83
6.14.3	Critical Risk.....	83
6.14.3.1	ACC-LOG-CRIT-1	83
6.14.3.1.1	Reference.....	83
6.14.3.1.2	Objective	83
6.14.3.1.3	Preparation.....	83
6.14.3.1.4	Activities	84
6.14.3.1.5	Verdict.....	84
6.14.3.1.6	Evidence	84
6.14.3.2	ACC-LOG-CRIT-2	84

6.14.3.2.1	Reference.....	84
6.14.3.2.2	Objective	84
6.14.3.2.3	Preparation.....	84
6.14.3.2.4	Activities	85
6.14.3.2.5	Verdict	85
6.14.3.2.6	Evidence	85
6.15	Factory reset and data portability	85
6.15.1	Normal Risk.....	85
6.15.1.1	REQ-DRT-NORM-1.....	85
6.15.1.1.1	Reference.....	85
6.15.1.1.2	Objective	85
6.15.1.1.3	Preparation.....	85
6.15.1.1.4	Activities	85
6.15.1.1.5	Verdict	86
6.15.1.1.6	Evidence	86
6.15.2	High Risk.....	86
6.15.2.1	ACC-DRT-HIGH-1.....	86
6.15.2.1.1	Reference.....	86
6.15.2.1.2	Objective	86
6.15.2.1.3	Preparation.....	86
6.15.2.1.4	Activities	86
6.15.2.1.5	Verdict	87
6.15.2.1.6	Evidence	87
6.15.3	Critical Risk.....	87
6.15.3.1	REQ-DRT-CRIT-1 (ex IEF-REQ-5).....	87
6.15.3.1.1	Reference.....	87
6.15.3.1.2	Objective	87
6.15.3.1.3	Preparation.....	87
6.15.3.1.4	Activities	87
6.15.3.1.5	Verdict	88
6.15.3.1.6	Evidence	88

Annex A (informative):	Relationship between the present document and the essential cybersecurity requirements of EU Regulation (EU) 2024/2847 - the Cyber Resilience Act.....	89
-------------------------------	---	-----------

Annex B (informative):	Security analysis.....	92
-------------------------------	-------------------------------	-----------

B.0	Cybersecurity threat landscape, risk identification and assessment methodology	92
B.1	Assets	92
B.1.1	Data	92
B.1.1.1	Vault data.....	92
B.1.1.2	Key material.....	93
B.1.1.3	Configuration data	93
B.1.1.4	Identity and device data	93
B.1.1.5	Operational data.....	94
B.1.1.6	Transient data.....	94
B.1.2	Product functions.....	94
B.1.2.1	Vault management essential functions.....	94
B.1.2.2	Autofill and credential delivery essential functions.....	95
B.1.2.3	Authentication and access control essential functions	95
B.1.2.4	Synchronisation functions.....	95
B.1.2.5	Browser extension functions.....	95
B.1.2.6	Enterprise administration functions	96
B.1.2.7	Backup and recovery functions.....	96
B.1.2.8	Update and maintenance functions	96
B.1.2.9	Hardware-specific functions	96
B.2	Use Cases	97
B.2.1	UC-1 Local Password Manager Risk Assessment.....	97
B.2.1.1	Threat Profile	97
B.2.1.2	Impact Analysis	97

B.2.2	UC-2 Password Manager Application with Remote-Based Resources Risk Assessment	98
B.2.2.1	Threat Profile	98
B.2.2.2	Impact Analysis	99
B.2.3	UC-3: Hybrid Local and Remote-Based Resources Risk Assessment	99
B.2.3.1	Threat Profile	99
B.2.3.2	Impact Analysis	100
B.2.4	UC-4: Browser Extension Risk Assessment	100
B.2.4.1	Threat Profile	100
B.2.4.2	Impact Analysis	101
B.2.5	UC-5: Enterprise Password Manager Risk Assessment	101
B.2.5.1	Threat Profile	101
B.2.5.2	Impact Assessment	102
B.2.6	UC-6: Hardware-Based Password Manager Risk Assessment	102
B.2.6.1	Threat Profile	102
B.2.6.2	Impact Analysis	103

Annexes C to J: Void	104
-----------------------------------	------------

Annex K (normative): Generic cryptographic requirements and assessment	105
---	------------

K.1	Cryptography	105
K.1.1	Requirement	105
K.1.2	Assessment of product cryptographic configuration	106
K.1.2.0	General	106
K.1.2.1	Assessment of ACM-listed cryptographic mechanisms	106
K.1.2.1.1	Assessment objective	106
K.1.2.1.2	Assessment preparation	106
K.1.2.1.3	Assessment activities	106
K.1.2.1.4	Assessment evidence	106
K.1.2.1.5	Assessment verdict	107
K.1.2.2	Assessment of ACM-extended cryptographic mechanisms	107
K.1.2.2.1	Assessment objective	107
K.1.2.2.2	Assessment preparation	107
K.1.2.2.3	Assessment activities	107
K.1.2.2.4	Assessment evidence	108
K.1.2.2.5	Assessment verdict	108
K.1.2.3	Assessment of interoperability-based cryptographic mechanisms	108
K.1.2.3.1	Assessment objective	108
K.1.2.3.2	Assessment preparation	108
K.1.2.3.3	Assessment activities	108
K.1.2.3.4	Assessment evidence	109
K.1.2.3.5	Assessment verdict	109
K.2	Crypto agility	109
K.2.1	Requirement	109
K.2.2	Assessment of crypto-agility	110
K.2.2.1	Assessment objective	110
K.2.2.2	Assessment preparation	110
K.2.2.3	Assessment activities	110
K.2.2.4	Assessment evidence	111
K.2.2.5	Assessment verdict	111
K.3	ACM-extended cryptographic mechanisms	111
K.3.1	Requirement	111
K.3.2	List of ACM-extended cryptographic mechanisms	112
K.3.2.1	Symmetric atomic primitives	112
K.3.2.1.1	Stream ciphers	112
K.3.2.1.2	Hash Functions	112
K.3.2.2	Symmetric constructions	112
K.3.2.2.1	Integrity modes: message authentication codes	112
K.3.2.2.2	Authenticated encryption	113
K.3.2.2.3	Key derivation functions	113
K.3.2.2.4	Password protection/password hashing mechanisms	113
K.3.2.3	Asymmetric atomic primitives	114

K.3.2.3.1	Discrete logarithm in elliptic curves	114
K.3.2.4	Asymmetric constructions	114
K.3.2.4.1	Asymmetric encryption scheme	114
K.3.2.4.2	Digital signature scheme	114
K.3.2.4.3	Key establishment and key encapsulation.....	114
K.3.2.5	Protocols	115
K.3.2.5.1	Password-authenticated key agreement.....	115
K.3.2.5.2	Transport and authenticated channels	115
K.3.2.6	List of cryptographic catalogues	115
K.3.3	Assessment	115
Annexes L to Q: Void		116
Annex R (normative): Remote Data Processing Solutions		117
R.1	Scope & Applicability	117
R.2	RDPS as a product-boundary extension.....	117
R.3	Threat Model	118
R.3.0	Introduction	118
R.3.1	Assets	118
R.3.2	Threat catalogue	119
R.3.3	Assets ↔ Threats mapping.....	120
R.4	Security Requirements	120
R.4.1	General and guidance for requirement-structure selection	120
R.4.2	Applicability of Annex R requirements.....	120
R.4.3	Local product side requirements	122
R.4.3.1	Data authenticity of interactions received from the RDPS side.....	122
R.4.3.2	Integrity of interactions received from the RDPS side	122
R.4.3.3	Confidentiality of data exchanged with the RDPS side	123
R.4.3.4	Availability	123
R.4.4	RDPS side requirements.....	124
R.4.4.1	Data authenticity of interactions received from the local product side	124
R.4.4.2	Integrity of interactions received from the local product side.....	125
R.4.4.3	Confidentiality of data exchanged with the local product side	125
R.4.4.4	Availability	126
R.4.5	Threats ↔ Requirements mapping.....	127
R.5	Conformity assessment.....	127
R.5.1	Introduction	127
R.5.1	Local product side requirements	127
R.5.1.1	Assessment case for REQ-RDPS-L-AUTH-NORM-001	127
R.5.1.2	Assessment case for REQ-RDPS-L-AUTH-HIGH-002	128
R.5.1.3	Assessment case for REQ-RDPS-L-AUTH-CRIT-003.....	129
R.5.1.4	Assessment case for REQ-RDPS-L-INTEG-NORM-001	130
R.5.1.5	Assessment case for REQ-RDPS-L-INTEG-HIGH-002	131
R.5.1.6	Assessment case for REQ-RDPS-L-INTEG-CRIT-002	131
R.5.1.7	Assessment case for REQ-RDPS-L-CONF-NORM-001.....	132
R.5.1.8	Assessment case for REQ-RDPS-L-CONF-HIGH-002.....	133
R.5.1.9	Assessment case for REQ-RDPS-L-CONF-CRIT-003	134
R.5.1.10	Assessment case for REQ-RDPS-L-AVAIL-NORM-001	135
R.5.1.11	Assessment case for REQ-RDPS-L-AVAIL-HIGH-002.....	136
R.5.1.12	Assessment case for REQ-RDPS-L-AVAIL-CRIT-003.....	136
R.5.2	RDPS side requirements.....	137
R.5.2.1	Assessment case for REQ-RDPS-R-AUTH-NORM-001	137
R.5.2.2	Assessment case for REQ-RDPS-R-AUTH-HIGH-002	138
R.5.2.3	Assessment case for REQ-RDPS-R-AUTH-CRIT-003.....	139
R.5.2.4	Assessment case for REQ-RDPS-R-INTEG-NORM-001	140
R.5.2.5	Assessment case for REQ-RDPS-R-INTEG-HIGH-002	141
R.5.2.6	Assessment case for REQ-RDPS-R-INTEG-CRIT-003	142
R.5.2.7	Assessment case for REQ-RDPS-R-CONF-NORM-001	143
R.5.2.8	Assessment case for REQ-RDPS-R-CONF-HIGH-002	143

R.5.2.9	Assessment case for REQ-RDPS-R-CONF-CRIT-003	144
R.5.2.10	Assessment case for REQ-RDPS-R-AVAIL-NORM-001.....	145
R.5.2.11	Assessment case for REQ-RDPS-R-AVAIL-HIGH-002.....	146
R.5.2.12	Assessment case for REQ-RDPS-R-AVAIL-CRIT-003.....	147
History		148

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the [ETSI IPR online database](#).

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organisations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organisational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organisations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organisational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

Bluetooth® is a trademark registered and owned by Bluetooth SIG, Inc.

Foreword

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Security (CYBER), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

The present document has been prepared under the Commission's standardisation request C(2025)618 [i.3] to provide one voluntary means of conforming to the requirements of Regulation (EU) 2024/2847 [i.1] of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828, known as the Cyber Resilience Act (CRA).

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

Proposed national transposition dates	
Date of latest announcement of this EN (doa):	3 months after ETSI publication
Date of latest publication of new National Standard or endorsement of this EN (dop/e):	6 months after doa
Date of withdrawal of any conflicting National Standard (dow):	18 months after doa

Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the [ETSI Drafting Rules](#) (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

Introduction

The present document provides the technical cybersecurity requirements for the products in scope, following a risk-based approach in support of the Cyber Resilience Act (CRA) [i.1]. The technical cybersecurity requirements are thereby proportionate to the intended purpose, reasonably foreseeable use, deployment context, and threat exposure of the products.

Clause 4 does not contain technical requirements; it describes the product context that is considered for the application of this standard.

Clause 4 also defines Use Cases (UCs) that represent the main deployment scenarios reflecting the intended purpose and reasonably foreseeable use of the product, which serve as the basis for identifying relevant cybersecurity risks.

Clause 5 specifies technical cybersecurity requirements for the product to mitigate the identified risks, including their applicability conditions.

Clause 6 specifies the assessment criteria and compliance verification procedures with the requirements of clause 5.

Annex A maps the technical requirements of the present document with the essential requirements of the CRA [i.1] Regulation.

Annex B informs about the methodology used to assess the security risks of the products in their context.

Annex K supports the definition of the cryptographic requirements and assessment criteria used by the present document.

Annex R provides supplementary requirements and assessment provisions where a product relies on Remote Data Processing Solutions (RDPSs) for the provision or support of one or more product functions.

A manufacturer seeking to establish conformance with the present document is expected to proceed as follows. First, identify the product at hand within the product context described in clause 4 and confirm that it falls within the scope of this vertical. Second, identify the use case or use cases the product is intended to support, including its intended purpose, deployment model, and reasonably foreseeable use, and derive the applicable risk level from the characteristics mapped in Annex B.

Third, implement the requirements specified in clause 5 for the applicable risk level, drawing on Annex K for cryptographic constructions and on the referenced standards in clause 2 where the present document defers to them.

Fourth, perform the assessments specified in clause 6 for each applicable requirement and collect the evidence the assessment criteria require. Successful completion of the applicable assessments, with supporting evidence, constitutes the basis on which conformance with this standard is claimed.

The present document does not address requirements imposed on manufacturers by other instruments of Union law, nor does it address horizontal obligations under the CRA that apply irrespective of product class. In particular, vulnerability handling, incident reporting, technical documentation, and the placing-on-market obligations of the CRA itself are addressed by the CRA and by the horizontal standards referenced in clause 2; the present document specifies only the product-class-specific cybersecurity requirements and their assessment.

1 Scope

The present document specifies technical requirements and corresponding assessment criteria for password managers related to cybersecurity. The products with digital elements in scope, thereafter "the product":

- are specified within the "technical description" of the "category of product" number "NN" by the Commission Implementing Regulation (EU) 2025/2392 [i.2] as:

"Products with digital elements that store passwords, locally on a device or on a remote server, including activities such as generation of passwords as well as password sharing and integration with local or third-party applications for usage of passwords.

This category includes but is not limited to local password managers, password managers provided as browser extensions, enterprise password managers as well as hardware-based password managers".

- are only covered within the product context described in clause 4.

The present document covers those products to demonstrate compliance with essential cybersecurity requirements in the Regulation (EU) 2024/2847 [i.1], Annex I Part I under the conditions identified in annex A.

Password Managers: a subset of identity and access management systems. For other types of authentication mechanisms, see the IAM standard prEN 40000-10 [i.10] currently drafted by CEN TC 224. Consult clause 3.1 for the product definition.

2 References

2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the [ETSI docbox](#).

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long term validity.

The following referenced documents are necessary for the application of the present document.

- [1] [IETF RFC 6238 \(May 2011\)](#): "TOTP: Time-Based One-Time Password Algorithm".
- [2] [IETF RFC 4226 \(December 2005\)](#): "HOTP: An HMAC-Based One-Time Password Algorithm".
- [3] W3C® Recommendation (April 2021): [Web Authentication: An API for accessing Public Key Credentials Level 2](#).
- [4] FIDO™ Alliance (July 2025): "[Client to Authenticator Protocol \(CTAP\) 2.2](#)".
- [5] FIDO™ Alliance (February 2026): "[Client to Authenticator Protocol \(CTAP\) 2.3](#)".
- [6] ENISA European Cybersecurity Certification Group Sub-group on Cryptography Report: "[Agreed Cryptographic Mechanisms](#)" version 2.0 - April 2025.

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long term validity.

The following referenced documents are not necessary for the application of the present document but they assist the user with regard to a particular subject area.

- [i.1] [Regulation \(EU\) 2024/2847](#) of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).
- [i.2] [Commission Implementing Regulation \(EU\) 2025/2392](#) of 28 November 2025 on the technical description of the categories of important and critical products with digital elements pursuant to Regulation (EU) 2024/2847 of the European Parliament and of the Council.
- [i.3] [Standardisation request M/606 - C\(2025\)618](#): "Commission Implementing decision of 3.2.2025 on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)".
- [i.4] prEN 40000-1-1: "Cybersecurity requirements for products with digital elements - Vocabulary" (Produced by CEN CENELEC).

NOTE: Version and date to be added upon its publication by CEN CENELEC.

- [i.5] ENISA (July 2014): "[Basic security practices regarding passwords and online identities](#)".
- [i.6] BSI (April 2026): "[Creating Secure Passwords](#)".
- [i.7] NCSC (April 2026): "[Top Tips for Staying Secure Online - Three Random Words](#)".
- [i.8] CNIL (March 2024): "[Security of Personal Data](#)".
- [i.9] [NIST SP 800-63B-4 \(July 2025\)](#): "Digital Identity Guidelines Authentication and Authenticator Management".
- [i.10] prEN 40000-10: "Cybersecurity essential requirements for products with digital elements used in identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers", CEN TC 224, produced by CEN.
- [i.11] IETF RFC 8439: "ChaCha20 and Poly1305 for IETF Protocols".
- [i.12] draft-arciszewski-xchacha-03: "XChaCha: eXtended-nonce ChaCha and AEAD_XChaCha20_Poly1305".
- [i.13] [Salsa20 specification](#).
- [i.14] [Extending the Salsa20 nonce](#).
- [i.15] IETF RFC 7693: "The BLAKE2 Cryptographic Hash and Message Authentication Code (MAC)".
- [i.16] NIST IR 7896: "Third-Round Report of the SHA-3 Cryptographic Hash Algorithm Competition".
- [i.17] draft-aumasson-blake3-00: "The BLAKE3 Hashing Framework".
- [i.18] FIPS 202: "SHA-3 Standard: Permutation-Based Hash and Extendable-Output Functions".
- [i.19] IETF RFC 8452: "AES-GCM-SIV: Nonce Misuse-Resistant Authenticated Encryption".
- [i.20] BSI TR-0210 2-1: "Cryptographic Mechanisms".
- [i.21] IETF RFC 9106: "Argon2 Memory-Hard Function for Password Hashing and Proof-of-Work Application".
- [i.22] IETF RFC 7914: "The scrypt Password-Based Key Derivation Function".
- [i.23] IETF RFC 7748: "Elliptic Curves for Security".
- [i.24] IETF RFC 9496: "The ristretto255 and decaf448 Groups".
- [i.25] IETF RFC 9180: "Hybrid Public Key Encryption".
- [i.26] IETF RFC 8032: "Edwards-Curve Digital Signature Algorithm (EdDSA)".
- [i.27] FIPS 186-5: "Digital Signature Standard (DSS)".
- [i.28] draft-connelly-cfrg-xwing-kem-10: "X-Wing: general-purpose hybrid post-quantum KEM".
- [i.29] draft-ietf-tls-ecdhe-mlkem-05: "Post-quantum hybrid ECDHE-MLKEM Key Agreement for TLSv1.3".
- [i.30] IETF RFC 2945: "The SRP Authentication and Key Exchange System".
- [i.31] draft-irtf-cfrg-cpace-21: "CPace, a balanced composable PAKE".
- [i.32] IETF RFC 9807: "The OPAQUE Augmented Password-Authenticated Key Exchange (aPAKE) Protocol".
- [i.33] IETF RFC 9383: "SPAKE2+, an Augmented Password-Authenticated Key Exchange (PAKE) Protocol".

- [i.34] [Noise Protocol Framework](#).
- [i.35] BSI TR-02102-1: "Cryptographic Mechanisms: Recommendations and Key Lengths" Version: 2026-01.
- [i.36] BSI TR-02102-2: "Cryptographic Mechanisms: Recommendations and Key Lengths: Use of Transport Layer Security (TLS)" Version: 2026-01.
- [i.37] BSI TR-02102-4: "Cryptographic Mechanisms: Recommendations and Key Lengths - Use of Secure Shell (SSH)" Version: 2026-01.
- [i.38] ANSSI-PG-083: "Règles et recommandations concernant le choix et le dimensionnement des mécanismes cryptographiques".
- [i.39] ACN: "Linee Guida Funzioni Crittografiche Cifratura Autenticata".
- [i.40] ACN: "Linee Guida Funzioni Crittografiche Funzioni di Hash".
- [i.41] ACN: "Linee Guida Funzioni Crittografiche Conservazione delle Password".
- [i.42] [Salsa20/12](#).
- [i.43] [Cryptography in NaCl](#).

3 Definition of terms, symbols and abbreviations

3.1 Terms

For the purposes of the present document, the terms given in Regulation (EU) 2024/2847 [i.1], prEN 40000-1-1 [i.4] and the following apply:

authenticator: entity or product layer that supports the required provisions of the W3C WebAuthn [3] and FIDO CTAP [4] and [5] standards to store FIDO2 credentials and to authenticate users with supporting services

EXAMPLE: A passkey is a FIDO2 credential held by such an authenticator.

brute-force resistant: system design property to make efficient secret guessing by attackers infeasible

credential: type of secret that is sufficient to authenticate identity and access to a protected resource or system

NOTE 1: All credentials are types of secrets, but not all secrets are credentials (e.g. encryption keys, digital certificates).

NOTE 2: A password is often not a credential in of itself, requiring pairing with an associated username or other unique user identifier to be considered a credential.

cryptographic mechanism: security-related procedure using cryptography

NOTE 1: The term "cryptographic mechanism" is used in this annex as an umbrella term covering the categories used in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [6], including cryptographic algorithms, primitives, schemes, protocols, protocol profiles, cipher suites, modes of operation, constructions and parameter sets.

NOTE 2: The terms "cryptographic primitive", "cryptographic construction", "cryptographic scheme" and "cryptographic protocol" are used consistently with the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [6].

NOTE 3: A cryptographic mechanism can be specified at different levels of abstraction. For example, AES is a cryptographic primitive, AES-GCM is a mode of operation / authenticated encryption construction, TLS 1.3 is a protocol, a TLS 1.3 restricted cipher-suite profile is a protocol profile, and TLS_AES_128_GCM_SHA256 is a cipher suite.

cryptographic property: property provided or supported by a cryptographic mechanism

NOTE 1: Cryptographic properties include, for example, confidentiality, integrity, authenticity, entity authentication, message authentication, key establishment, key confirmation, replay protection, collision resistance, second-preimage resistance, pre-image resistance, signature unforgeability, non-repudiation, forward secrecy and password-verifier protection. Where relevant, a cryptographic property can be expressed using a formal cryptographic notion, for example IND-CPA, IND-CCA, IND-CCA2, EUF-CMA, SUF-CMA or authenticated key exchange security.

NOTE 2: A cryptographic property is distinct from a product-level technical requirement, although it can support such a requirement. For example, a secure communication requirement can rely on cryptographic properties such as confidentiality, integrity and authentication.

exponential backoff: user-authentication rate-limiting property whereby each successive unsuccessful authentication attempt increases the mandatory wait time before the next permitted attempt exponentially

generation of password: process of creating a new password using either deterministic algorithms with cryptographically secure random inputs or user-defined composition rules to achieve specified entropy and complexity requirements

NOTE: Generation can be performed automatically by software or manually by users.

master password: primary authentication secret used to decrypt and access the password manager's encrypted database

Multifactor Authentication (MFA): authentication requiring verification of two or more authentication factors drawn from different factor categories, namely knowledge ("something you know"), possession ("something you possess") and inherence ("something you are")

NOTE: Configurable MFA approaches can include, but are not limited to, the following:

- FIDO2 credentials (Passkey, TPM-based, or roaming)
- Challenge-based authenticator applications
- Biometrics
- Application or hardware-based OTP codes
- Keyfiles
- Message-based methods (email, SMS and call-based)

passkey: discoverable WebAuthn credential [3] consisting of a public and private key pair

NOTE 1: Passkeys are ownership-based authentication factors ("something you possess"), but require an additional inherence-based ("something you are") or knowledge-based ("something you know") authentication step for use.

NOTE 2: Ergo, a passkey can be considered multi-factor authentication.

password: type of secret consisting of a sequence of characters used to authenticate a user's identity and authorize access to a protected resource or system

NOTE 1: Passwords are knowledge-based authentication factors ("*something you know*").

NOTE 2: Characters may include alphanumeric, special characters, symbols, or Unicode characters as supported by the target system.

NOTE 3: This definition encompasses passphrases, PINs, and other character-based authentication strings.

password management: systematic process of creating, storing, organising, retrieving, updating, and securely disposing of passwords throughout their lifecycle

NOTE 1: Password management includes both manual and automated processes.

NOTE 2: This can include administrative functions such as password policy enforcement, rotation scheduling, and compliance monitoring.

phishing: cybercrime technique in which attackers distribute malicious communications impersonating legitimate services

NOTE: The communications may carry malware or ransomware, or induce the recipient to reveal sensitive information (such as a password) or to transfer money.

principle of least privilege: delegating access or authority such that the level of permission granted is commensurate with the level needed to undertake the action required, but not more.

product: Products with digital elements that store passwords, locally on a device or on a remote server, including activities such as generation of passwords as well as password sharing and integration with local or third-party applications for usage of passwords. This category includes but is not limited to local password managers, password managers provided as browser extensions, enterprise password managers as well as hardware-based password managers.

NOTE: As defined in [i.2].

secret: information whose confidentiality is to be protected, known only to authorized entities, and used to establish or maintain a security property such as authentication, authorization, confidentiality, or integrity

session: period of time within which permission has been granted to use the unlocked contents of the vault

target system: computing system, application, service, or protected resource for which the product provides credentials or other authentication secrets for the purpose of user authentication and authorization

usage of password: act of retrieving and applying a stored password for authentication purposes, including manual entry, automated form filling, API-based submission, or programmatic authentication

NOTE 1: Usage includes both interactive (user-initiated) and non-interactive (system-initiated) authentication events.

NOTE 2: This encompasses password disclosure to the user for manual entry and automated injection into authentication interfaces.

user, individual: person who uses the product for personal and/or professional purposes

user, group: member of a group like a family or household, who may use the same device with different accounts or have a manager who allocates and revokes permissions

user, organisational: team member or employee who has personal and potentially role-based access to vaults. Some of these users are administrators with elevated permissions and the ability to set and adapt policies

vault: encrypted container storing the collection of managed passwords, credentials, and associated metadata for the product's exclusive use

3.2 Symbols

Void.

3.3 Abbreviations

For the purposes of the present document, the following abbreviations apply:

ABAC	Attribute-Based Access Control
AC	Access Control
AEAD	Authenticated Encryption with Associated Data
AES	Advanced Encryption Standard
ANSSI	Agence nationale de la sécurité des systèmes d'information
API	Application Programming Interface
APT	Advanced Persistent Threat
BSI	Bundesamt für Sicherheit in der Informationstechnik
CIAA	Confidentiality, Integrity, Availability, Authenticity
CNIL	Commission Nationale de l'Informatique et des Libertés

CPU	Central Processing Unit
CRA	Cyber Resilience Act
CSP	Content Security Policy
CSRNG	Cryptographically Secure Random Number Generator
CTAP	Client to Authenticator Protocol
CTAP2	Client to Authenticator Protocol version 2
DDoS	Distributed Denial-of-Service
DOM	Document Object Model
ECCG	European Cybersecurity Certification Group
ENISA	European Union Agency for Cybersecurity
EU	European Union
EUVD	European Union Vulnerability Database
FIPS	Federal Information Processing Standards
GHSA	GitHub Security Advisory
IAM	Identity and Access Management
IID	Independent and Identically Distributed
ISO	International Organisation for Standardization
KDF	Key Derivation Function
MFA	Multi-Factor Authentication
MSP	Managed Service Provider
NCSC	UK National Cyber Security Centre
NFC	Near-Field Communication
NIST	National Institute of Standards and Technology
OS	Operating System
OTP	One-Time Password
PAM	Privileged Access Management
PIN	Personal Identification Number
RAM	Random Access Memory
RBAC	Role-Based Access Control
RDPS	Remote Data Processing Solution
RNG	Random Number Generator
SAML	Security Assertion Markup Language
SBOM	Software Bill of Materials
SSO	Single Sign-On
SU	Secure Update
TLS	Transport Layer Security
TOTP	Time-based One-Time Password
TPM	Trusted Platform Module
UC	Use Case
URL	Uniform Resource Locator
USB	Universal Serial Bus
VEX	Vulnerability Exploitability eXchange
XSS	Cross-Site Scripting

4 Product context

4.1 Product Functions

The product's primary function is the secure storage and retrieval of passwords and other managed credentials, held locally on a device, on a remote server, or across both, with the purpose of facilitating credential management for the user.

The product's functions decompose hierarchically. Storage and retrieval is the base function and is present in every product within scope. Credential generation extends this base, using secure randomness to produce passwords or other credential material on demand. Active credential management extends the product further, and may include credential health checks, breach exposure detection, rotation prompts, and other features that act on stored credentials over time rather than merely holding them. A product that performs only storage and retrieval is within scope; a product that adds generation, active management, or both, is within scope at the corresponding extended capability.

Multi-user and synchronisation functions are independently selectable extensions. Multi-user support enables the management of individual and shared credentials across several users, as in an enterprise environment. Synchronisation enables a single user's credential collection to remain consistent across multiple devices. Either, both, or neither may be present.

Some products further function as guidance agents, directing the user toward more secure choices. This may include encouraging the use of strong passwords (through secure generation by default for new entries, password strength indicators, alerts for password reuse, and notification of credentials observed in known data breaches), or supporting the management of other stored credential types such as passkeys (through support for WebAuthn Conditional Create for automatic password-to-passkey uplift, or WebAuthn Signal API usage for automatic stored passkey validity management from supporting services) [4] and [5].

Configuration functions are within scope wherever they govern the behaviour of the functions above, including the selection of storage location, the parameters of credential generation, the policies applied by active credential management, the boundaries of multi-user sharing, and the scope of synchronisation.

Where the product contributes to credential-handling services delivered as part of a wider system (for example, single-sign-on flows, enterprise identity platforms, or relying-party authentication exchanges), those services are not themselves functions of the product. The product's role in such services is limited to the storage, retrieval, generation, management, and guidance functions described above.

4.2 Product Architecture

The password manager architecture may consist of many or all of the following fundamental components operating in concert to provide secure credential management:

- 1) **Cryptographic Engine:** Main component handling all encryption/decryption operations for stored credentials. Implements layered encryption with multiple independent algorithms for defence-in-depth. Supports cryptographic agility through modular algorithm selection and runtime substitution without data migration. Manages key derivation, key storage, and secure key rotation. Provides an abstraction layer between application logic and underlying cryptographic primitives, enabling algorithm updates without application changes.
- 2) **Vault Storage Layer:** The persistent storage mechanism that maintains the encrypted password and managed credential database. This layer enables functionality such as indexing, management and organisation of data and credentials as well as providing additional business logic if the use-case requires it. This is potentially RDPS.
- 3) **Authentication Module:** The gatekeeper component managing master password verification, multi-factor authentication integration, biometric authentication processing, and session management. This module implements anti-hammering protections, secure session token generation, authentication attempt logging, and timeout mechanisms, serving as the primary access control enforcement point. This is potentially RDPS.
- 4) **User Interface Layer:** The presentation and interaction component providing password entry forms, vault browsing interfaces, password generation controls, and security status indicators. Implementations include native desktop applications, mobile applications, web interfaces, browser extensions, and command-line interfaces, each adapted to platform-specific security models and user interaction patterns.
- 5) **Integration Services:** The interoperability layer enabling browser autofill through DOM manipulation or native messaging APIs, application integration via accessibility APIs or clipboard management, API endpoints for programmatic access, and import/export functionality for data portability. This component manages the security boundaries between the password manager and external systems.
- 6) **Synchronisation Service:** The replication and conflict resolution mechanism ensuring consistent vault state across multiple devices through encrypted sync protocols utilizing hybrid key exchange mechanisms, differential synchronisation algorithms with cryptographic message authentication, and end-to-end encryption ensuring provider-blind synchronisation where service operators cannot access vault contents regardless of their computational capabilities. This is potentially RDPS.

- 7) **Passkey Service:** Products supporting passkeys for both credential storage and challenge signing, and web services that accept passkeys as an authentication method follow external implementation requirements. Passkey technical requirements are outlined as discoverable WebAuthn credentials and FIDO Client to Authenticator Protocol 2 (CTAP2) [4] and [5], detailed within W3C Web Authentication (WebAuthn) Level 2 [3].

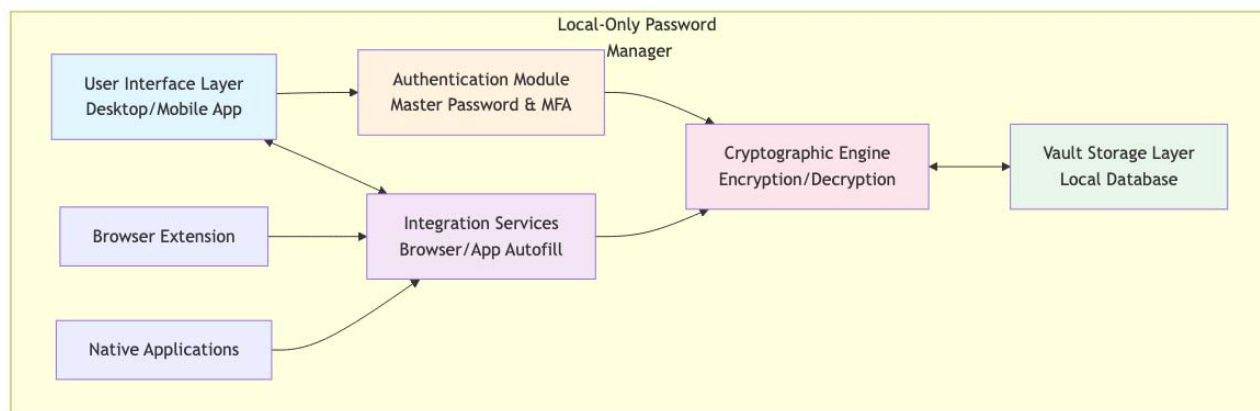


Figure 4.2-1: Sample Architecture of a Local-Only Password Manager

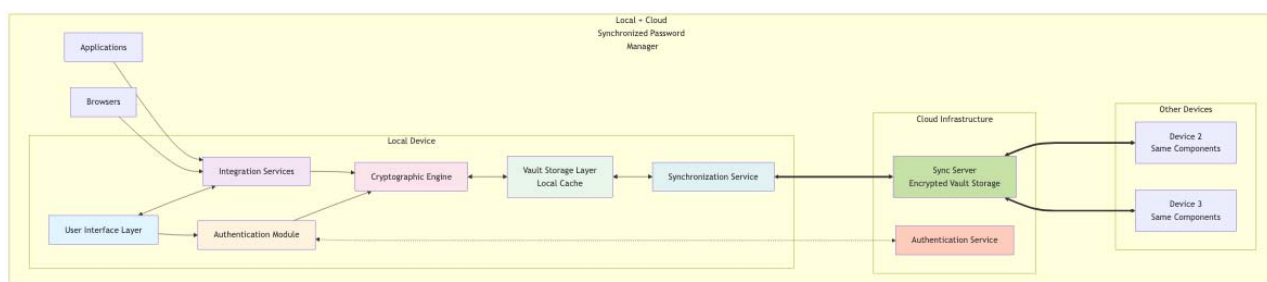


Figure 4.2-2: Sample Architecture of a Synchronising Password Manager

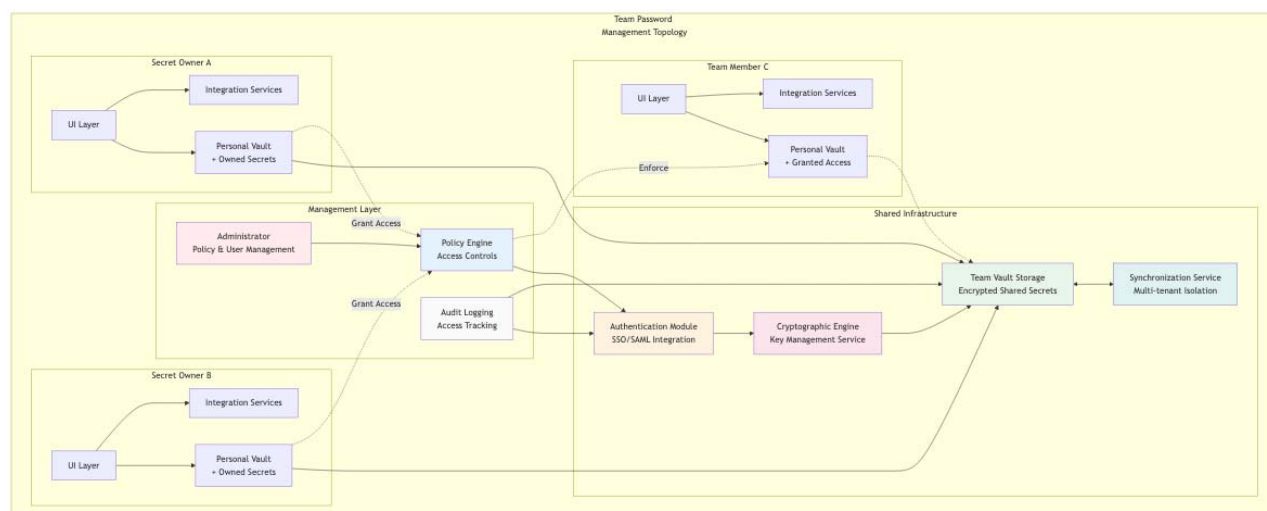


Figure 4.2-3: Sample Architecture of an Enterprise-Managed Password Manager

4.3 Operational Environment

4.3.1 General description

The product stores and retrieves user credentials on behalf of the user, with the goal of maintaining confidentiality and integrity throughout. It operates on general-purpose host devices, including personal computers, mobile devices, and shared workstations, running multiple concurrent applications under an operating system the product does not control.

Where the product takes the form of a browser extension or interacts with web content, it operates within browser environments that load content from arbitrary origins. Where the product takes the form of a server-side component, it operates within hosting infrastructure shared with other tenants.

The product integrates with adjacent systems through the host operating system's credential and authentication facilities, web browsers and their extension interfaces, mobile platform autofill and biometric frameworks, relying-party authentication endpoints, enterprise identity services where deployed in a managed context, and synchronisation or backup endpoints where present. The product's operational boundary ends at the point of presentation to a relying party.

The product communicates over shared network infrastructure of varying trust, from residential and public networks to enterprise networks, and is expected to retain its security properties under partial or hostile network conditions. Host devices may be located in private dwellings, offices, vehicles, public spaces, or transit, and the product is expected to retain its security properties under conditions including unattended devices, shared physical access, and loss or theft of the host. External conditions affecting any remote data-processing components are those typical of commercial hosting environments.

The credentials the product manages are high-value assets subject to active interest from threat actors. The operational environment accordingly encompasses storage at rest on the host and on remote infrastructure where applicable, transmission across networks of varying trust, and presentation to applications, browsers, or web content at the point of use.

4.3.2 Hardware environment

The product operates on host hardware outside its direct control. The host may take the form of a personal laptop, shared workstation, smartphone, tablet, or dedicated hardware token, and may be transported between environments ranging from controlled office settings to public or shared spaces. The underlying hardware varies across deployment targets and may or may not include security features such as secure enclaves or trusted platform modules. Storage, memory, and firmware constitute distinct layers of the hardware stack with differing characteristics. Physical access to the host by parties other than the user is a foreseeable condition during the device's operational lifetime. Where the product relies on remote data-processing components, the hardware environment of those components is that of commercial hosting infrastructure.

4.3.3 Software environment

There are five main types of software environment for password manager:

Operating System-Level: System-integrated credential management leveraging OS security primitives, kernel-level protection mechanisms, and platform-specific secure storage, enabling cross-application credential sharing through system APIs.

Standalone Application: Independent password management applications operating in user space.

Browser-Integrated: Password management functionality embedded within web browsers, providing native integration with web authentication flows while operating within browser security constraints and update cycles.

Browser Extension: The product operates as a sandboxed component within the browser process, interacting with web page content through DOM access and communicating with the browser runtime and optionally a native host process. Its operational environment is bounded by the browser's extension permission model and marketplace update infrastructure.

Website: The product operates as a remotely delivered web application with no local installation. Its environment is defined by transport security, server-side session infrastructure, and browser content security policy enforcement.

4.3.4 Connectivity aspects

The synchronisation model fundamentally determines the availability, consistency, and security properties of password management systems. These can generally be considered Remote Data Processing Solutions, and as such should be reviewed in consideration of Annex R. In case the cloud synchronisation is entirely managed by a third party, due diligence is required commensurate with clause 4.4 of the present document.

Cloud synchronized, with or without local persistence: Solutions utilizing RDPS or a third-party for credential replication, providing device-agnostic access through synchronisation services.

Local Only, without remote persistence: Non-synchronised implementations maintaining credentials exclusively within a single device or defined security perimeter, eliminating network attack vectors while constraining availability to the local environment.

4.4 Distribution of Security Functions

Where a password manager depends on, embeds, or is combined with another product or component, security functions may be distributed across more than one responsible party. The integrating manufacturer retains due-diligence obligations for the combined product's security posture, and should identify which party is responsible for each function below.

The following scenarios are recognized as giving rise to distributed responsibilities, and should each be addressed in the product's security documentation:

- **Synchronisation between devices:** confidentiality and integrity of credential data in transit, including the trust model for each synchronisation endpoint.
- **Update mechanisms:** authenticity and integrity of delivered updates, and the chain of trust from signing authority to installed component; potentially consult Annex R.
- **Browser extension integration:** the isolation boundary between the extension and host browser, and interfaces exposed to web content or other extensions.
- **Integration with another product:** responsibility for the security functions below should be explicitly allocated in the integration agreement or technical documentation.

Regardless of how functions are distributed, the following should be maintained across the combined product:

- **Encryption at rest:** credentials and sensitive metadata should be encrypted in accordance with Annex K.
- **Key derivation:** master passwords should be processed through a computationally-intensive or memory-intensive key derivation function in accordance with Annex K.
- **Secure Randomness:** for generation of passwords and other methods of deriving secrets in general.
- **Transport security:** network communications should be secured in accordance with Annex K, with a strong preference for TLS 1.3 or higher version.
- **Authenticated access:** access to the credential store should require explicit authentication; bypass mechanisms can be permitted in lower-risk scenarios provided they do not weaken the underlying authentication boundary.

The following additional protections are recommended where the platform permits:

- protection of credentials in process memory against disclosure through swap, crash dumps, or inter-process inspection;
- isolation of the password manager process from other applications;
- resilience against side-channel attacks, including the use of constant-time comparison for authentication-critical operations;

- safe handling of shared platform resources, in particular ensuring that credential data placed on the system clipboard is cleared after a short, configurable timeout.

Where the password manager is delivered as or includes a browser extension, its security posture is partially derived from the security properties of the host browser and the underlying operating system.

Where a security function is delegated to the operating system, platform or third-party component, the product's technical documentation should advise about the delegation, identify the component version and provenance, and assess the adequacy of that component's security posture.

Where a product incorporates a component that qualifies as a remote data processing solution RDPS (such as a cloud synchronisation backend, a server-side credential store, or a hosted key management service), the distribution of security functions spans a trust boundary between the local product and that remote component.

The technical product documentation should describe which security functions are implemented locally and which are delegated to the RDPS component, and to identify the mechanisms by which the integrity and confidentiality of that boundary are maintained. The applicable risk level, determined in accordance with respective clauses in 5, governs which of the functions or assets apply to the combined product inclusive of its RDPS component. Consult Annex R for further details about the additional requirements RDPS place on the product functionality.

4.5 Users

User categories follow the definitions in clause 3.1 and are characterised by need rather than profession.

Individual users manage personal credentials with a focus on user autonomy and a simplified security model appropriate to consumer threat profiles. This category includes privacy-conscious users, users with elevated personal threat exposure, vulnerable users including children and the elderly where the product is offered to them, and users relying on assistive technology to access the product.

Family or household groups operate multi-user deployments with hierarchical access control and selective credential sharing, requiring privacy between members while enabling oversight, shared access, and emergency provisions.

Organisational deployments cover centralized administration, policy enforcement, and credential management at scale, supporting compliance and privileged-access requirements including logging. Within these deployments, users include administrators with privileged rights, ordinary end users with no privileged role, and integrators connecting the product to adjacent systems.

Accessibility, health, and safety considerations apply across all user categories and are not confined to any one of them.

4.6 Use Cases

4.6.1 UC-1: Local Password Manager

Goal: Store and retrieve user credentials exclusively on the user's device, without network connectivity or cloud synchronisation, providing complete data ownership and offline operation.

Description:

- Product type: Standalone application storing encrypted vaults locally on a single device or within a defined security perimeter.
- Function: Base storage and retrieval of passwords and other managed credentials held locally on the device. Credential generation and active credential management (health checks, breach exposure detection, rotation prompts) may be present as extensions to the base function. Neither multi-user support nor synchronisation is present.
- Users: Individual users managing personal credentials, including privacy-conscious users, users with elevated personal threat exposure, vulnerable users where the product is offered to them, and users relying on assistive technology.

- Architecture: Cryptographic engine, vault storage layer, authentication module, user interface layer, and (where applicable) integration services for browser autofill or application integration. No synchronisation service and no remote data processing solution component.
- Operational environment: General-purpose host hardware (desktop workstation, mobile device, or portable medium such as a USB drive for air-gapped systems) running an operating system the product does not control. Physical access to the host by parties other than the user is foreseeable. No network attack surface arising from synchronisation.

Example Environments:

- Desktop applications on desktop workstations.
- Mobile applications with local-only storage.
- Portable applications on USB drives for air-gapped systems.

Risk Considerations:

- no remote wipe capability (confidentiality);
- backup responsibility falls entirely on user (integrity);
- device loss or theft represents single point of failure (availability);
- unauthorised user on a shared device (authenticity).

The security analysis of this use case is detailed in clause B.2.1.

4.6.2 UC-2: Password Manager Application with Remote-Based Resources

Goal: Provide credential storage, retrieval, and management through a service in which the vault is held and processed in remote infrastructure, accessed by the user through a local application or browser.

Description:

- Product type: Password manager in which the vault is stored and managed entirely in remote infrastructure, accessed through a thin client, browser interface, or mobile application.
- Function: Storage and retrieval of credentials, with persistence and primary processing on remote infrastructure. Credential generation, active credential management, multi-user support, and synchronisation may be present.
- Users: Individual users with hosted personal vaults, family or household groups with hosted shared vaults, and organisational deployments.
- Architecture: Standard component set operating predominantly within the remote infrastructure, exposed through a user interface layer delivered as a web application, mobile application, or local client. The vault storage layer, authentication module, and synchronisation service are Remote Data Processing Solutions (Annex R).
- Operational environment: A trust boundary spans the network between the host device and remote infrastructure, which is commercial hosting infrastructure potentially multi-tenant and operated by the manufacturer or a third party.

Example Environments:

- Web-based vault access through browser interfaces.
- Mobile applications with remote-only storage.
- Enterprise deployments with centralized administration

- Multi-tenant architectures with logical separation.

Risk Considerations:

- communication methodology with remote resources (confidentiality);
- provider compromise affects all users (integrity);
- dependency on network connectivity (availability);
- user impersonation at the remote endpoint (authenticity);

The security analysis of this use case is detailed in clause B.2.2.

4.6.3 UC-3: Hybrid Local and Remote-Based

Goal: Provide credential storage and retrieval that operates against a local copy of the vault for offline access, while maintaining consistency with a remote copy to enable synchronisation across the user's devices.

Description:

- Product type: Password manager maintaining encrypted copies of the vault both on the user's device and in remote storage that may be controlled by the manufacturer or a third party.
- Function: Storage and retrieval of credentials, with local persistence replicated to remote storage through synchronisation. Credential generation, active credential management, and multi-user support may be present.
- Users: Individual users across multiple personal devices, family or household groups, and organisational deployments where local caching supports performance or offline availability.
- Architecture: Standard component set present on each device, together with a synchronisation service mediating between local and remote copies. The remote copy and the synchronisation service are Remote Data Processing Solutions (Annex R); where remote storage is third-party operated, clause 4.4 applies.
- Operational environment: General-purpose host devices each holding a local copy, with a trust boundary spanning the network to remote storage in commercial hosting infrastructure.

Example Environments:

- Desktop applications with cloud backup and sync.
- Mobile apps with cached offline vaults.
- Enterprise deployments with local caching for performance.
- Travel scenarios requiring offline access with periodic sync.

Risk Considerations:

- cloud-stored credentials may be accessible to provider (confidentiality)
- increased attack surface across multiple storage locations (integrity);
- provider failure may break cross-device workflows (availability);
- replay attack may restore or leverage a stale or outdated state (authenticity).

The security analysis of this use case is detailed in clause B.2.3.

4.6.4 UC-4: Browser Extension Password Manager

Goal: Provide credential storage, retrieval, and autofill through an add-on component installed in the user's browser, with deep integration into web forms and authentication flows.

Description:

- Product type: Password manager delivered as a browser extension, operating within the host browser's sandbox and extension permission model. Where the extension is paired with local storage or remote storage, UC-1, UC-2, or UC-3 applies concurrently.
- Function: Storage and retrieval of passwords and other managed credentials, with integration into web forms and authentication flows as a primary mode of presentation to relying parties. Credential generation, active credential management, and guidance agent functions for passkey support may be present.
- Users: Individual users managing personal credentials through their browser, family or household groups, and organisational deployments where the extension is provisioned and managed centrally.
- Architecture: Cryptographic engine, vault storage layer, authentication module, and user interface layer operating within the browser process. Integration services interact with web content through DOM access and with the browser runtime through extension APIs. The security posture is partially derived from the host browser and underlying operating system, and clause 4.4 applies.
- Operational environment: Host browser running on a general-purpose device under an operating system the product does not control, loading content from arbitrary origins. The extension operates alongside other extensions and receives updates through the browser marketplace or enterprise management channel rather than directly from the manufacturer.

Example Environments:

- Browser extension stores.
- Browser-based deployments.
- Enterprise browser management through group policy.
- Web application testing environments.

Risk Considerations:

- extension storage is potentially accessible to other installed extensions and the browser itself (confidentiality);
- browser vulnerabilities affect extension security (integrity);
- extension updates delivered through the browser marketplace bypass user control (availability);
- weaknesses in trust chain are inherited (authenticity);

The security analysis of this use case is detailed in clause B.2.4.

4.6.5 UC-5: Enterprise Password Manager

Goal: Provide centrally administered credential storage, retrieval, and policy enforcement across an organisation, with integration into enterprise identity infrastructure and privileged access workflows.

Description:

- Product type: Password manager deployed under organisational administration, supporting scale of thousands of users and millions of credentials. Commonly composed with UC-2 or UC-3 for the underlying storage model.
- Function: Storage and retrieval of credentials with multi-user support, including hierarchical access control, selective sharing, policy enforcement, privileged access management, and logging. Credential generation, active credential management, and synchronisation are typically present.
- Users: Administrators with privileged rights, ordinary end users, and integrators connecting the product to adjacent identity systems.

- Architecture: Standard component set extended with an administrative interface, policy engine, audit and logging subsystem, and integration services for enterprise identity infrastructure. Backend components are Remote Data Processing Solutions (Annex R); clause 4.4 applies to identity-infrastructure integrations.
- Operational environment: Managed host devices under organisational policy, with backend components in commercial or organisational hosting infrastructure. Trust boundaries span both the network and the administrative privilege hierarchy.

Example Environments:

- Active Directory integrated deployments.
- Privileged Access Management (PAM) systems.
- Admin Web Panel
- Managed Service Provider (MSP) multi-tenant systems.

Risk Considerations:

- inappropriate sharing of data between users and groups (confidentiality)
- insider threats with administrative access (integrity);
- scale amplifies breach impact (availability);
- activity cannot be reliably attributed to an individual actor (authenticity).

The security analysis of this use case is detailed in clause B.2.5.

4.6.6 UC-6: Hardware-Based Password Manager

Goal: Provide credential storage and retrieval through a dedicated physical device with a secure element, requiring physical possession for access and providing security through hardware isolation.

Description:

- Product type: Password manager implemented as a physical device with a dedicated secure element, used standalone or paired with a host through USB, NFC, or similar interface.
- Function: Storage and retrieval of credentials held within the secure element. Credential generation may be present; active credential management, multi-user support, and synchronisation are typically absent or limited.
- Users: Individual users requiring strong possession-based access control, and organisational deployments where hardware tokens are issued under policy.
- Architecture: Cryptographic engine and vault storage layer within the secure element, with the authentication module bound to physical possession and an optional on-device user interface. Integration services mediate presentation to a paired host where present.
- Operational environment: Self-contained device transported by the user across environments ranging from controlled settings to public spaces, with physical access by other parties a foreseeable condition. When paired with a host, the host is outside the product's control.

Example Environments:

- USB security keys with password storage.
- Smart cards with credential management.
- Hardware wallets adapted for passwords.
- Offline password safes with displays.

Risk Considerations:

- If decrypted on device and transported in clear text (confidentiality);
- physical tampering may go unnoticed (integrity);
- physical theft or loss (availability);
- unauthorised writing/overwriting of credentials (authenticity).

The security analysis of this use case is detailed in clause B.2.6.

5 Technical requirements for Products

5.1 Introduction - Applicability of the requirements

The technical requirements of the present document apply under the product context described in Clause 4, which shall be in accordance with its intended use. The product shall comply with all applicable technical requirements of the present document at all times when operating in such a product context.

Three risk levels are defined: Normal, High, and Critical. Normal addresses the protection of personal credentials against opportunistic adversaries; High addresses business or professional credentials, wider attack surfaces, and targeted attack; Critical addresses deployments where compromise would have systemic consequences and where adversaries are assumed to be well-resourced and persistent.

Requirements are cumulative across the three levels: a product at the High level meets the High-level requirements together with all Normal-level requirements, and a product at the Critical level meets the Critical-level requirements together with all High-level and Normal-level requirements

Not all requirements are universally applicable: The applicability of requirements may be based on use cases or specific capabilities of the product.

Table 5.1.1: Allocation of Risk Levels to Use Cases

Description	Essential Requirements of Regulation (EU) 2024/2847	Sub-clause Clause(s) of the present document (requirements / assessment)	UC-1 B.2.1 Local	UC-2 B.2.2 Remote	UC-3 B.2.3 Hybrid	UC-4 B.2.4 Browser ext.	UC-5 B.2.5 Enterprise	UC-6 B.2.6 Hardware
Annex I, Part I, (1)	<i>"Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks."</i>	Clauses 5 and 6 (5.2 / 6.2)	High	Critical	Critical	High	Critical	High
Annex I, Part I, (2)(a)	<i>"Products with digital elements shall be made available on the market without known exploitable vulnerabilities."</i>	5.3 / 6.3	Normal	Normal	Normal	Normal	Normal	Normal

Description	Essential Requirements of Regulation (EU) 2024/2847	Sub-clause Clause(s) of the present document (requirements / assessment)	UC-1 B.2.1 Local	UC-2 B.2.2 Remote	UC-3 B.2.3 Hybrid	UC-4 B.2.4 Browser ext.	UC-5 B.2.5 Enterprise	UC-6 B.2.6 Hardware
Annex I, Part I, (2)(b)	<i>"Products with digital elements shall be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state."</i>	5.4 / 6.4	Normal	Normal	Normal	Normal	Normal	Normal
Annex I, Part I, (2)(c)	<i>"Products with digital elements shall ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them."</i>	5.5 / 6.5	Normal	Critical	Critical	Critical	Critical	Critical
Annex I, Part I, (2)(d)	<i>"Products with digital elements shall ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible</i>	5.6 / 6.6	High	High	High	High	Critical	High

Description	Essential Requirements of Regulation (EU) 2024/2847	Sub-clause Clause(s) of the present document (requirements / assessment)	UC-1 B.2.1 Local	UC-2 B.2.2 Remote	UC-3 B.2.3 Hybrid	UC-4 B.2.4 Browser ext.	UC-5 B.2.5 Enterprise	UC-6 B.2.6 Hardware
	<i>unauthorised access."</i>							
Annex I, Part I, (2)(e)	<i>"Products with digital elements shall protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by best practice mechanisms, and by using other technical means."</i>	5.7 / 6.7	High	Critical	Critical	Critical	Critical	Critical
Annex I, Part I, (2)(f)	<i>"Products with digital elements shall protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions."</i>	5.8 / 6.8	Normal	Normal	Normal	Normal	Normal	Normal
Annex I, Part I, (2)(g)	<i>"Products with digital elements shall process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation)."</i>	5.9 / 6.9	Normal	Normal	Normal	Normal	Normal	Normal

Description	Essential Requirements of Regulation (EU) 2024/2847	Sub-clause Clause(s) of the present document (requirements / assessment)	UC-1 B.2.1 Local	UC-2 B.2.2 Remote	UC-3 B.2.3 Hybrid	UC-4 B.2.4 Browser ext.	UC-5 B.2.5 Enterprise	UC-6 B.2.6 Hardware
Annex I, Part I, (2)(h)	<i>"Products with digital elements shall protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks."</i>	5.10 / 6.10	Normal	Normal	Normal	Normal	Normal	Normal
Annex I, Part I, (2)(i)	<i>"Products with digital elements shall minimise the negative impact by the products themselves or connected products on the availability of services provided by other products or networks."</i>	5.11 / 6.11	Normal	Normal	Normal	Normal	Normal	Normal
Annex I, Part I, (2)(j)	<i>"Products with digital elements shall be designed, developed and produced to limit attack surfaces, including external interfaces."</i>	5.12 / 6.12	Normal	Critical	Critical	Critical	Critical	Normal
Annex I, Part I, (2)(k)	<i>"Products with digital elements shall be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques."</i>	5.13 / 6.13	Normal	Normal	Normal	Normal	Normal	Normal

Description	Essential Requirements of Regulation (EU) 2024/2847	Sub-clause Clause(s) of the present document (requirements / assessment)	UC-1 B.2.1 Local	UC-2 B.2.2 Remote	UC-3 B.2.3 Hybrid	UC-4 B.2.4 Browser ext.	UC-5 B.2.5 Enterprise	UC-6 B.2.6 Hardware
Annex I, Part I, (2)(l)	"Products with digital elements shall provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user."	5.14 / 6.14	Normal	Critical	Critical	Normal	Critical	Normal
Annex I, Part I, (2)(m)	"Products with digital elements shall provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner."	5.15 / 6.15	Normal	High	High	Normal	Critical	Normal

NOTE 1: Annex I Part I (1) (overarching obligation that the product ensures an appropriate level of cybersecurity based on the risks) is addressed across Clause 5 as a whole, with sub-clause 5.2 / 6.2 carrying the explicit 'appropriate level of cybersecurity' requirement and assessment. The per-use-case tier in this row reflects the tier required for that sub-clause.

NOTE 2: Where Clause 5 defines only the Normal tier for a given essential requirement (5.3, 5.4, 5.8, 5.9, 5.10, 5.11, 5.13), all use cases are assigned Normal. The use-case severity differential is carried by the requirements in 5.2, 5.5, 5.6, 5.7, 5.12, 5.14 and 5.15.

Use case legend. UC1: Local password manager (clause B.2.1). UC2: Password manager application with remote-based resources (clause B.2.2). UC3: Hybrid local and cloud (clause B.2.3). UC4: Browser extension (clause B.2.4). UC5: Enterprise password manager (clause B.2.5). UC6: Hardware-based password manager (clause B.2.6)

NOTE 3: Each risk level either applies unconditionally to all products in scope, or applies only to the specific use cases identified in its description.

Some products are likely to selectively offer certain multifactor authentication technologies as features, such as passkeys or TOTP. If the product does not exhibit the feature, relevant requirements and assessments are moot.

5.2 Appropriate level of cybersecurity

5.2.0 Introduction

This clause addresses the requirements in the CRA [i.1], Annex I Part I.

5.2.1 Normal Risk

5.2.1.0 Applicability: All UC

5.2.1.1 REQ-AC-NORM-1: Secure secret generation shall use Cryptographically Secure Random Number Generators (CSRNG).

5.2.1.2 REQ-AC-NORM-2: If the product offers passkeys as a storable credential type, it shall securely implement passkey functionality following the relevant W3C WebAuthn [3] and FIDO CTAP 2.2 [4] or 2.3 [5] requirements for implementing Authenticators.

5.2.1.3 REQ-AC-NORM-3: If the product offers TOTP-type protocol participation as a storable credential type, it shall implement TOTP functionality following the relevant IETF RFC 6238 [1] and IETF RFC 4226 [2] requirements.

5.2.2 High Risk

5.2.2.0 Applicability: All UC

5.2.2.1 REQ-AC-HIGH-1: Generated passwords shall by default have 80 or more bits of entropy. If the user reduces that strength in order to comply with lesser requirements as defined by the target system, the product shall warn the user.

5.2.3 Critical Risk

5.2.3.0 Applicability: UC-2, UC-3, UC-5

5.2.3.1 REQ-AC-CRIT-1: Generated passwords shall meet or exceed the minimum p-value requirements for Independent and Identically Distributed (IID) evaluation, as defined by the target system or security policy.

5.3 No known exploitable vulnerabilities

5.3.0 Introduction

This clause addresses the requirements in the CRA [i.1], Annex 1 Part I (2) (a).

5.3.1 Normal Risk

5.3.1.0 Applicability: All UC

5.3.1.1 REQ-KEV-NORM-1: The product shall be free from exploitable vulnerabilities that can be classified as impacting the confidentiality, integrity, authenticity, or availability of one of the product's assets as listed in clauses B.1.1.1, B.1.1.2, B.1.1.3, or B.1.1.4.

5.4 Secure by default configuration

5.4.0 Introduction

This clause addresses the requirements in the CRA [i.1], Annex 1 Part I (2) (b).

NOTE: The CRA [i.1] essential requirement laid out in Annex 1 Part I (2) (b) foresees an applicability exception to the secure configuration by default in case there is an agreement between manufacturer and business user in relation to a tailor-made product with digital elements.

5.4.1 Normal Risk

5.4.1.0 Applicability: All UC

5.4.1.1 REQ-SD-NORM-1: The product shall enforce minimum master password complexity on creation using an entropic level commensurate with a cited standard in line with Annex K or configured by local policy for enterprise use-cases.

NOTE 1: ENISA suggests a complexity of 8+ characters using different types of characters [i.5].

NOTE 2: BSI suggests "short and complex", or "long and less complex" for sufficient password complexity [i.6].

Examples:

- It is 20 to 25 characters long and uses two types of characters (e.g. a sequence of words). This kind of password is long and less complex.
- It is eight to 12 characters long and uses four types of characters. This kind of password is short and complex.
- It is eight characters long, uses three types of characters and is also protected by multi-factor authentication

NOTE 3: NCSC suggests achieving sufficient password complexity through length rather than enforcement of multiple character classes. The "three random words" password / passphrase construction is recommended as a user memorable approach [i.7].

NOTE 4: CNIL suggest master passwords to be particularly strong, while generally advising passwords for single factor authentication to achieve a minimum of 80 bits of entropy (e.g. through passwords of 12+ characters with four character classes, or 14+ characters with three character classes) [i.8].

NOTE 5: NIST requires 15+ characters for passwords used as a single factor authentication method, or 8+ characters when combined as part of an MFA approach. Character class stipulations are explicitly prohibited within this guidance, however, restrictions on commonly used, expected or leaked passwords is permitted [i.9].

5.4.1.2 REQ-SD-NORM-2: The product shall mask master password entry fields on the user interface by default unless overridden by the user.

5.5 Security updates

5.5.0 Introduction

This clause addresses the requirements in the CRA [i.1], Annex I, Part I (2) (c).

NOTE: Some application marketplaces or operating systems manage this for the product, and in those cases, then to be considered under clause 4.4 requiring manufacturer due diligence and documented appropriately.

5.5.1 Normal Risk

5.5.1.0 Applicability: All UC

5.5.1.1 REQ-SU-NORM-1: The product shall implement automatic secure update before or during first use.

5.5.1.2 REQ-SU-NORM-2: The product's update process shall verify the authenticity of update packages prior to applying the update.

5.5.1.3 REQ-SU-NORM-3: The product's update process shall reject the installation of updates that fail the verification of the authenticity of the update

5.5.1.4 REQ-SU-NORM-4: The product's update process shall verify the integrity of update packages prior to applying the update.

5.5.1.5 REQ-SU-NORM-5: The product's update process shall reject the installation of updates that fail the integrity verification.

5.5.2 High Risk (none)

5.5.3 Critical Risk

5.5.3.0 Applicability: UC-2, UC-3, UC-4, UC-5, UC-6

5.5.3.1 REQ-SU-CRIT-1: The product shall maintain a monotonic version counter or equivalent mechanism to prevent unauthorised installation of an older version.

5.5.3.2 REQ-SU-CRIT-2: If the product supports intentional rollback, this action shall require explicit authorisation.

5.6 Authentication and Access Control

5.6.0 Introduction

This clause addresses the requirements in the CRA [i.1] Annex I, Part I (2) (d).

5.6.1 Normal Risk

5.6.1.0 Applicability: All UC

5.6.1.1 REQ-AC-NORM-1: Unless the product user authentication is managed at the operating system or host level, unlocking or decrypting the vault shall require at least one explicit authentication per user session.

5.6.1.2 REQ-AC-NORM-2: The product shall implement an appropriate Key Derivation Function (KDF) to derive encryption keys to secure the vault in line with cryptographic sources and requirements as found in Annex K.

5.6.1.3 REQ-AC-NORM-3: The product shall support multi-factor authentication as an available authentication option.

NOTE 1: Configurable MFA approaches can include, but are not limited to, the following:

- TPM-based or roaming FIDO2 credentials (e.g. passkeys)
- Challenge-based authenticator applications
- Biometrics
- Application or hardware-based OTP codes
- Keyfiles
- Message-based methods (email, SMS and call-based)

5.6.1.4 REQ-AC-NORM-4: The product shall enforce user-defined policy-dependent session timeout and re-authentication.

NOTE 2: Some products also leverage "auto-extending" sessions, where repeated user interaction (i.e. filling passwords) extends the session.

5.6.2 High Risk

5.6.2.0 Applicability: All UC

5.6.2.1 REQ-AC-HIGH-1: The product shall enforce the principle of least privilege for all operations.

5.6.2.2 REQ-AC-HIGH-2: The product shall validate authorisation for each sensitive operation such as adding a new device, export, sharing of credentials.

5.6.3 Critical Risk

5.6.3.0 Applicability: UC-5

5.6.3.1 REQ-AC-CRIT-1: In the factory default configuration, multi-factor authentication shall be enforced for administrative access and security-sensitive administrative operations.

NOTE 1: The distribution of security functions might offload authentication to SSO services outside of the control of the product, and thus pre-empt MFA within the app.

5.6.3.2 REQ-AC-CRIT-2: The product shall implement exponential backoff for failed online password authentication attempts.

5.6.3.3 REQ-AC-CRIT-3: The product shall implement Role-Based Access Control (RBAC) or Attribute-Based Access Control (ABAC) for multi-user environments.

5.6.3.4 REQ-AC-CRIT-4: The product shall ensure that there is no exploitable gap between authorisation decision and operation execution by implementing atomic authorisation checks.

5.6.3.5 REQ-AC-CRIT-5: If the product allows resources to be shared at a given level of granularity, it shall allow permissions to be assigned at that same level of granularity.

NOTE 2: A resource is an item or a group of items that can be stored in a vault.

5.6.3.6 REQ-AC-CRIT-6: In the factory default configuration, the product shall implement online account lockout after failed attempts.

5.7 Confidentiality Protection

5.7.0 Introduction

This clause addresses the requirements in the CRA [i.1], Annex I, Part I (2) (e).

5.7.1 Normal Risk

5.7.1.0 Applicability: All UC

5.7.1.1 REQ-CON-NORM-1: The product shall use approved encryption algorithms to encrypt vault contents at rest in order to ensure confidentiality and integrity (e.g. using Authenticated Encryption with Associated Data) in accordance with Annex K.

5.7.2 High Risk

5.7.2.0 Applicability: All UC

5.7.2.1 REQ-CON-HIGH-1: The product shall use unique salts per vault in accordance with Annex K.

5.7.2.2 REQ-CON-HIGH-2: The product shall use encryption for all network transmissions in accordance with Annex K.

5.7.2.3 REQ-CON-HIGH-3: The product shall encrypt all backup data in accordance with Annex K.

5.7.3 Critical Risk

5.7.3.0 Applicability: UC-2, UC-3, UC-4, UC-5, UC-6

5.7.3.1 REQ-CON-CRIT-1: The product's RDPS shall offer perfect forward secrecy (PFS) for network transmissions in accordance with Annex K.

5.8 Integrity Protection

5.8.0 Introduction

This clause addresses the requirements in the CRA [i.1], Annex I, Part I (2) (f).

5.8.1 Normal Risk

5.8.1.0 Applicability: All UC

5.8.1.1 REQ-INT-HIGH-1: shall apply input validation to data submitted for import.

5.9 Data Minimisation

5.9.0 Introduction

This clause addresses the requirements in the CRA [i.1], Annex I, Part I (2) (g).

5.9.1 Normal Risk

5.9.1.0 Applicability: All UC

5.9.1.1 REQ-DM-NORM-1: shall prevent leaking of sensitive data into logging and telemetry systems.

5.10 Availability Protection

5.10.0 Introduction

This clause addresses the requirements in the CRA [i.1], Annex I, Part I (2) (h).

5.10.1 Normal Risk

5.10.1.0 Applicability: All UC

5.10.1.1 REQ-AP-NORM-1: Any recovery process shall be operationally or cryptographically brute-force resistant.

5.11 Non-interference

5.11.0 Introduction

This clause addresses the requirements in the CRA [i.1], Annex I, Part I (2) (i).

5.11.1 Normal Risk

5.11.1.0 Applicability: All UC

5.11.1.1 REQ-IM-NORM-1: The product shall not generate resource consumption such that system availability is degraded.

5.11.1.2 REQ-IM-NORM-2: The product shall not interfere with other products that would prevent other products from executing their normal expected functions, unless configured by the user.

5.12 Attack Surface Minimisation

5.12.0 Introduction

This clause addresses the requirements in the CRA [i.1], Annex I, Part I (2) (j).

5.12.1 Normal Risk

5.12.1.0 Applicability: All UC

5.12.1.1 REQ-MAS-NORM-1: The product shall implement Content Security Policy (CSP) following the principle of least privilege in web applications and browser extensions.

5.12.2 High Risk (none)

5.12.3 Critical Risk

5.12.3.0 Applicability: UC-2, UC-3, UC-4, UC-5

5.12.3.1 REQ-MAS-CRIT-1: The product shall enforce session timeout and re-authentication.

5.13 Exploit Mitigation

5.13.0 Introduction

This clause addresses the requirements in the CRA [i.1], Annex I, Part I (2) (k).

5.13.1 Normal Risk

5.13.1.0 Applicability: All UC

5.13.1.1 REQ-EM-NORM-1: When a credential has an associated target system, the product shall validate the target system identifier (e.g. domain name, app ID, related origin) before performing an autofill operation.

5.14 Monitoring

5.14.0 Introduction

This clause addresses the requirements in the CRA [i.1], Annex I, Part I (2) (l).

5.14.1 Normal Risk

5.14.1.0 Applicability: All UC

5.14.1.1 REQ-LOG-NORM-1: The product shall log all import/export activities.

5.14.2 High Risk (none)

5.14.3 Critical Risk

5.14.3.0 Applicability: UC-2, UC-3, UC-5

5.14.3.1 REQ-LOG-CRIT-1: The product shall maintain comprehensive audit logs with tamper protection. At minimum, the product shall log the following events:

- a) access to a password vault;
- b) enrolment of a new device on which the product is to be used;
- c) reset of a master password.

5.14.3.2 REQ-LOG-CRIT-2: The product shall log all authorisation decisions and violations.

5.15 Factory Reset and Data Portability

5.15.0 Introduction

This clause addresses the requirements in the CRA [i.1], Annex I, Part I (2) (m).

5.15.1 Normal Risk

5.15.1.0 Applicability: All UC

5.15.1.1 REQ-DRT-NORM-1: The export option, including the migration of credentials (e.g. FIDO Credential Exchange Protocol), shall by default use dedicated secure platform APIs or provide an encrypted method in line with Annex K

NOTE 1: Plaintext export remains permitted with explicit user opt-in.

NOTE 2: In some environments user exports might be restricted or disabled.

5.15.2 High Risk

5.15.2.0 Applicability: UC-2, UC-3, UC-5

5.15.2.1 REQ-DRT-HIGH-1: User offboarding shall trigger revocation of online vault access.

5.15.3 Critical Risk

5.15.3.0 Applicability: UC-5

5.15.3.1 REQ-DRT-CRIT-1: The product shall require re-authentication for export operations.

NOTE 1: An existing SSO or OS level authentication is considered equivalent with an active re-authentication.

NOTE 2: If there is no authentication mechanism, explicit user confirmation is needed.

6 Assessment criteria for compliance with technical requirements

6.1 Introduction to the assessment and compliance criteria

This clause provides objective and reproducible assessment criteria to determine whether a product complies with the technical security requirements of clause 5, based on the UC it may belong towards its placement in the EU market.

For each cybersecurity requirement defined in clause 5, the following clauses specify assessment criteria to determine if the technical requirement is met.

The assessment criteria for each security requirements are described in a structured manner, as follows:

- **Assessment reference:** Refers to the identifier of the concerned technical requirement.

- **Assessment Objective:** Defines the security property or capability that shall be verified, ensuring that the assessment remains focused on the intent of the requirement.

It includes the reference index of the requirement(s) it aims to assess.

- **Assessment Preparation:** Describes the environment, setup, and preconditions required before executing the test with a view to guaranteeing consistent evaluation results. It includes the following elements as applicable:
 - Test environment: Describe the hardware, software, and network setup used for the assessment, including versions, topology, and any relevant dependencies.
 - Preconditions: Specify any configurations, credentials, or operational states that should be established before the test (e.g. product initialized, certificates loaded, user roles created).
 - Required tools: Identify the tools or software necessary to perform the assessment (e.g. vulnerability scanners, protocol fuzzers, traffic analysers, static code analysers, cryptographic test suites).
 - Required information/documentation for the assessment: Specify all information that is necessary to perform the assessment.
 - Reference any vendor-provided setup guides, configuration instructions, or operational manuals, as well as any relevant standards or technical notes, that define how the product shall be configured or operated for the assessment.
- **Assessment Activities:** Provides execution steps to be performed. Assessment activities may include, as applicable:
 - Review documentation to confirm that the described implementation matches the requirement (e.g. verify that the security architecture document specifies TLS 1.2 or higher for all external interfaces, or that the password policy aligns with the defined threshold).
 - Perform security functional tests to verify the completeness and correctness of the information/documentation for the assessment.
 - Perform security functional or penetration tests to verify that implemented controls prevent unauthorised access or data modification (e.g. attempt to log in with invalid credentials to test lockout enforcement or try to modify protected configuration files without administrative privileges).
 - Analyse code or binaries to identify potential security weaknesses or misconfigurations (e.g. perform static analysis to detect hardcoded credentials or use dynamic analysis tools to identify buffer overflow or injection vulnerabilities).
 - Inspect configurations to ensure that required security parameters are correctly applied (e.g. check that weak cipher suites are disabled, two-factor authentication is enabled, and least-privilege access controls are configured in the system).
 - Observe runtime behaviour to confirm that protections such as encryption, authentication, and integrity verification operate as intended (e.g. monitor network traffic to ensure data in transit is encrypted or observe system logs to verify successful validation of digital signatures during startup).
- **Assessment of Verdict:** Defines the pass/fail criteria.
 - Pass: The assessment is considered passed if the product demonstrably fulfils the requirement and meets the defined security thresholds. Examples of such thresholds include:
 - Minimum cryptographic strength (e.g. AES-128 or higher);
 - Password policy limits (e.g. minimum of 12 characters);
 - Login protection mechanisms (e.g. account lockout after five consecutive failed attempts);
 - Resistance to a specified attack potential (e.g. equivalent to CSA High/AVA_VAN.3 or higher).
 - Fail: The assessment is considered failed if the requirement is not fulfilled, or if the defined security thresholds are not achieved (e.g. insufficient key length, missing authentication enforcement, or inadequate resistance to the required attack potential).

- **Assessment evidence:** Defines the artefacts and documentation that shall be collected to demonstrate that the requirement has been assessed and fulfilled. The evidence shall be sufficient to enable independent verification of the assessment results and to demonstrate compliance with the relevant CRA essential requirements. The supporting evidence includes, where applicable:
 - Test or assessment reports showing the steps performed and results obtained;
 - Logs, configuration files, or audit traces demonstrating the implementation of the requirement;
 - Screenshots, captures, or console outputs confirming the correct execution or protection behaviour;
 - Relevant vendor or design documentation describing the applied security measures;

6.2 Appropriate level of cybersecurity

6.2.1 Normal Risk

6.2.1.1 ACC-SD-NORM-1

6.2.1.1.1 Reference

Secure secret generation shall use Cryptographically Secure Random Number Generators (CSRNG).

6.2.1.1.2 Objective

Verify that all secret material generated by the product is produced by a CSRNG conformant to Annex K.

6.2.1.1.3 Preparation

- Source code availability
- Documentation identifying every secret-generation code path and the CSRNG construction used

6.2.1.1.4 Activities

- Enumerate all secret-generation call sites and confirm coverage by code
- Confirm each call site invokes a CSRNG conformant to Annex K

6.2.1.1.5 Verdict

- Pass: Every secret-generation call site uses a CSRNG conformant to Annex K
- Fail: Any secret-generation path uses a non-cryptographic generator, a CSRNG outside Annex K is used

6.2.1.1.6 Evidence

- Inventory of secret-generation call sites with source references
- Code references showing implementation
- Mapping from each CSRNG instance to its Annex K entry

6.2.1.2 ACC-SD-NORM-2

6.2.1.2.1 Reference

If the product offers passkeys as a storable credential type, it shall securely implement passkey functionality following the relevant W3C WebAuthn [3] and FIDO CTAP 2.2 [4] or 2.3 [5] requirements for implementing Authenticators.

6.2.1.2.2 Objective

Verify that the product complies with the passkey specifications

6.2.1.2.3 Preparation

- Password manager with passkey functionality
- WebAuthn [4]/FIDO2 specifications [5]
- Cryptographic analysis tools
- Access to passkey implementation details

6.2.1.2.4 Activities

- Implement the mandatory WebAuthn Level 2 conformance criteria for Authenticators (clause 2.2) [3]
- Implement the FIDO CTAP 2.2 [4] or 2.3 [5] mandatory features (clause 9)
- Implement all necessary features for discoverable Authenticators within WebAuthn/FIDO2 standards
- Check algorithm choices comply with WebAuthn/FIDO2 standards
- Confirm no deprecated or weak cryptographic mechanisms
- Verify signature algorithms match approved list

6.2.1.2.5 Verdict

- Pass: All cryptographic mechanisms are WebAuthn/FIDO2 compliant; no deprecated algorithms
- Fail: non-standard implementations

6.2.1.2.6 Evidence

- WebAuthn/FIDO2 conformance test results
- Algorithm implementation details
- Third-party security audit confirming cryptographic compliance
- When available, a third-party passkey certification can provide evidence

6.2.1.3 ACC-SD-NORM-3

6.2.1.3.1 Reference

If the product offers TOTP-type protocol participation as a storable credential type, it shall implement TOTP functionality following the relevant IETF RFC 6238 [1] and IETF RFC 4226 [2] requirements.

6.2.1.3.2 Objective

Verify that the product's TOTP implementation conforms to IETF RFC 6238 [1] and IETF RFC 4226 [2].

6.2.1.3.3 Preparation

- Installed product with TOTP enabled
- Sample otpauth:// enrolment URIs covering each supported configuration

6.2.1.3.4 Activities

- Confirm code generation conforms to IETF RFC 6238 [1] and IETF RFC 4226 [2]
- Attempt enrolment with out-of-policy parameters and confirm rejection

6.2.1.3.5 Verdict

- Pass: Code generation conforms to IETF RFC 6238 [1] and IETF RFC 4226 [2] and out-of-policy configurations are rejected
- Fail: Code generation does not conform or an out-of-policy configuration is accepted

6.2.1.3.6 Evidence

- Conformance test results against IETF RFC 6238 [1] and IETF RFC 4226 [2]
- Configuration excerpts for supported parameter ranges

6.2.2 High Risk

6.2.2.1 ACC-SD-HIGH-1

6.2.2.1.1 Reference

Generated passwords shall by default have 80 or more bits of entropy, but will warn the user if that strength has been reduced in order to comply with lesser requirements as they may be defined by the target system.

6.2.2.1.2 Objective

Verify that passwords generated by the product meet the entropy threshold defined by the applicable target system or configured security policy.

6.2.2.1.3 Preparation

- Installed product with password generator enabled
- Sample target-system policies covering common entropy thresholds
- Entropy calculation tooling

6.2.2.1.4 Activities

- For each documented policy preset, generate a sample of passwords and compute theoretical entropy from the character set and length
- Confirm computed entropy meets or exceeds 80 bits of entropy
- Confirm that the user has been notified when a strength reduction below 80 bits of entropy has occurred

6.2.2.1.5 Verdict

- Pass: All generated passwords meet or exceed the policy threshold, and below-threshold generated passwords trigger a notification to the user
- Fail: Any sample falls below the applicable threshold, default preset is below 80 bits of entropy, or below-threshold passwords are silently accepted

6.2.2.1.6 Evidence

- Generated password samples with computed entropy
- Documentation reference for the entropy policy
- Log of below-threshold configuration attempts
- Screenshot of user notification

6.2.3 Critical Risk

6.2.3.1 ACC-SD-CRIT-1

6.2.3.1.1 Reference

Generated passwords shall meet or exceed the minimum p-value requirements for Independent and Identically Distributed (IID) evaluation, as defined by the target system or security policy.

6.2.3.1.2 Objective

Verify that the output of the password generator passes IID evaluation at the p-value threshold defined by the applicable policy, demonstrating statistical independence and uniform distribution of generated material.

6.2.3.1.3 Preparation

- Installed product with password generator configured per the policy under test
- IID evaluation tooling for permutation testing
- Sample size sufficient for the statistical test (typically 1 000 000 samples or as specified by the policy)
- Documentation of the p-value threshold defined by the policy

6.2.3.1.4 Activities

- Generate the required sample size under controlled conditions, preserving raw output bytes
- Execute the IID test suite and record p-values for each test in the battery
- Compare each p-value against the policy threshold
- Repeat the sampling and evaluation in an independent run to confirm reproducibility

6.2.3.1.5 Verdict

- Pass: All p-values from the IID test battery meet or exceed the policy threshold across both runs
- Fail: Any p-value falls below the threshold in either run, or the sample exhibits patterns inconsistent with IID assumptions

6.2.3.1.6 Evidence

- Raw sample files with cryptographic hashes
- IID test output with per-test p-values for both runs
- Policy reference for the p-value threshold
- Test environment description (CPU, OS, RNG source, product version)

6.3 No known exploitable vulnerabilities

6.3.1 Normal Risk

6.3.1.1 ACC-KEV-NORM-1

6.3.1.1.1 Reference

The product shall be free from exploitable vulnerabilities that can be classified as impacting the confidentiality, integrity, authenticity, or availability of one of the product's assets as listed in clauses B.1.1.1, B.1.1.2, B.1.1.3, or B.1.1.4.

6.3.1.1.2 Objective

Verify that no exploitable vulnerability present in the product impacts the confidentiality, integrity, authenticity, or availability of any asset listed in clauses B.1.1.1 through B.1.1.4, unless covered by a substantiated false-positive declaration in current product documentation.

6.3.1.1.3 Preparation

- Clean target host and installation package from the manufacturer's official channel
- Software Bill of Materials (SBOM) for the product and bundled components
- Inventory of the assets listed in clauses B.1.1.1, B.1.1.2, B.1.1.3 and B.1.1.4, with reference to their CIAA properties
- Vulnerability Exchange (VEX) document or equivalent false-positive register aligned to the assessed product version
- SBOM correlation tooling with vulnerability database synchronised within 24 hours
- Access to vulnerability intelligence sources (NVD, EUVD, GHSA, vendor advisories)

6.3.1.1.4 Activities

- Install the product using defaults
- Correlate all components against vulnerability database entries and identify those whose impact, as recorded in the source advisory, affects confidentiality, integrity, authenticity, or availability
- For each candidate match, map the impact to the assets listed in clause B.1.1.1 through B.1.1.4 and confirm whether the affected asset is in scope
- For each in-scope candidate match, verify the manufacturer's VEX justification by code, configuration, or controlled test
- For in-scope matches without a VEX statement, assess reachability and exploitability in the as-installed configuration directly

6.3.1.1.5 Verdict

- Pass: No candidate matches map to an in-scope asset, OR every in-scope match is covered by a verified false-positive declaration, OR every in-scope match is independently shown to be non-reachable and non-exploitable
- Fail: One or more in-scope matches remain reachable or exploitable, OR a false-positive claim cannot be substantiated, OR SBOM coverage or asset inventory is insufficient to support the correlation

6.3.1.1.6 Evidence

- SBOM with hash
- Inventory of assets from clause B.1.1.1 through B.1.1.4 with CIAA mapping
- Raw correlation output identifying vulnerabilities and their declared CIAA impact, pre-suppression
- Mapping of each candidate match to in-scope assets
- VEX document with version tied to the assessed product
- Verification record for each not_affected claim
- Vulnerability database snapshots used during correlation, with retrieval timestamps

6.4 Secure by default configuration

6.4.1 Normal Risk

6.4.1.0 Introduction

All requirements at this risk level are unconditionally applicable.

6.4.1.1 ACC-SD-NORM-1

6.4.1.1.1 Reference

The product shall enforce master password complexity on creation using an entropic level commensurate with a cited standard in line with Annex K or configured by local policy for enterprise use-cases.

6.4.1.1.2 Objective

Test that the password manager enforces minimum master password complexity requirements of the method chosen by the manufacturer inline with the Notes from this assessment's requirement.

6.4.1.1.3 Preparation:

- Fresh installation of password manager
- Account creation interface accessible
- Test suite with various password complexity samples

6.4.1.1.4 Activities

- Verify that the product documentation discloses the approach taken
- Confirm that the password validator rejects passwords inappropriate for the approach

6.4.1.1.5 Verdict

- Pass: All non-compliant passwords rejected with clear error messages; compliant password accepted
- Fail: Any weak password accepted, OR no enforcement detected, OR unclear/missing error messages

6.4.1.1.6 Evidence:

- Screenshots of rejection messages for each weak password attempt
- Screenshot of successful creation with compliant password
- Error message text logs
- Video recording of password creation attempts, when available

6.4.1.2 ACC-SD-NORM-2

6.4.1.2.1 Reference: REQ-SD-NORM-2

The product shall mask master password entry fields on the user interface by default unless and until overridden by the user.

6.4.1.2.2 Objective

Verify that password entry fields are masked by default.

6.4.1.2.3 Preparation

- Password manager login interface visible
- Screen capture capability

6.4.1.2.4 Activities

- Confirm password characters are never displayed in plaintext by default

6.4.1.2.5 Verdict

- Pass: Password field is masked by default
- Fail: Password visible in plaintext in default state without user override

6.4.1.2.6 Evidence

- Screenshot of masked password field during entry

6.5 Security updates

6.5.1 Normal Risk

6.5.1.1 ACC-SU-NORM-1

6.5.1.1.1 Reference

The product shall implement automatic secure update by default before or during first use.

6.5.1.1.2 Objective

Verify that the product, in its default configuration, performs an authenticated secure update check and applies available security updates before or during first use, without user opt-in.

6.5.1.1.3 Preparation

- Clean target host with network connectivity
- Installation package from the manufacturer's official channel
- Network capture and inspection tooling
- Documentation describing the update mechanism and signing scheme

6.5.1.1.4 Activities

- Install using defaults and capture all network traffic through first use
- Verify the update channel uses TLS with certificate validation or equivalent scheme from Annex K
- Confirm payloads are signature-verified; attempt a tampered payload and confirm rejection
- Confirm any pending security update is applied automatically before operational use
- Inspect default settings to confirm automatic update is not opt-in

6.5.1.1.5 Verdict

- Pass: Automatic secure update runs by default before or during first use, over an authenticated channel, with enforced signature verification
- Fail: Update is opt-in, occurs after first use, uses an unauthenticated channel, or accepts a tampered payload

6.5.1.1.6 Evidence

- PCAP covering installation through first use
- TLS handshake and certificate validation log or equivalent scheme from Annex K
- Signed and tampered payload samples with verification results
- Screenshot of default update configuration where possible

6.5.1.2 ACC-SU-NORM-2

6.5.1.2.1 Reference

The product shall verify the authenticity of update packages prior to applying the update, in accordance with Annex K.

6.5.1.2.2 Objective

Verify that the product cryptographically authenticates the origin of each update package before any installation step is executed.

6.5.1.2.3 Preparation

- Installed product in default configuration
- Legitimate signed update package from the manufacturer
- Documentation of the signing scheme, trust anchor, and verification algorithm
- Network capture tooling and access to update logs

6.5.1.2.4 Activities

- Trigger an update and observe the verification step in logs or instrumentation
- Confirm the signature is checked against the embedded or provisioned trust anchor before any file is written to a privileged location
- Inspect the verification algorithm against the documented scheme
- Confirm the trust anchor cannot be silently replaced by an unprivileged process

6.5.1.2.5 Verdict

- Pass: Authenticity verification occurs before installation, uses the documented scheme, and is anchored in a protected trust store
- Fail: Verification is skipped, occurs after installation steps, uses a weaker algorithm than documented, or relies on a mutable trust anchor

6.5.1.2.6 Evidence

- Update log excerpt showing verification step and timestamp
- Signed package sample with signature metadata
- Documentation reference for the signing scheme and trust anchor location

6.5.1.3 ACC-SU-NORM-3

6.5.1.3.1 Reference

The product's update process shall reject the installation of updates that fail the verification of the authenticity of the update, in accordance with Annex K.

6.5.1.3.2 Objective

Verify that an update package failing authenticity verification is rejected and no installation step proceeds.

6.5.1.3.3 Preparation

- Installed product in default configuration
- Update packages prepared with: (a) invalid signature, (b) signature from an untrusted key, (c) stripped signature
- Update logs and filesystem monitoring tooling

6.5.1.3.4 Activities

- Submit each tampered package to the update mechanism
- Observe the product's response and confirm rejection with an error condition
- Verify no installed file is modified and no privileged process is invoked beyond verification
- Confirm the rejection event is logged

6.5.1.3.5 Verdict

- Pass: All three tampered packages are rejected, no installation artefacts are written, and each rejection is logged

- Fail: Any tampered package proceeds past verification, partial installation occurs, or rejection is silent

6.5.1.3.6 Evidence

- Tampered package samples used in the test
- Update logs showing rejection events
- Filesystem diff confirming no installation occurred

6.5.1.4 ACC-SU-NORM-3

6.5.1.4.1 Reference

The product's update process shall verify the integrity of update packages prior to applying the update, in accordance with Annex K.

6.5.1.4.2 Objective

Verify that the product checks the integrity of each update package, via cryptographic hash or equivalent, before installation.

6.5.1.4.3 Preparation

- Installed product in default configuration
- Legitimate update package with published hash or integrity manifest
- Documentation of the integrity scheme and hash algorithm
- Update logs and instrumentation

6.5.1.4.4 Activities

- Trigger an update and observe the integrity check in logs
- Confirm the computed hash matches the published or signed manifest value
- Confirm the integrity check occurs before installation steps begin
- Confirm the hash algorithm meets the strength required by Annex K, as determined by the product documentation

6.5.1.4.5 Verdict

- Pass: Integrity verification runs before installation, uses an approved algorithm, and matches the manifest
- Fail: Integrity check is skipped, runs after installation, uses a deprecated algorithm, or accepts a mismatched hash

6.5.1.4.6 Evidence

- Update log excerpt showing integrity check
- Integrity manifest sample
- Algorithm reference cross-checked against Annex K

6.5.1.5 ACC-SU-NORM-4

6.5.1.5.1 Reference

The product's update process shall reject the installation of updates that fail the integrity verification, in accordance with Annex K.

6.5.1.5.2 Objective

Verify that an update package failing integrity verification is rejected and no installation step proceeds.

6.5.1.5.3 Preparation

- Installed product in default configuration
- Update packages prepared with:
 - a) corrupted payload;
 - b) truncated payload;
 - c) manifest-payload mismatch.
- Update logs and filesystem monitoring tooling

6.5.1.5.4 Activities

- Submit each corrupted package to the update mechanism
- Observe rejection and confirm no installation occurs
- Verify the rejection event is logged
- Confirm no partial files are left in the installation path

6.5.1.5.5 Verdict

- Pass: All corrupted packages are rejected, no installation artefacts are written, and each rejection is logged
- Fail: Any corrupted package proceeds past verification, partial installation occurs, or rejection is silent

6.5.1.5.6 Evidence

- Corrupted package samples
- Update logs showing rejection events
- Filesystem diff confirming no installation occurred

6.5.2 High Risk (none)

6.5.3 Critical Risk

6.5.3.1 ACC-SU-CRIT-1

6.5.3.1.1 Reference

The product shall maintain a monotonic version counter or equivalent mechanism to prevent unauthorised installation of an older version.

6.5.3.1.2 Objective

Verify that the product enforces a non-decreasing version state and rejects update packages whose version is lower than the currently installed version.

6.5.3.1.3 Preparation

- Installed product at a known current version
- Signed update package corresponding to an earlier supported version
- Signed update package matching the current version
- Documentation of the version counter or anti-rollback mechanism
- Access to the persistent store holding the version state

6.5.3.1.4 Activities

- Attempt to install the older signed package and observe the response
- Attempt to install the current-version package and confirm it is handled per policy
- Inspect the persistent store and confirm the version counter cannot be decremented by an unprivileged process
- Where the mechanism is hardware-anchored, confirm the anchor is engaged

6.5.3.1.5 Verdict

- Pass: The older signed package is rejected, the version counter is monotonic, and the counter store is protected against unauthorised modification
- Fail: An older signed package installs, the counter can be decremented or reset by an unprivileged actor, or no equivalent mechanism is demonstrable

6.5.3.1.6 Evidence

- Logs showing rejection of the older package
- Version counter state before and after each attempt
- Documentation reference for the anti-rollback mechanism and its protection

6.5.3.2 ACC-SU-CRIT-2

6.5.3.2.1 Reference

If the product supports intentional rollback, this action shall require explicit authorisation.

6.5.3.2.2 Objective

Verify that, where rollback is supported, it cannot proceed without an authenticated authorisation step distinct from ordinary update operation.

6.5.3.2.3 Preparation

- Installed product with rollback capability enabled
- Earlier signed version package
- Credentials or authorisation tokens required by the documented rollback procedure

- Documentation of the rollback authorisation scheme

6.5.3.2.4 Activities

- Attempt rollback without providing authorisation and confirm it is refused
- Attempt rollback with invalid or expired authorisation and confirm it is refused
- Perform rollback with valid authorisation and confirm the action is logged with the authorising identity
- Confirm the authorisation step is distinct from the ordinary update flow and cannot be bypassed by replaying earlier credentials

6.5.3.2.5 Verdict

- Pass: Rollback proceeds only with valid explicit authorisation, refusals are logged, and the authorisation step is non-bypassable
- Fail: Rollback proceeds without authorisation, accepts invalid credentials, or the authorisation step can be bypassed or replayed

6.5.3.2.6 Evidence

- Logs of refused and accepted rollback attempts with authorising identity
- Documentation reference for the rollback authorisation scheme
- Credential or token sample used in the successful test (redacted)

6.6 Authentication and access control

6.6.1 Normal Risk

6.6.1.1 ACC-AC-NORM-1

6.6.1.1.1 Reference

Unless the product user authentication is managed at the operating system or host level, unlocking or decrypting the vault shall require at least one explicit authentication per user session.

6.6.1.1.2 Objective

Verify that the password manager requires at least one explicit authentication event per user session before the vault is unlocked or decrypted, or that authentication is verifiably delegated to the operating system or host platform.

6.6.1.1.3 Preparation

- Password manager application installed with debug / instrumentation build where available
- Test user account provisioned with a populated vault
- Means to start and end clean user sessions
- Documentation describing authentication architecture

6.6.1.1.4 Activities

- Review documentation to determine whether authentication is delegated to the OS or host; if so, confirm the delegation mechanism (e.g. OS keyring, platform credential store, enterprise SSO) through configuration inspection and runtime behaviour
- If no delegation is claimed, start a clean user session and attempt to access vault contents without performing any authentication action; confirm access is denied
- Trigger the documented unlock or decrypt flow and confirm an explicit authentication step is presented to the user (passphrase entry, biometric prompt, hardware token, or equivalent)
- Confirm the authentication event is recorded in logs or instrumentation output and is bound to the active session
- Terminate the session and start a new one; confirm that prior authentication state does not carry over and that authentication is required again
- Inspect source code or runtime behaviour to verify that vault decryption keys are not retained or recoverable without an authentication event in the new session

6.6.1.1.5 Verdict

- Pass: An explicit authentication event is required and observed at least once per user session before the vault can be unlocked or decrypted, OR authentication is verifiably delegated to the OS or host with documented and observable enforcement
- Fail: Vault contents are accessible in a new session without any authentication event, OR a delegation claim cannot be substantiated by configuration, code, or runtime evidence, OR authentication state persists across session boundaries in a way that bypasses the per-session requirement

6.6.1.1.6 Evidence

- Session log or debug trace showing the authentication event and its timestamp relative to session start
- Screenshot or screen recording of the authentication prompt presented on first vault access in a new session
- Configuration dump indicating the authentication mode in use (local, OS-delegated, host-delegated)
- Documentation reference for any claimed OS or host authentication delegation, with corresponding runtime evidence
- Source code reference showing the session-to-authentication binding and key handling logic (if available)

6.6.1.2 ACC-AC-NORM-2

6.6.1.2.1 Reference

The product shall implement an appropriate Key Derivation Function (KDF) to derive encryption keys to secure the vault in line with cryptographic sources and requirements as found in Annex K.

6.6.1.2.2 Objective

Verify the password manager implements a key derivation function with minimum iteration count or equivalent computational cost as found in Annex K.

6.6.1.2.3 Preparation

- Password manager application installed with debug / instrumentation build where available
- Access to configuration files or runtime parameters

- Source code

6.6.1.2.4 Activities

- Inspect captured logs or configuration files for KDF parameters
- Confirm KDF algorithm is from approved list
- Confirm appropriate implementation with code inspection

6.6.1.2.5 Verdict

- Pass: KDF iteration count meets or exceeds minimum threshold, OR alternative KDF meets equivalent computational cost with documented justification
- Fail: Iteration count below requirements for algorithm, OR unapproved KDF algorithm used, OR no KDF implementation detected

6.6.1.2.6 Evidence

- Documentation on KDF algorithms and configuration in use
- Configuration dump showing KDF parameters
- Debug log file capturing initialization sequence
- Screenshot of KDF settings in administrative interface
- Source code reference showing KDF implementation

6.6.1.3 ACC-AC-NORM-3

6.6.1.3.1 Reference

The product shall support multi-factor authentication (MFA) as an available option.

6.6.1.3.2 Objective

Confirm that multi-factor authentication can be enabled and enforced as a mandatory option, preventing authentication with master password alone. See Note 1 under definition of Multi Factor Authentication in clause 3.1 for examples of approaches.

6.6.1.3.3 Preparation

- Password manager with MFA configuration interface
- Access to MFA approach

6.6.1.3.4 Activities

- Confirm MFA enrolment process is available and functional
- Verify authentication fails with single factor authentication after MFA is enabled
- Verify authentication succeeds with MFA
- Verify authentication fails with incorrect MFA
- Check MFA can be made mandatory (non-optional) for all users via policy

6.6.1.3.5 Verdict

- Pass: MFA is available, can be enabled, properly enforces second factor, and can be configured as mandatory
- Fail: No MFA support, OR MFA is optional without mandatory enforcement capability, OR MFA can be bypassed

6.6.1.3.6 Evidence

- Screenshots of MFA enrolment process
- Screenshot showing authentication failure without MFA
- Screenshot showing authentication success with MFA
- Configuration file or policy setting showing MFA mandatory option
- Test log showing MFA enforcement behaviour

6.6.1.4 ACC-AC-NORM-4

6.6.1.4.1 Reference

The product shall enforce user-defined policy-dependent session timeout and re-authentication.

6.6.1.4.2 Objective

Verify that administrative sessions implement idle timeout (for example ≤ 15 minutes) and absolute timeout (for example ≤ 8 hours) with automatic termination, re-authentication requirements, token invalidation, and concurrent session limits.

6.6.1.4.3 Preparation

- Password manager administrative interface
- Administrative session with active access
- Session timeout configuration settings
- System clock manipulation capability (for testing)
- Session monitoring tools

6.6.1.4.4 Activities

- Confirm idle session timeout configured and enforced (≤ 15 minutes recommended)
- Verify sessions automatically terminate after timeout
- Check re-authentication required after timeout
- Confirm absolute maximum session duration configured (e.g. ≤ 8 hours)
- Verify session invalidated on timeout or logout
- Check session timeout cannot be indefinitely extended
- Confirm concurrent session limits enforced
- Verify timeout values appropriate for security posture (shorter for higher security)

6.6.1.4.5 Verdict

- Pass: Idle timeout configured and enforced (≤ 15 min); automatic session termination; re-authentication required; absolute timeout configured (≤ 8 hours); tokens invalidated; concurrent session limits
- Fail: No session timeout, OR timeout too long (>15 min idle), OR no automatic termination, OR no re-authentication, OR no absolute timeout, OR tokens not invalidated, OR unlimited concurrent sessions

6.6.1.4.6 Evidence

- Session timeout configuration showing idle and absolute timeout values
- Test results showing automatic session termination after idle timeout
- Re-authentication prompt after timeout
- Absolute session timeout test results
- Session invalidation verification
- Concurrent session limit testing results
- Session management security policy documentation
- Authentication logs showing session lifecycle (creation, timeout, re-auth)

6.6.2 High Risk

6.6.2.1 ACC-AC-HIGH-1

6.6.2.1.1 Reference

The product shall enforce the principle of least privilege for all operations.

6.6.2.1.2 Objective

Test that the least privilege principle is enforced for all operations with minimum required privilege levels, privilege escalation blocked, default assignments minimal, explicit grants required, and violations logged.

6.6.2.1.3 Preparation

- Password manager with multiple user roles and operations
- Complete list of all operations and functions
- User accounts with different privilege levels
- Access control configuration
- Operation logging capability

6.6.2.1.4 Activities

- Confirm all operations have defined minimum privilege requirements
- Verify users receive only necessary privileges for their role
- Check default privilege assignments are minimal
- Confirm privilege escalation attempts are blocked

- Verify privileges should be explicitly granted
- Check that operation-specific privileges are not overly broad
- Confirm privilege violations are logged
- Verify new users start with minimal privileges

6.6.2.1.5 Verdict

- Pass: All operations have minimum privilege requirements; users receive only necessary privileges; default assignments minimal; privilege escalation blocked; explicit grant required; operation-specific privileges; violations logged
- Fail: Undefined privilege requirements, OR excessive default privileges, OR privilege escalation possible, OR implicit grants, OR overly broad privileges, OR violations not logged

6.6.2.1.6 Evidence

- Complete operation inventory with minimum privilege requirements
- Privilege matrix (operations vs. roles)
- Default privilege assignment documentation
- Privilege escalation test results (blocked attempts)
- Explicit grant requirement verification
- Operation-specific privilege enforcement examples
- Privilege violation logs
- Least privilege policy documentation

6.6.2.2 Assessment AC-HIGH-2

6.6.2.2.1 Reference

The product shall validate authorisation for each sensitive operation such as adding a new device, export, sharing of credentials.

6.6.2.2.2 Objective

Verify that authorisation is validated before every sensitive operation with authentication and privilege checks that cannot be bypassed, including batch operations and logging of failures.

6.6.2.2.3 Preparation

- Password manager with sensitive operations
- User accounts with various privilege levels
- Access control enforcement mechanism
- Operation logging and monitoring

6.6.2.2.4 Activities

- Confirm authorisation validated for all sensitive operations

- Verify authorisation check occurs before operation execution
- Check authentication and privilege verification performed
- Confirm unauthorised operations are blocked
- Verify authorisation checks cannot be bypassed
- Check authorisation validated on every invocation (no caching of authorisation decisions)
- Confirm batch operations check authorisation for each item
- Verify authorisation failures are logged

6.6.2.2.5 Verdict

- Pass: Authorisation validated for all sensitive operations; check before execution; authentication and privileges verified; unauthorised operations blocked; no bypass; checked on every invocation; batch items individually checked; failures logged
- Fail: Missing authorisation checks, OR check after execution, OR incomplete verification, OR unauthorised operations succeed, OR bypass possible, OR cached authorisation, OR batch operations not individually checked, OR failures not logged

6.6.2.2.6 Evidence

- Sensitive operations inventory with authorisation requirements
- Test results showing successful authorised operations
- Test results showing blocked unauthorised operations
- Authorisation bypass attempt results (failed attempts)
- Every-invocation authorisation verification
- Batch operation authorisation test results
- Authorisation failure logs

6.6.3 Critical Risks

6.6.3.1 Assessment ACC-AC-CRIT-1

6.6.3.1.1 Reference

In the factory default configuration, multi-factor authentication shall be enforced for administrative access.

6.6.3.1.2 Objective

Verify that multi-factor authentication is enforced for an administrative access session, with both factors required and no bypass capability without additional authorisation.

6.6.3.1.3 Preparation

- Password manager with administrative interface
- Administrative account for testing
- Multiple authentication factors available

- Access to authentication configuration
- Authentication logging and monitoring

6.6.3.1.4 Activities

- Confirm multi-factor authentication enforced for all administrative access
- Verify MFA cannot be bypassed or disabled by a user trying to authenticate
- Verify MFA enrolment and recovery processes are secure

6.6.3.1.5 Verdict

- Pass: MFA enforced for all administrative access; no bypass
- Fail: No MFA, OR MFA bypassable, OR insecure enrolment

6.6.3.1.6 Evidence

- Administrative authentication configuration showing MFA requirement
- Screenshot of MFA prompt during administrative login
- Supported MFA approaches documentation
- Successful MFA authentication flow
- MFA bypass resistance verification
- MFA enrolment and recovery process documentation
- Authentication logs showing MFA validation

6.6.3.2 Assessment ACC-AC-CRIT-2

6.6.3.2.1 Reference

The product shall implement exponential backoff for failed online password authentication attempts.

6.6.3.2.2 Objective

Demonstrate that the password manager implements exponential backoff by measuring increasing delays for consecutive failed authentication attempts.

6.6.3.2.3 Preparation

- Password manager with existing account and known master password
- Access to system time measurement tools
- Automated test script capable of recording response times

6.6.3.2.4 Activities

- Analyse recorded response times showing increasing delays
- Confirm delay pattern follows exponential or linear-with-cap backoff
- Verify minimum delay increases (e.g. 1 s, 2 s, 4 s, 8 s, etc.)

- Check maximum cap exists to prevent permanent lockout (e.g. 60 s max)
- Test successful authentication after backoff period resets counter

6.6.3.2.5 Verdict

- Pass: Failed attempts result in measurably increasing delays with exponential or stepped pattern
- Fail: No delay increase detected, OR constant delay regardless of attempts

6.6.3.2.6 Evidence

- Timestamped log of authentication attempts with response times
- Graph showing exponential backoff curve
- Configuration file showing backoff parameters
- Test script output with timing measurements

6.6.3.3 ACC-AC-CRIT-3

6.6.3.3.1 Reference

The product shall implement Role-Based Access Control (RBAC) or Attribute-Based Access Control (ABAC) for multi-user environments.

6.6.3.3.2 Objective

Verify that the product enforces RBAC or ABAC across multi-user functionality, with clearly defined roles or attributes, permissions consistent with the documented policy, and enforcement on every operation governed by the policy.

6.6.3.3.3 Preparation

- Installed product with multi-user functionality enabled
- Test accounts covering each role or attribute set supported by the product
- Shared resources to which access is governed by the policy
- Documentation identifying the access control model (RBAC or ABAC), the roles or attributes, the permissions associated with each, the hierarchy or composition rules, and the propagation behaviour of role or attribute changes

6.6.3.3.4 Activities

- For each role or attribute set, attempt every operation governed by the policy and confirm the product's response matches the documented permission
- Confirm operations not permitted by the role or attribute set are refused
- Modify a role assignment or attribute and confirm the change takes effect on subsequent operations consistent with documentation
- Confirm role hierarchy or attribute composition is enforced consistent with documentation

6.6.3.3.5 Verdict

- Pass: Every governed operation produces the response documented for the acting role or attribute set, refused operations remain refused, role or attribute changes take effect consistent with documentation, hierarchy or composition is enforced, and the policy cannot be bypassed
- Fail: Any operation diverges from the documented permission, a refused operation succeeds, role or attribute changes do not take effect consistent with documentation, hierarchy or composition is not enforced, or the policy can be bypassed

6.6.3.3.6 Evidence

- Documentation reference for the access control model, roles or attributes, and permissions
- Record of each governed operation across each role or attribute set with observed response
- Record of role or attribute modification and the resulting permission change
- Inspection notes on hierarchy or composition enforcement

6.6.3.4 ACC-AC-CRIT-4

6.6.3.4.1 Reference

The product shall ensure that there is no exploitable gap between authorisation decision and operation execution by implementing atomic authorisation checks.

6.6.3.4.2 Objective

Verify that the product binds authorisation decisions to the operations they govern such that no exploitable interval exists between the decision and the execution, and that intervening changes to authorisation state are reflected before the operation completes.

6.6.3.4.3 Preparation

- Installed product with multi-user authorisation functionality enabled
- Test accounts whose authorisation state can be modified during the test window
- Tooling capable of inducing concurrent authorisation changes and timed operation submissions
- Documentation identifying the atomicity mechanism, the handling of authorisation changes during in-flight operations, and the caching policy applied to authorisation decisions

6.6.3.4.4 Activities

- Submit operations under valid authorisation and confirm they complete
- Revoke authorisation between the documented decision point and the operation execution and confirm the operation is refused or rolled back
- Submit concurrent operations while modifying authorisation state and confirm no operation executes under authorisation that no longer holds at the time of execution
- Where authorisation depends on resource state, modify the resource state between decision and execution and confirm authorisation is re-evaluated
- Confirm that any caching of authorisation decisions is bounded as documented and does not extend across an authorisation change

6.6.3.4.5 Verdict

- Pass: Authorisation decisions are bound to the operations they govern, operations under revoked or changed authorisation are refused or rolled back, concurrent authorisation changes produce no operation executing under stale authorisation, resource-state changes trigger re-evaluation as documented, and caching is bounded consistent with documentation
- Fail: Any operation executes under authorisation that no longer holds at the time of execution, revocation between decision and execution does not refuse or roll back the operation, concurrent authorisation changes permit unauthorised execution, resource-state changes do not trigger documented re-evaluation, or caching extends across an authorisation change

6.6.3.4.6 Evidence

- Documentation reference for the atomicity mechanism, in-flight change handling, and caching policy
- Record of operations submitted under valid authorisation
- Record of the revocation-between-decision-and-execution test
- Record of concurrent authorisation change tests
- Record of resource-state change re-evaluation
- Record of caching behaviour across an authorisation change

6.6.3.5 ACC-AC-CRIT-5

6.6.3.5.1 Reference

If the product allows resources to be shared at a given level of granularity, it shall allow permissions to be assigned at that same level of granularity.

6.6.3.5.2 Objective

Verify that, for every resource sharing boundary the product supports, the product also supports differentiated permission assignment between users and resources at the same boundary, such that the permission model is no coarser than the sharing model.

6.6.3.5.3 Preparation

- Installed product with multi-user and resource sharing functionality enabled
- Test accounts covering multiple users
- Resources covering each granularity at which the product supports sharing
- Documentation identifying the resource sharing granularities supported, the permission types available at each granularity, and the propagation behaviour of permission changes

6.6.3.5.4 Activities

- Inventory the resource sharing granularities supported by the product
- For each granularity, confirm permissions can be assigned independently between different users for the same resource
- For each granularity, confirm permissions can be differentiated between resources for the same user
- Confirm each documented permission type at each granularity is enforced consistent with documentation

- Modify a permission assignment and confirm the change takes effect on subsequent operations consistent with documentation
- Revoke a permission and confirm the affected operations are refused thereafter

6.6.3.5.5 Verdict

- Pass: For every supported sharing granularity, permissions can be differentiated between users and between resources, each documented permission type is enforced, permission changes take effect consistent with documentation, and revocation produces refusal of the affected operations
- Fail: The permission model is coarser than the sharing model at any supported granularity, permissions cannot be differentiated between users or between resources at any granularity, any documented permission type is not enforced, permission changes do not take effect consistent with documentation, or revocation does not produce refusal of the affected operations

6.6.3.5.6 Evidence

- Documentation reference for the sharing granularities and permission types
- Inventory of sharing granularities with corresponding permission assignment evidence
- Record of differentiated permissions across users for the same resource at each granularity
- Record of differentiated permissions across resources for the same user at each granularity
- Record of permission modification with observed effect
- Record of revocation with observed refusal of affected operations

6.6.3.6 ACC-AC-CRIT-6

6.6.3.6.1 Reference

In the factory default configuration, the product shall implement online account lockout after failed attempts.

6.6.3.6.2 Objective

Verify that the product enforces account lockout for online access after failed authentication attempts consistent with the a configurable lockout policy, that a locked account refuses authentication for the duration of the lockout.

6.6.3.6.3 Preparation

- Installed product with authentication and account lockout functionality enabled
- Test account configured under the documented lockout policy
- Means to submit repeated authentication attempts
- Access to authentication logs and any lockout notification channel

6.6.3.6.4 Activities

- Submit failed authentication attempts up to the documented threshold and confirm the account is locked at the threshold
- Submit authentication attempts to the locked account, including with correct credentials, and confirm all are refused for the duration of the lockout
- Confirm the documented notification is delivered when lockout is triggered
- Submit a successful authentication and confirm the failed-attempt counter resets

6.6.3.6.5 Verdict

- Pass: Lockout is triggered at the configured threshold, a locked account refuses authentication including with correct credentials for the configured duration
- Fail: Lockout is not triggered at the configured threshold, a locked account accepts authentication during the lockout period, notification is absent, the failed-attempt counter does not reset

6.6.3.6.6 Evidence

- Record of failed authentication attempts leading to lockout, with timestamps
- Record of authentication attempts against the locked account
- Notification artefact captured at lockout
- Record of the unlock procedure and the subsequent successful authentication
- Record of the failed-attempt counter reset
- Record of the bypass attempt

6.7 Confidentiality protection

6.7.1 Normal Risk

6.7.1.1 ACC-CON-NORM-1

6.7.1.1.1 Reference

The product shall use approved encryption algorithms to encrypt all data at rest in order to ensure confidentiality and integrity (e.g. using Authenticated Encryption with Associated Data) in accordance with Annex K.

6.7.1.1.2 Objective

Verify that all sensitive data at rest is protected by an encryption mechanism conformant to Annex K that provides both confidentiality and integrity.

6.7.1.1.3 Preparation

- Installed product with vault storage enabled
- Active vault containing test credentials across all supported sensitive field types
- Access to vault storage files on the host file system
- Binary inspection tooling
- Documentation identifying the encryption mechanism, the algorithm and key size used, and how the mechanism provides confidentiality and integrity

6.7.1.1.4 Activities

- Populate the vault with test data
- Inspect the vault storage files and confirm no sensitive data is present in plaintext
- Confirm the encryption mechanism, including algorithm and key size, is conformant to Annex K and provides both confidentiality and integrity

- Confirm the vault cannot be decrypted without the credentials required by the documented mechanism
- Tamper with the encrypted storage and confirm the product detects and refuses to use the modified data

6.7.1.1.5 Verdict

- Pass: All sensitive data at rest is encrypted under a mechanism conformant to Annex K providing both confidentiality and integrity, the vault cannot be decrypted without the required credentials, and tampering with stored data is detected and refused
- Fail: Any sensitive data is present in plaintext, the encryption mechanism falls outside Annex K, the mechanism does not provide integrity, the vault can be decrypted without the required credentials, or tampering with stored data is not detected

6.7.1.1.6 Evidence

- Inspection record of vault storage files confirming absence of plaintext sensitive data
- Documentation reference for the encryption mechanism, algorithm, and key size
- Annex K cross-reference for the mechanism and its confidentiality and integrity properties
- Inventory of supported sensitive field types with coverage confirmation
- Record of the failed-open-without-credentials test
- Record of the tamper-detection test

6.7.2 High Risk

6.7.2.1 ACC-CON-HIGH-1

6.7.2.1.1 Reference

The product shall use unique salts per vault in accordance with Annex K.

6.7.2.1.2 Objective

Verify that each password database created by the product uses a unique salt conformant to the cryptographic requirements of an algorithm selected from Annex K.

6.7.2.1.3 Preparation

- Installed product capable of creating multiple databases or vaults
- Access to database files or debug instrumentation sufficient to observe salt values
- Binary inspection tooling
- Test environment supporting at least three separate vault instances

6.7.2.1.4 Activities

- Create at least three separate databases under controlled conditions
- Extract the salt value from each database
- Confirm each salt is distinct across the sample
- Confirm salt length and properties conform to the specifications of the selected algorithm

6.7.2.1.5 Verdict

- Pass: Each database has a distinct salt, salt generation and salt length and properties meet the specifications of the selected algorithm
- Fail: Any salt is reused across databases, no salt is present, salt generation or salt length or properties fall outside of the specifications of the selected algorithm

6.7.2.1.6 Evidence

- Extracted salt values from each test database
- Code or instrumentation reference for salt generation
- Annex K cross-reference for the salt generation mechanism and parameters\

6.7.2.2 ACC-CON-HIGH-2

6.7.2.2.1 Reference

The product shall use encryption for all network transmissions in accordance with Annex K.

6.7.2.2.2 Objective

Verify that all network transmissions performed by the product are protected by a transport security mechanism conformant to Annex K, with no fallback to unprotected channels and no exposure of credential data in transit.

6.7.2.2.3 Preparation

- Installed product with network synchronisation or remote communication features enabled
- Network capture tooling and TLS inspection harness with a controlled root of trust
- Test account configured for all network-facing features under assessment
- Network monitoring position capable of capturing all product-originated traffic

6.7.2.2.4 Activities

- Exercise every network-facing feature of the product and capture the resulting traffic
- Confirm each connection uses a transport security mechanism conformant to Annex K
- Confirm certificate validation is enforced and invalid certificates are refused
- Confirm no fallback to unprotected channels under degraded or hostile network conditions
- Inspect packet payloads to confirm no credential data is transmitted outside the protected channel

6.7.2.2.5 Verdict

- Pass: Every network transmission uses a transport security mechanism conformant to Annex K, certificate validation is enforced, no fallback to an unprotected channel occurs, and no credential data is observed outside the protected channel
- Fail: Any transmission occurs over an unprotected channel, the transport mechanism falls outside Annex K, certificate validation is bypassed, fallback to an unprotected channel occurs, or credential data is observed in transit outside the protected channel

6.7.2.2.6 Evidence

- Network capture covering each exercised feature
- Transport session details for each connection (protocol, cipher, certificate chain)
- Certificate validation records, including refusal of invalid certificates
- Payload inspection notes confirming absence of credential data outside the protected channel
- Annex K cross-reference for each transport mechanism observed

6.7.2.3 ACC-CON-HIGH-3

6.7.2.3.1 Reference

The product shall encrypt all backup data in accordance with Annex K.

6.7.2.3.2 Objective

Verify that backup data produced by the product is protected by an encryption mechanism conformant to Annex K and equivalent in strength to that applied to the primary database.

6.7.2.3.3 Preparation

- Installed product with backup functionality enabled
- Active database containing test credentials
- Access to backup files on the host file system
- Binary inspection tooling
- Documentation identifying the encryption mechanism applied to the primary database

6.7.2.3.4 Activities

- Create one backup under controlled conditions
- Confirm the backup file is encrypted and contains no plaintext credential data
- Confirm the backup encryption mechanism is conformant to an algorithm selected from Annex K
- Confirm the backup encryption mechanism is equivalent in algorithm, mode, and key derivation to that applied to the primary database
- Confirm the backup cannot be opened without the credentials required by the documented mechanism

6.7.2.3.5 Verdict

- Pass: Backup data is encrypted under a mechanism conformant to an algorithm selected from Annex K and equivalent to that of the primary database, and the backup cannot be opened without the required credentials
- Fail: Backup data is unencrypted or partially plaintext, the encryption mechanism falls outside Annex K, the mechanism is weaker than or divergent from that applied to the primary database, or the backup can be opened without the required credentials

6.7.2.3.6 Evidence

- Inspection record of the backup file confirming encryption and absence of plaintext
- Documentation reference for the primary database encryption mechanism

- Documentation reference for the backup encryption mechanism
- Annex K cross-reference for the backup encryption mechanism
- Record of the failed-open-without-credentials test

6.7.3 Critical Risk

6.7.3.1 ACC-CON-CRIT-1

6.7.3.1.1 Reference

The product's RDPS shall offer Perfect Forward Secrecy (PFS) for network transmissions in accordance with Annex K.

6.7.3.1.2 Objective

Verify that all RDPS network transmissions performed by the product offer a key exchange mechanism conformant to Annex K that provides perfect forward secrecy.

6.7.3.1.3 Preparation

- Installed product with network communication features enabled
- Network capture tooling and TLS inspection harness with a controlled root of trust
- Documentation identifying the key exchange mechanisms supported by the product
- Network monitoring position capable of capturing all product-originated traffic

6.7.3.1.4 Activities

- Exercise every network-facing feature of the product and capture the resulting traffic
- Confirm each session uses a key exchange mechanism conformant to Annex K that offers perfect forward secrecy
- Confirm non-PFS key exchange mechanisms are accepted by the product as a fallback
- Confirm perfect forward secrecy cannot be disabled through product configuration
- If PFS is enabled, confirm a past captured session cannot be decrypted given subsequent compromise of the long-term server key

6.7.3.1.5 Verdict

- Pass: Every network session uses a PFS-providing key exchange mechanism conformant to Annex K, PFS cannot be disabled, and a past session cannot be decrypted given subsequent long-term key compromise
- Fail: The key exchange mechanism falls outside Annex K, PFS can be disabled, or a past session is decryptable given subsequent long-term key compromise

6.7.3.1.6 Evidence

- Network capture covering each exercised feature
- Session details for each connection including key exchange mechanism
- Annex K cross-reference for each observed mechanism
- Record of the past-session decryption test demonstrating PFS

6.8 Integrity protection

6.8.1 Normal Risk

6.8.1.1 ACC-INT-HIGH-1

6.8.1.1.1 Reference

The product shall apply input validation to data submitted for import.

6.8.1.1.2 Objective

Verify that the product determines the format of imported files by content analysis rather than by extension alone, and that files which do not conform to a supported format are refused.

6.8.1.1.3 Preparation

- Installed product with import functionality enabled
- Documentation identifying the supported import formats and their detection mechanisms
- Test files covering each supported format under correct conditions
- Test files covering format-confusion conditions: extension-content mismatch, corrupted payload, polyglot construction, missing extension, malformed schema

6.8.1.1.4 Activities

- Submit each correctly formed test file and confirm the product accepts it and identifies the format correctly
- Submit each format-confusion test file and confirm the product refuses it
- Confirm format detection relies on content analysis and not solely on file extension
- Confirm refusals are reported with an error condition rather than silently dropped or processed
- Confirm refused inputs do not cause the product to crash or to write partial state

6.8.1.1.5 Verdict

- Pass: Format detection uses content analysis, every correctly formed file is accepted, every format-confusion file is refused with an error condition, and refused inputs leave the product in a consistent state
- Fail: Format detection relies on extension alone, any format-confusion file is accepted, refusal is silent, or any test input causes a crash or partial state

6.8.1.1.6 Evidence

- Test file set covering correct and format-confusion conditions
- Product response record for each test file (accept, refuse, error message)
- Documentation reference for the format detection mechanism
- Post-test inspection record confirming product state consistency

6.9 Data Minimisation

6.9.1 Normal Risk

6.9.1.1 ACC-DM-NORM-1

6.9.1.1.1 Reference

The product shall prevent leaking of sensitive data into logging and telemetry systems.

6.9.1.1.2 Objective

Verify that the product applies the data minimisation principle to its logging and telemetry channels, such that these channels collect, transmit, and retain only data necessary for the declared operational, diagnostic, or security purposes of the product, and do not carry sensitive data outside what is strictly necessary.

6.9.1.1.3 Preparation

- Installed product with logging and telemetry at maximum verbosity
- Active vault populated with test credentials across supported field types
- Access to local log destinations and network capture for telemetry traffic
- Documentation declaring, for each channel, the data categories collected and their purpose

6.9.1.1.4 Activities

- Exercise the product's functional surface and collect all log and telemetry output produced
- Confirm every observed data element corresponds to a declared category with a documented purpose
- Confirm no sensitive data outside the declared categories is present
- Confirm default settings align with the minimisation principle and any opt-out controls are functional

6.9.1.1.5 Verdict

- Pass: Every observed data element falls within a declared category, no sensitive data outside those categories is present, and defaults align with the minimisation principle
- Fail: Any observed data element exceeds the declared categories, sensitive data outside those categories is present, or defaults collect more than is necessary

6.9.1.1.6 Evidence

- Inventory of logging and telemetry channels with declared categories and purposes
- Collected log and telemetry output
- Classification of observed data elements against declared categories
- Configuration excerpts showing default settings

6.10 Availability protection

6.10.1 Normal Risk

6.10.1.1 ACC-AP-NORM-1

6.10.1.1.1 Reference

Any recovery process shall be operationally or cryptographically brute-force resistant.

6.10.1.1.2 Objective

Verify that account recovery flows resist brute-force attempts through operational or cryptographic means.

6.10.1.1.3 Preparation

- Installed product with account recovery functionality enabled
- Test account configured for recovery
- Tooling capable of submitting repeated recovery attempts at varying rates
- Documentation identifying the brute-force resistance mechanism

6.10.1.1.4 Activities

- Submit repeated recovery attempts using incorrect material and confirm the brute-force resistance mechanism is engaged
- Where resistance is operational, confirm rate limiting or progressive lockout is enforced consistently with documentation
- Where resistance is cryptographic, confirm recovery material is generated and validated in accordance with Annex K such that exhaustive search is computationally infeasible

6.10.1.1.5 Verdict

- Pass: The brute-force resistance mechanism is engaged consistently with documentation, and conforms to Annex K where cryptographic
- Fail: The mechanism is absent, inconsistently enforced, or falls outside Annex K where a cryptographic method is used

6.10.1.1.6 Evidence

- Record of repeated recovery attempts demonstrating brute-force resistance behaviour
- Documentation reference for the brute-force resistance mechanism
- Annex K cross-reference for any cryptographic resistance mechanism

6.11 Non-interference

6.11.1 Normal Risk

6.11.1.1 Assessment REQ-IM-NORM-1

6.11.1.1.1 Reference

The product shall not generate resource consumption such that system availability is degraded.

6.11.1.1.2 Objective

Verify that the product, in normal and worst-case operational conditions, does not consume host resources to a degree that degrades the availability of the host or of other applications running on it.

6.11.1.1.3 Preparation

- Installed product on a host representative of a supported deployment configuration
- Resource monitoring tooling for CPU, memory, storage I/O, network bandwidth, and file handles
- Workload scenarios covering idle, typical use, and worst-case sustained use (large vaults, bulk operations, synchronisation under contention, repeated unlock cycles)

6.11.1.1.4 Activities

- Establish a baseline of host resource consumption with the product installed but idle
- Exercise the product across each workload scenario and record resource consumption against the baseline
- Confirm the host remains responsive and other applications retain access to resources during product operation
- Confirm the product does not accumulate unbounded resources over an extended test window (memory growth, handle exhaustion, storage growth without bound)

6.11.1.1.5 Verdict

- Pass: Host and other applications retain availability during product operation, and no unbounded resource accumulation is observed
- Fail: Host or other application availability is degraded during product operation, or unbounded resource accumulation is observed

6.11.1.1.6 Evidence

- Baseline resource consumption record
- Resource consumption records for each workload scenario
- Record of the extended-duration test for unbounded accumulation
- Inspection notes on host and concurrent-application responsiveness

6.11.1.2 ACC-IM-NORM-2

6.11.1.2.1 Reference

The product shall not interfere with other products in a way that would prevent those products from executing their normal expected functions, unless configured by the user or in cases where the usage of this product implicitly overrides the usage of other products.

6.11.1.2.2 Objective

Verify that the product, in its default configuration, does not interfere with the operation of other products on the host, including other credential managers, hardware password managers, and platform credential services, and that any behaviour that would interfere requires explicit user configuration unless its usage implicitly pre-empts the application of other products.

6.11.1.2.3 Preparation

- Installed product on a host on which other credential-handling products and platform services are also present, including at least one other software password manager, one hardware password manager or platform authenticator, and the platform's native credential and autofill services
- Test scenarios covering autofill events, credential prompts, deep links, custom URL schemes, platform credential APIs, and browser extension event surfaces shared between products

6.11.1.2.4 Activities

- In default configuration, exercise each test scenario and confirm other products receive the events and inputs they would receive in the product's absence
- Confirm the product does not consume, suppress, or rewrite events that the platform would otherwise propagate to other products
- Confirm the product does not register itself as the default handler for deep links, custom URL schemes, or platform credential APIs without user configuration
- Confirm the product does not modify or remove the registrations, defaults, or persistent settings of other products
- Where the product offers user-configurable options that would alter these behaviours, confirm they are off by default and that enabling them requires explicit user action

6.11.1.2.5 Verdict

- Pass: In default configuration, the product does not interfere with other products across the test scenarios, does not consume or rewrite events bound for other products, does not claim default handler status without user configuration, and does not modify the state of other products; any interfering behaviour is gated behind explicit user configuration that is off by default
- Fail: In default configuration, the product consumes or rewrites events bound for other products, claims default handler status without user configuration, modifies the state of other products, or any interfering behaviour is enabled without explicit user action

6.11.1.2.6 Evidence

- Inventory of other credential-handling products and platform services present on the test host
- Record of each test scenario showing event propagation to other products in default configuration
- Inspection of deep link, URL scheme, and platform credential API registrations after product installation
- Inspection of other products' state before and after product installation

6.12 Attack surface minimisation

6.12.1 Normal Risk

6.12.1.1 ACC-MAS-NORM-1

6.12.1.1.1 Reference

The product shall implement Content Security Policy (CSP) following the principle of least privilege in web applications and browser extensions.

6.12.1.1.2 Objective

Verify that, where the product provides browser extension components or interacts with third-party websites, it declares and respects Content Security Policy in accordance with the principle of least privilege.

6.12.1.1.3 Preparation

- Installed product components that operate against the web platform, including any browser extension and any module that interacts with third-party websites
- Browser developer tooling with CSP violation reporting
- Access to the extension manifest, content script declarations, and any product-served response headers
- Test set of third-party websites enforcing a range of CSP postures, including strict policies that would conflict with permissive content script behaviour

6.12.1.1.4 Activities

- Inspect the CSP declared by each product component and confirm each directive is no more permissive than required by documented functional need
- Exercise the product against the third-party test set and confirm its content scripts and injected behaviour do not require relaxation of the third-party CSP and do not trigger policy violations on the third-party page

6.12.1.1.5 Verdict

- Pass: Each product-declared CSP is no more permissive than the functional need, the product's behaviour on third-party pages does not violate or require relaxation of the third-party CSP
- Fail: Any product-declared CSP contains directives more permissive than the need justifies, the product's behaviour on third-party pages violates or requires relaxation of the third-party CSP

6.12.1.1.6 Evidence

- Manifest excerpts, response headers, and content script declarations showing the CSP posture of each component
- Records of product behaviour on each third-party test site, including any policy violations observed

6.12.2 High Risk (none)

6.12.3 Critical Risk

6.12.3.1 ACC-MAS-CRIT-1

6.12.3.1.1 Reference

The product shall enforce session timeout and re-authentication.

6.12.3.1.2 Objective

Verify that authenticated sessions are subject to timeout and that re-authentication is required to resume use after timeout.

6.12.3.1.3 Preparation

- Installed product with authenticated session functionality enabled
- Test account with credentials sufficient to establish a session
- Means to advance system time or simulate elapsed conditions or just wait
- Documentation identifying the timeout policy and re-authentication behaviour

6.12.3.1.4 Activities

- Establish a session and allow the documented timeout to elapse; confirm the session is terminated
- Attempt to resume use after timeout and confirm re-authentication is required

6.12.3.1.5 Verdict

- Pass: Timeout is enforced as documented or configured, re-authentication is required to resume
- Fail: Timeout is absent or not enforced as documented or configured, re-authentication is not required

6.12.3.1.6 Evidence

- Configuration excerpt showing the documented timeout policy if it exists
- Record of the timeout test with timestamps

6.13 Exploitation Mitigation

6.13.1 Normal Risk

6.13.1.1 ACC-EMM-NORM-1

6.13.1.1.1 Reference

When a credential has an associated target system, the product shall validate the target system identifier (e.g. domain name, app ID, related origin) before performing an autofill operation.

6.13.1.1.2 Objective

Verify that, for any credential bound to a target system identifier, the product validates the identifier of the requesting context against the stored identifier before performing autofill, and refuses autofill where the identifiers do not match.

6.13.1.1.3 Preparation

- Installed product with autofill functionality enabled across each supported target system type (e.g. web origin, mobile app, related origin)
- Test credentials stored against known identifiers of each supported type
- Test set of requesting contexts covering: exact identifier matches, near-match variants (lookalike, homograph, sibling, substring), scheme variants where applicable, related-origin declarations, and contexts presenting no identifier

6.13.1.1.4 Activities

- Exercise autofill from each test requesting context against the corresponding stored credential
- Confirm autofill is offered on exact identifier matches and refused on near-match and non-matching contexts
- For related-origin or equivalent declarations, confirm matching follows the documented policy
- Confirm autofill is refused where the requesting context presents no identifier that can be validated

6.13.1.1.5 Verdict

- Pass: Autofill is offered only on requesting contexts whose identifier matches the stored identifier under the user configuration, all non-matching contexts are refused, contexts without an identifier that can be validated are refused
- Fail: Autofill is offered on any non-matching context, autofill proceeds where no identifier that can be validated is present, matching diverges from user configuration for any target system type

6.13.1.1.6 Evidence

- Record of autofill behaviour on each requesting context in the test set
- Matching user configuration for each target system type if available

6.14 Monitoring

6.14.1 Normal Risk

6.14.1.1 ACC-LOG-NORM-1

6.14.1.1.1 Reference

The product shall log all import and export activities.

6.14.1.1.2 Objective

Verify that every import and export operation performed by the product produces a log entry containing appropriate metadata, that failed operations are logged with sufficient detail to support audit, and that logs do not carry sensitive credential content.

6.14.1.1.3 Preparation

- Installed product with logging enabled and import and export functionality available
- Access to the log destinations used by the product
- Test inputs covering successful import, successful export, failed import (authentication failure, validation failure), and failed export

6.14.1.1.4 Activities

- Exercise each test scenario and collect the resulting log entries
- Confirm every operation produces a log entry containing the metadata required by documentation
- Confirm failed operations are logged with the error condition that caused refusal
- Inspect log entries to confirm no credential content or other sensitive field values are present

6.14.1.1.5 Verdict

- Pass: Every test scenario produces a log entry with appropriate metadata, failed operations are logged with error detail, no sensitive content appears in logs
- Fail: Any operation produces no log entry, any failed operation is logged without error detail, sensitive content appears in any log entry

6.14.1.1.6 Evidence

- Log excerpts for each test scenario
- Inspection notes confirming absence of sensitive content

6.14.2 High Risk (none)

6.14.3 Critical Risk

6.14.3.1 ACC-LOG-CRIT-1

6.14.3.1.1 Reference

The product shall maintain comprehensive audit logs with tamper protection. At minimum, the product shall log the following events:

- a) access to a password vault;
- b) enrolment of a new device on which the product is to be used;
- c) reset of a master password.

6.14.3.1.2 Objective

Verify that the product produces audit log entries for vault access, device enrolment, master password reset, with the metadata required by the documented logging policy, with tamper protection conformant to Annex K, and without exposing sensitive credential content.

6.14.3.1.3 Preparation

- Installed product with audit logging enabled

- Active vault with test credentials
- Access to the log destinations used by the product
- Means to induce each of vault access, device enrolment, and master password reset under controlled conditions

6.14.3.1.4 Activities

- Induce each of vault access, device enrolment, master password reset, and collect the resulting log entries
- Confirm each event produces a log entry containing the metadata required by documentation
- Inspect log entries to confirm no credential content, key material, or other sensitive field values are present
- Confirm the tamper protection mechanism is conformant to Annex K, and that tampering with stored log entries is detected

6.14.3.1.5 Verdict

- Pass: Each of vault access, device enrolment, master password reset, produces a log entry with the required metadata, no sensitive content appears in logs, tamper protection is conformant to Annex K and detects modification, log destinations are protected as documented, and retention behaviour is consistent with documentation
- Fail: Any of these events produces no log entry, any entry omits required metadata, sensitive content appears in any entry, tamper protection is absent or falls outside Annex K, or modification of stored logs is not detected

6.14.3.1.6 Evidence

- Log excerpts for each of vault access, password view or use, device enrolment, master password reset, and Failed unlock attempt
- Annex K cross-reference for the tamper protection mechanism
- Record of the tamper-detection test
- Record of the unprivileged modification attempt
- Inspection notes confirming absence of sensitive content

6.14.3.2 ACC-LOG-CRIT-2

6.14.3.2.1 Reference

The product shall log all authorisation decisions.

6.14.3.2.2 Objective

Verify that every authorisation decision performed by the product produces a log entry containing the metadata required by the configured logging policy, and that the resulting logs are subject to tamper protection conformant to Annex K.

6.14.3.2.3 Preparation

- Installed product with authorisation and logging functionality enabled
- Test accounts covering each privilege level supported by the product
- Access to the logs
- Test scenarios covering both authorised operations and denied operations across each privilege level

6.14.3.2.4 Activities

- Exercise each test scenario and collect the resulting log entries
- Confirm every authorisation produces a log entry containing appropriate metadata
- Inspect log entries to confirm no credential content or other sensitive field values are present
- Confirm the tamper protection mechanism is conformant to Annex K, and that tampering with stored log entries is detected

6.14.3.2.5 Verdict

- Pass: Every authorisation event in the test scenarios produces a log entry with the appropriate metadata, denials are logged with the reason for refusal, no sensitive content appears in logs, tamper protection is conformant to Annex K
- Fail: Any authorisation decision produces no log entry, sensitive content appears in any entry, tamper protection is absent or falls outside Annex K

6.14.3.2.6 Evidence

- Log excerpts for authorised and denied operations across each privilege level
- Annex K cross-reference for the tamper protection mechanism
- Record of the tamper-detection test
- Inspection notes confirming absence of sensitive content

6.15 Factory reset and data portability

6.15.1 Normal Risk

6.15.1.1 REQ-DRT-NORM-1

6.15.1.1.1 Reference

The export option, including the migration of credentials (e.g. FIDO Credential Exchange Protocol), shall by default use dedicated secure platform APIs or provide an encrypted method in line with Annex K.

6.15.1.1.2 Objective

Verify that the default export pathways provided by the product, including credential migration flows, select an encrypted method or dedicated secure platform API by default in line with Annex K.

6.15.1.1.3 Preparation

- Installed product with export and credential migration functionality enabled
- Active vault containing test credentials across each supported sensitive field type, including any credential types subject to migration protocols
- Access to the file system or transport endpoint where exports are delivered

6.15.1.1.4 Activities

- For each export pathway, including credential migration, initiate an export without altering default settings and confirm the encrypted method is selected

- Confirm exported material is protected under a mechanism conformant to Annex K or uses a dedicated secure platform API and contains no plaintext credential data

6.15.1.1.5 Verdict

- Pass: Every export pathway defaults to an encrypted method conformant to Annex K or dedicated secure platform API, exported material contains no plaintext credential data
- Fail: Any export pathway defaults to a plaintext or non-Annex-K and does not use a dedicated secure platform API, exported material contains plaintext credential data

6.15.1.1.6 Evidence

- Record of the default state for each export pathway including credential migration
- Inspection record of exported material confirming encryption and absence of plaintext
- Annex K cross-reference for each encryption mechanism observed
- Record of the failed-decryption-without-credentials test
- Reference to the dedicated secure platform API used (if one is used)

6.15.2 High Risk

6.15.2.1 ACC-DRT-HIGH-1

6.15.2.1.1 Reference

User offboarding shall trigger revocation of related online vault.

6.15.2.1.2 Objective

Verify that, when an offboarding event is initiated for a user, the product revokes that user's access to all related online vaults.

6.15.2.1.3 Preparation

- Installed product with multi-user and shared vault functionality enabled
- Test user account enrolled across multiple devices and with active sessions
- Shared vaults to which the test user has access at varying privilege levels
- Means to trigger an offboarding event consistent with the documented procedure

6.15.2.1.4 Activities

- Establish active sessions for the test user across each enrolled device and confirm access to each shared vault
- Trigger the offboarding event per the documented procedure
- Confirm the test user's access to each shared vault is revoked
- Confirm existing sessions held by the test user are invalidated such that they cannot be reused on any enrolled device

6.15.2.1.5 Verdict

- Pass: Offboarding revokes access to every related vault, existing sessions are invalidated across all enrolled devices
- Fail: Any shared vault remains accessible to the offboarded user, any existing session remains usable on any device

6.15.2.1.6 Evidence

- Record of active sessions and shared vault access before offboarding
- Record of the offboarding event with timestamp
- Record of access attempts to each shared vault after offboarding
- Record of authentication attempts to the password manager after offboarding
- Record of session and token reuse attempts across enrolled devices

6.15.3 Critical Risk

6.15.3.1 REQ-DRT-CRIT-1 (ex IEF-REQ-5)

6.15.3.1.1 Reference

The product shall require re-authentication for export operations. An existing SSO or OS-level authentication is considered equivalent to an active re-authentication. If there is no authentication mechanism, there shall be explicit user confirmation.

6.15.3.1.2 Objective

Verify that every export operation requires one of: active re-authentication, an equivalent SSO or OS-level authentication, or, where no authentication mechanism exists, explicit user confirmation; and that incorrect, cancelled, or denied challenges prevent the export from proceeding.

6.15.3.1.3 Preparation

- Installed product with export functionality enabled and an active authenticated session
- Active vault containing test credentials
- Access to the file system or transport endpoint where exports are delivered
- Means to exercise any SSO or OS-level authentication mechanism the product relies on as equivalent

6.15.3.1.4 Activities

- For each export pathway, initiate an export from an active session and confirm the product invokes one of: active re-authentication, an SSO or OS-level authentication assertion, or, where no authentication mechanism exists, an explicit user confirmation step
- For pathways using active re-authentication, submit incorrect credentials and confirm the export is refused
- For pathways using SSO or OS-level equivalence, deny the underlying assertion and confirm the export is refused
- For pathways using explicit confirmation, decline the confirmation and confirm the export is refused
- In each case, cancel the challenge and confirm the export is aborted with no exported material produced

- Complete the challenge successfully and confirm the export proceeds
- Confirm the challenge cannot be bypassed by manipulation of session state

6.15.3.1.5 Verdict

- Pass: Every export pathway invokes an applicable challenge (re-authentication, SSO or OS-level equivalent, or explicit confirmation where no authentication mechanism exists), incorrect or denied challenges refuse the export, cancellation aborts the export with no material produced, and the challenge cannot be bypassed
- Fail: Any export pathway proceeds without an applicable challenge, an incorrect or denied challenge does not refuse the export, cancellation leaves any exported material produced, or the challenge can be bypassed

6.15.3.1.6 Evidence

- Record of the challenge invoked for each export pathway, classified by type (re-authentication, SSO or OS-level equivalent, explicit confirmation)
- Record of the refused export under incorrect or denied challenge
- Record of the cancelled challenge with inspection confirming no exported material
- Record of the successful export following a completed challenge

Annex A (informative): Relationship between the present document and the essential cybersecurity requirements of EU Regulation (EU) 2024/2847 - the Cyber Resilience Act

The present document has been prepared under the Commission's standardisation request C(2025)618 [i.3] to provide one voluntary means of conforming to the requirements of Regulation (EU) 2024/2847 [i.1] of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828, known as the Cyber Resilience Act (CRA).

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

**Table A.1: Correspondence between the European Standard and
Annex I Part I of Regulation (EU) 2024/2847**

Description	Essential Requirements of Regulation (EU) 2024/2847	Clause(s) of the present document	Remarks / Notes
Annex I, Part I (1)	<i>"Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks."</i>	Clause 5.2 Clause 6.2 Annex R: REQ-RDPS-L-AUTH-NORM-001 to -003, REQ-RDPS-L-INTEG-NORM-001 to -003, REQ-RDPS-L-CONF-NORM-001 to -003, REQ-RDPS-L-AVAIL-NORM-001 to -003, REQ-RDPS-R-AUTH-NORM-001 to -003, REQ-RDPS-R-INTEG-NORM-001 to -003, REQ-RDPS-R-CONF-NORM-001 to -003, REQ-RDPS-R-AVAIL-NORM-001 to -003.	
Annex I, Part I, (2)(a)	<i>"Products with digital elements shall be made available on the market without known exploitable vulnerabilities."</i>	Clause 5.3 Clause 6.3	
Annex I, Part I, (2)(b)	<i>"Products with digital elements shall be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state."</i>	Clause 5.4 Clause 6.4	
Annex I, Part I, (2)(c)	<i>"Products with digital elements shall ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out"</i>	Clause 5.5 Clause 6.5	

Description	Essential Requirements of Regulation (EU) 2024/2847	Clause(s) of the present document	Remarks / Notes
	<i>mechanism, through the notification of available updates to users, and the option to temporarily postpone them"</i>		
Annex I, Part I, (2)(d)	<i>"Products with digital elements shall ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access"</i>	Clause 5.6 Clause 6.6 Annex R: REQ-RDPS-L-AUTH-NORM-001 to -003 and REQ-RDPS-R-AUTH-NORM-001 to -003.	
Annex I, Part I, (2)(e)	<i>"Products with digital elements shall protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by best practice mechanisms, and by using other technical means."</i>	Clause 5.7 Clause 6.7 Annex R: REQ-RDPS-L-CONF-NORM-001 to -003 and REQ-RDPS-R-CONF-NORM-001 to -003.	
Annex I, Part I, (2)(f)	<i>"Products with digital elements shall protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions."</i>	Clause 5.8 Clause 6.8 Annex R: Integrity: REQ-RDPS-L-INTEG-NORM-001 to -003 and REQ-RDPS-R-INTEG-NORM-001 to -003.	
Annex I, Part I, (2)(g)	<i>"Products with digital elements shall process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation)."</i>	Clause 5.9 Clause 6.9	
Annex I, Part I, (2)(h)	<i>"Products with digital elements shall protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks."</i>	Clause 5.10 Clause 6.10 Annex R: REQ-RDPS-L-AVAIL-NORM-001 to -003 and REQ-RDPS-R-AVAIL-NORM-001 to -003.	
Annex I, Part I, (2)(i)	<i>"Products with digital elements shall minimise the negative impact by the products themselves or connected products on the availability of services provided by other products or networks."</i>	Clause 5.11 Clause 6.11	
Annex I, Part I, (2)(j)	<i>"Products with digital elements shall be designed, developed and produced to limit attack surfaces, including external interfaces."</i>	Clause 5.12 Clause 6.12 Annex R: REQ-RDPS-L-AUTH-NORM-001 to -003, REQ-RDPS-R-AUTH-NORM-001 to -003	

Description	Essential Requirements of Regulation (EU) 2024/2847	Clause(s) of the present document	Remarks / Notes
Annex I, Part I, (2)(k)	<i>"Products with digital elements shall be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques."</i>	Clause 5.13 Clause 6.13 Annex R: REQ-RDPS-L-AVAIL-HIGH-002 to -003 and REQ-RDPS-R-AVAIL-HIGH-002 to -003.	
Annex I, Part I, (2)(l)	<i>"Products with digital elements shall provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user."</i>	Clause 5.14 Clause 6.14	
Annex I, Part I, (2)(m)	<i>"Products with digital elements shall provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner."</i>	Clause 5.15 Clause 6.15	

Key to columns:

Description A textual reference to the requirement.

Requirements of Regulation

Identification of point(s) defining the requirement in Regulation (EU) 2024/2847 - the Cyber Resilience Act.

Clause(s) of the present document

Identification of clause(s) addressing the requirement in the present document

Presumption of conformity stays valid only as long as a reference to the present document is maintained in the list published in the Official Journal of the European Union. Users of the present document should consult frequently the latest list published in the Official Journal of the European Union.

Other Union legislation may be applicable to the product(s) falling within the scope of the present document.

Annex B (informative): Security analysis

B.0 Cybersecurity threat landscape, risk identification and assessment methodology

This annex presents the security analysis underpinning the requirements specified in the present document, in accordance with the risk-based approach prescribed by the Cyber Resilience Act [i.1].

The security analysis identifies the assets handled by password managers, the threats to which those assets are exposed in the use cases defined in clause 4.6, and the factors that determine how those threats translate into severity for a given deployment. From this, security profiles are derived that inform the applicability of the technical requirements specified in clause 5 and the corresponding assessments in clause 6.

The analysis presented here is the work of the standardizers and serves only to inform the applicability of requirements within the present document. It does not constitute, replace, or interact with the assessment of cybersecurity risks that manufacturers are legally obliged to conduct under Article 13 of the Cyber Resilience Act. Manufacturers conducting their own assessment of cybersecurity risks should refer to the CRA and to the legal guidance issued in support of it.

A password manager stores credentials on behalf of a user and presents them to applications, browsers, or relying parties at the point of use. It operates on host devices that may be compromised, inside browsers that load content from arbitrary origins, and across networks that may be observed or interfered with. The credentials it holds are high-value assets and consequently attract active interest from threat actors. Users may be deceived into presenting credentials to illegitimate destinations, and physical access to the host device by parties other than the user is a foreseeable condition. The product is expected to protect credentials at rest, in transit, and at the point of use, while remaining usable enough to be adopted in practice. Some deployments are composed of multiple components, including enterprise, mobile, desktop, and browser extension parts, each contributing to the overall handling of credentials and each presenting its own exposure.

The use cases defined in clause 4.6 describe the principal deployment models for password managers within the scope of the present document. Each presents a distinct combination of threat exposure, asset sensitivity, and architectural constraint. For each use case, this annex provides a table mapping the requirement categories of the confidentiality, integrity, authenticity, and availability framework against the assets identified in clause B.1, assigning a severity level of Normal, High, or Critical to each combination.

These severity levels form security profiles that determine, for each use case, both the intensity of the requirements applied in each category and the type of evidence required to demonstrate conformance. A use case with a higher overall severity demands more rigorous implementation and stronger forms of evidence than a use case with lower severity. This graduated approach ensures that the requirements imposed by the present document are proportional to the exposure that each deployment model presents to the confidentiality, integrity, authenticity, and availability of the assets it handles.

B.1 Assets

B.1.1 Data

B.1.1.1 Vault data

- Stored credentials (usernames, passwords, passphrases)
- Stored passkeys and cryptographic key pairs
- TOTP seeds and other MFA secrets
- Associated URIs and service identifiers

- Secure notes and custom fields
- File attachments
- Vault structure and folder/collection organisation
- Entry metadata (creation date, modification date, last accessed, access count, title, expiry, icons)
- Password history per entry
- Shared vault and group membership associations

B.1.1.2 Key material

- Master password or equivalent authentication secret
- Key derivation parameters (salt, iteration count, algorithm)
- Vault encryption key (derived or wrapped)
- Per-entry or per-field encryption keys, if applicable
- Session tokens and authentication tokens
- API keys and service credentials
- Key shares or recovery keys
- Hardware-bound keys (secure element, TPM)
- TLS certificates and pinning data

B.1.1.3 Configuration data

- Application settings and user preferences
- Autofill rules and URI matching configuration
- Browser extension permissions and content script scope
- Sync configuration (endpoints, device list, pairing state)
- Backup schedule and retention settings
- Enterprise policy definitions and enforcement rules
- Role-based access control rules and group definitions
- Password generation policy (length, complexity, character sets)
- Clipboard clearing timeout and lock timeout settings

B.1.1.4 Identity and device data

- User account identity (such as email, username, account ID)
- Device identifiers and device trust state
- Registered MFA devices and recovery codes
- Biometric enrolment data or references

- Session history and active session list
- IP addresses and geolocation data associated with access events

B.1.1.5 Operational data

- Audit logs (access events, sharing changes, administrative actions)
- Sync state (version vectors, conflict logs, pending changes)
- Error and diagnostic logs
- Network traffic metadata (request timing, endpoints contacted)
- Telemetry and usage analytics, if collected
- Backup copies of vault data (local or remote)
- Import/export files (plaintext or encrypted)

B.1.1.6 Transient data

- Decrypted credentials held in memory
- Clipboard contents containing credentials
- Autofill data injected into DOM or form fields
- Decrypted vault contents in page or process memory
- Swap or hibernation files containing memory state

B.1.2 Product functions

B.1.2.1 Vault management essential functions

- Encrypt and decrypt vault data using derived key material
- Create, read, update, and delete credential entries
- Derive encryption keys from master password or vault key, using an approved KDF
- Authenticate user before granting vault access
- Lock vault after timeout or user action
- Generate passwords according to configured policy
- Search and filter vault entries
- Organise entries into folders, collections, or tags
- Store and manage secure notes and file attachments
- Maintain password history per entry
- Evaluate password strength and identify reused or compromised passwords
- Support import from and export to standard formats

B.1.2.2 Autofill and credential delivery essential functions

- Detect and match credential entries to target URIs or applications
- Fill username and password fields in forms or applications
- Deliver TOTP codes or passkey assertions on request
- Detect and fill custom or non-standard form fields
- Offer to save new or updated credentials after form submission
- Provide phishing protection by verifying URI before autofill
- Manage clipboard clearing after credential copy
- Support autofill in native applications outside the browser

B.1.2.3 Authentication and access control essential functions

- Authenticate user via appropriate methods (master password, biometrics, hardware tokens, etc.)
- Secured credential sharing
- Enforce vault lock on timeout, device lock, or application close
- Manage session lifecycle (creation, renewal, revocation)
- Support multi-factor authentication (TOTP, hardware key, biometric)
- Support passwordless or passkey-based vault unlock
- Enforce account lockout after repeated failed attempts
- Support emergency access or trusted contact recovery
- Support enterprise SSO integration (SAML, OIDC)

B.1.2.4 Synchronisation functions

- Synchronise vault data across multiple devices
- Resolve conflicts in concurrent vault modifications
- Maintain sync state and version history
- Detect and prevent replay of stale vault state
- Manage device registration and deregistration
- Operate in offline mode with deferred sync on reconnection

B.1.2.5 Browser extension functions

- Inject content scripts for form detection and autofill
- Communicate with host application via IPC or native messaging
- Manage extension-local credential cache
- Detect and warn on suspected phishing pages

- Handle browser storage for session and configuration data

B.1.2.6 Enterprise administration functions

- Provision and deprovision user accounts
- Define and enforce organisational password policies
- Manage shared vaults and group-based access
- Support directory integration
- Provide administrative audit and reporting interfaces
- Enforce role-based access control across the organisation
- Support multi-tenant isolation in managed service deployments

B.1.2.7 Backup and recovery functions

- Create encrypted backups of vault data
- Restore vault from backup
- Support account recovery via recovery keys or key shares
- Support emergency access delegation

B.1.2.8 Update and maintenance functions

- Apply software or firmware updates with integrity verification
- Manage automatic update delivery and installation
- Verify update authenticity via code signing
- Support rollback to previous version on update failure

B.1.2.9 Hardware-specific functions

- Store and protect key material within a secure element
- Enforce on-device authentication (PIN, biometric) before key release
- Resist physical tampering and side-channel attacks
- Communicate credentials to host via secure channel (USB, NFC, Bluetooth®)
- Perform secure erase on factory reset

B.2 Use Cases

B.2.1 UC-1 Local Password Manager Risk Assessment

B.2.1.1 Threat Profile

Primary Threat Actors: Opportunistic criminals, malware authors, physical thieves, insider threats (family/colleagues).

Attack Vectors:

- Physical device theft or unauthorised access.
- Malware/keyloggers on local system.
- Memory dumping attacks.
- Backup file extraction.
- Forensic recovery of deleted vault files.
- Brute force against master password.

B.2.1.2 Impact Analysis

Table B.2.1.2-1

Impact Category	Security Profile	Justification
Appropriate level of cybersecurity	High	Local malware can directly access vault data (clause B.1.1.1) and decrypted credentials in memory (clause B.1.1.6), enabling full credential extraction.
No known exploitable vulnerabilities	Normal	Local-side flaws (memory dumping, weak KDF parameters, import/export parsing) enable extraction of vault data (clause B.1.1.1) and key material (clause B.1.1.2).
Secure by default configuration	Normal	Default configuration enforces master-password complexity on creation and masked entry; no remote enrolment dependency.
Security updates	Normal	Updates are applied manually by the user; authenticity and integrity verification of update packages and rejection of failed updates remain in force.
Authentication and access control	High	Single-user device authentication; KDF-protected unlock, MFA where available and policy-driven re-authentication.
Confidentiality protection	High	Vault data (clause B.1.1.1), key material (clause B.1.1.2), configuration data (clause B.1.1.3) and backups (clause B.1.1.5) reside locally and require encryption at rest.
Integrity protection	Normal	No server-side validation to detect local tampering of vault data (clause B.1.1.1) or configuration data (clause B.1.1.3); on-device input validation of imported data applies.
Data minimisation	Normal	Local-only storage; no telemetry transmitted to third parties. Logging and telemetry should not leak sensitive data.
Availability protection	Normal	Device loss, theft or hardware failure is a single point of failure for vault data (clause B.1.1.1) and key material (clause B.1.1.2); any recovery process is brute-force resistant.
Non-interference	Normal	Product does not degrade host availability and does not interfere with other products unless configured by the user.
Attack surface minimisation	Normal	Primary vectors are local filesystem access to vault data (clause B.1.1.1), memory inspection of transient data (clause B.1.1.6) and parsing of import/export files (clause B.1.1.5).

Impact Category	Security Profile	Justification
Exploit mitigation	Normal	Decrypted credentials (B.1.1.6) cleared from RAM promptly; autofill operations validate the target system identifier before release.
Monitoring	Normal	Audit logs (clause B.1.1.5) record import/export activities; logs avoid storing plaintext credentials (clause B.1.1.1).
Factory reset and data portability	Normal	User has full control over vault data (clause B.1.1.1) deletion; export uses dedicated secure platform APIs or an encrypted method.

B.2.2 UC-2 Password Manager Application with Remote-Based Resources Risk Assessment

B.2.2.1 Threat Profile

Primary Threat Actors: Nation-state actors, organised cybercrime, malicious insiders at provider, hacktivist groups.

Attack Vectors:

- Provider infrastructure compromise.
- Account takeover via credential stuffing.
- Man-in-the-middle attacks.
- API vulnerabilities.
- Supply chain attacks on provider.
- Legal compulsion/surveillance.
- DDoS affecting availability.

B.2.2.2 Impact Analysis

Table B.2.2.2-1

Impact Category	Security Profile	Justification
Appropriate level of cybersecurity	Critical	A server-side vulnerability could compromise all vault data (clause B.1.1.1) and key material (clause B.1.1.2) simultaneously across the multi-tenant platform.
No known exploitable vulnerabilities	Normal	Server-side and client flaws subject to pre-deployment KEV testing; CIAA-impacting flaws on the assets in clauses B.1.1.1 to B.1.1.4 are out of scope at first use.
Secure by default configuration	Normal	Default configuration enforces master-password complexity and masked entry; client-side encryption applies before any data leaves the device.
Security updates	Critical	A compromised server-pushed update via update and maintenance functions (clause B.1.2.8) could exfiltrate vault data (clause B.1.1.1) at scale; monotonic version counter and authorised rollback apply.
Authentication and access control	High	Authentication and access control (clause B.1.2.3) resist credential stuffing, phishing and session hijacking; least-privilege and per-operation authorisation enforced.
Confidentiality protection	Critical	Vault data (clause B.1.1.1) and key material (clause B.1.1.2) never exposed in transit or at rest on the server; unique salts per vault, TLS for all transmissions, encrypted backups and perfect forward secrecy by default.
Integrity protection	Normal	Server-side compromise could enable silent modification of vault data (clause B.1.1.1) and configuration data (clause B.1.1.3); input validation of imported data applies.
Data minimisation	Normal	Server-side identity and device data (clause B.1.1.4) and operational data (clause B.1.1.5) such as access timestamps, IPs and device IDs are minimised; logging and telemetry do not leak sensitive data.
Availability protection	Normal	Network dependency means outages prevent vault management functions (clause B.1.2.1) and autofill functions (clause B.1.2.2); recovery processes are brute-force resistant.
Non-interference	Normal	Product does not degrade host availability and does not interfere with other products unless configured by the user.
Attack surface minimisation	Critical	Remote APIs, authentication endpoints (clause B.1.2.3), web interfaces, mobile apps and admin consoles each represent distinct attack vectors exposing vault data (clause B.1.1.1) and operational data (clause B.1.1.5).
Exploit mitigation	Normal	Autofill operations validate the target system identifier; transient data (clause B.1.1.6) cleared from RAM promptly on the client.
Monitoring	Critical	Centralised audit logs (clause B.1.1.5) with tamper protection cover vault access, device enrolment and master-password reset; authorisation decisions and violations are logged.
Factory reset and data portability	High	Verifiable purge of vault data (clause B.1.1.1), key material (clause B.1.1.2) and backup copies (clause B.1.1.5) from all replicas on account deletion; export uses an encrypted method.

B.2.3 UC-3: Hybrid Local and Remote-Based Resources Risk Assessment

B.2.3.1 Threat Profile

Primary Threat Actors: Advanced persistent threats, synchronised attack groups, state-sponsored actors.

Attack Vectors:

- Synchronisation protocol exploitation.
- Differential attack between local/cloud versions.
- Key distribution vulnerabilities.
- Conflict resolution manipulation.

- Version rollback attacks.
- Cross-device correlation attacks.

B.2.3.2 Impact Analysis

Table B.2.3.2-1

Impact Category	Security Profile	Justification
Appropriate level of cybersecurity	Critical	Combines the attack surfaces of local and cloud architectures; interaction between synchronisation functions (clause B.1.2.4) and local vault management (clause B.1.2.1) may introduce unique flaws.
No known exploitable vulnerabilities	Normal	Interaction between synchronisation functions (clause B.1.2.4) and local vault management (clause B.1.2.1) subject to pre-deployment KEV testing across both code paths.
Secure by default configuration	Normal	Default configuration enforces master-password complexity and masked entry on every client; client-side encryption applies before synchronisation.
Security updates	Critical	A compromised update via update and maintenance functions (clause B.1.2.8) on any platform could poison the sync chain (clause B.1.2.4) and propagate malicious changes to all synchronised devices; monotonic version counter and authorised rollback apply.
Authentication and access control	High	Authentication and access control (clause B.1.2.3) enforced consistently across local and remote surfaces; least-privilege and per-operation authorisation prevent a single compromised device from exfiltrating vault data (clause B.1.1.1).
Confidentiality protection	Critical	Cloud-stored vault data (clause B.1.1.1) encrypted with client-held key material (clause B.1.1.2) before sync; unique salts, TLS, encrypted backups and perfect forward secrecy by default.
Integrity protection	Normal	Replay attacks may restore stale vault data (clause B.1.1.1); input validation of imported data applies, anti-replay in synchronisation functions (clause B.1.2.4) is supported by the product design.
Data minimisation	Normal	Multiple storage copies increase the data footprint of vault data (clause B.1.1.1); sync state (clause B.1.1.5) and device data (clause B.1.1.4) minimised; logging and telemetry do not leak sensitive data.
Availability protection	Normal	Remote service failure may break synchronisation functions (clause B.1.2.4); local vaults remain functional for vault management (clause B.1.2.1); recovery processes are brute-force resistant.
Non-interference	Normal	Product does not degrade host availability and does not interfere with other products unless configured by the user.
Attack surface minimisation	Critical	Local filesystem access to vault data (clause B.1.1.1), cloud APIs, sync endpoints (clause B.1.2.4), conflict resolution and device pairing using device data (clause B.1.1.4) all require independent and combined hardening.
Exploit mitigation	Normal	Autofill operations validate the target system identifier; transient data (clause B.1.1.6) cleared from RAM promptly on each client.
Monitoring	Critical	Audit logs (clause B.1.1.5) with tamper protection capture sync events (clause B.1.2.4), conflict resolutions and access patterns across devices; authorisation decisions and violations are logged.
Factory reset and data portability	High	Deletion of vault data (clause B.1.1.1) propagates reliably across all synchronised copies; export uses an encrypted method.

B.2.4 UC-4: Browser Extension Risk Assessment

B.2.4.1 Threat Profile

Primary Threat Actors: Web-based attackers, malicious websites, phishing operators, extension store compromise.

Attack Vectors:

- Malicious website DOM manipulation.
- Cross-site scripting (XSS) attacks.
- Extension permission abuse.

- Update mechanism hijacking.
- Browser vulnerability inheritance.
- Phishing via lookalike domains.
- Extension store compromise.

B.2.4.2 Impact Analysis

Table B.2.4.2-1

Impact Category	Security Profile	Justification
Appropriate level of cybersecurity	High	JavaScript flaws, XSS and malicious web content can interact with browser extension functions (clause B.1.2.5) and autofill functions (clause B.1.2.2), exposing vault data (clause B.1.1.1) through the autofill pipeline.
No known exploitable vulnerabilities	Normal	Extension code and content scripts subject to pre-deployment KEV testing; CIAA-impacting flaws on the assets in clauses B.1.1.1 to B.1.1.4 are out of scope at first use.
Secure by default configuration	Normal	Default configuration enforces master-password complexity and masked entry; vault data (clause B.1.1.1) and key material (clause B.1.1.2) isolated from page-accessible contexts.
Security updates	Critical	Marketplace updates bypass user control of update and maintenance functions (clause B.1.2.8); monotonic version counter and authorised rollback apply.
Authentication and access control	High	Authentication and access control (clause B.1.2.3) gate access to vault data (clause B.1.1.1) before autofill; least-privilege and per-operation authorisation enforced for browser extension functions (clause B.1.2.5).
Confidentiality protection	Critical	Extension storage of vault data (clause B.1.1.1) and key material (clause B.1.1.2) encrypted at rest; unique salts, TLS, encrypted backups and perfect forward secrecy by default.
Integrity protection	Normal	Malicious pages may inject fake form fields targeting autofill functions (clause B.1.2.2); input validation of imported data applies.
Data minimisation	Normal	Browser extension functions (clause B.1.2.5) request minimum permissions; configuration data (clause B.1.1.3) such as content script scope is limited to form detection and autofill.
Availability protection	Normal	Marketplace removal or browser update may disable browser extension functions (clause B.1.2.5) but does not destroy vault data (clause B.1.1.1) stored externally; recovery processes are brute-force resistant.
Non-interference	Normal	Product does not degrade browser availability and does not interfere with other products unless configured by the user.
Attack surface minimisation	Critical	Browser extension functions (clause B.1.2.5) expose DOM manipulation, content scripts on every page, service workers, IPC channels, clipboard access to transient data (clause B.1.1.6), storage APIs and the marketplace update channel (clause B.1.2.8); CSP enforced and session timeout applied.
Exploit mitigation	Normal	Autofill operations validate the target system identifier by verifying associated URIs (clause B.1.1.1); transient data (clause B.1.1.6) cleared from RAM promptly.
Monitoring	Normal	Audit logs (clause B.1.1.5) record autofill events (clause B.1.2.2) and suspicious page interactions; logs avoid storing plaintext vault data (clause B.1.1.1).
Factory reset and data portability	Normal	Cached vault data (clause B.1.1.1), session tokens (clause B.1.1.2) and configuration data (clause B.1.1.3) purgeable from browser storage; export uses an encrypted method.

B.2.5 UC-5: Enterprise Password Manager Risk Assessment

B.2.5.1 Threat Profile

Primary Threat Actors: Nation-state APTs, insider threats, organised cybercrime, ransomware operators.

Attack Vectors:

- Privileged account compromise.

- Insider credential abuse.
- Supply chain attacks.
- Administrative interface exploitation.
- Directory service compromise.

B.2.5.2 Impact Assessment

Table B.2.5.2-1

Impact Category	Security Profile	Justification
Appropriate level of cybersecurity	Critical	Holds vault data (clause B.1.1.1) for the entire organisation including privileged accounts, API keys and service credentials (clause B.1.1.2); any exploitable vulnerability enables lateral movement at scale.
No known exploitable vulnerabilities	Normal	Server-side and admin-side flaws subject to pre-deployment KEV testing; CIAA-impacting flaws on the assets in clauses B.1.1.1 to B.1.1.4 are out of scope at first use.
Secure by default configuration	Normal	Default configuration enforces master-password complexity and masked entry; admin separation and identity-infrastructure integration apply.
Security updates	Critical	Update and maintenance functions (clause B.1.2.8) across thousands of endpoints rigorously authenticated; monotonic version counter and authorised rollback apply (UC5 in scope of clause 5.5.3).
Authentication and access control	Critical	MFA enforced for administrative access in factory default; exponential backoff for failed online attempts; RBAC or ABAC for multi-user environments; atomic authorisation checks; account lockout after failed attempts; granular permission assignment.
Confidentiality protection	Critical	Organisational vault data (clause B.1.1.1), key material (clause B.1.1.2) and shared vault associations encrypted; unique salts, TLS, encrypted backups and perfect forward secrecy by default.
Integrity protection	Normal	Insider threats with admin access may modify shared vault data (B.1.1.1) or RBAC rules (clause B.1.1.3); input validation of imported data applies.
Data minimisation	Normal	Enterprise operational data (clause B.1.1.5) including access patterns, identity and device data (clause B.1.1.4), sharing relationships and group memberships (clause B.1.1.3) minimised; logging and telemetry do not leak sensitive data.
Availability protection	Normal	Outage affecting vault management functions (clause B.1.2.1) and enterprise administration functions (clause B.1.2.6) can lock thousands of users out; recovery processes are brute-force resistant.
Non-interference	Normal	Product does not degrade managed endpoint availability and does not interfere with other products unless configured by the user.
Attack surface minimisation	Critical	Enterprise administration functions (clause B.1.2.6) including AD connectors, SCIM, SAML/OIDC endpoints, admin panels, APIs and MSP consoles each introduce distinct attack vectors; CSP enforced and session timeout applied.
Exploit mitigation	Normal	Autofill operations validate the target system identifier; transient data (clause B.1.1.6) cleared from RAM promptly on each client.
Monitoring	Critical	Audit logs (clause B.1.1.5) with tamper protection reliably attribute activity to individual actors across enterprise administration functions (clause B.1.2.6); authorisation decisions and violations are logged.
Factory reset and data portability	Critical	Employee offboarding triggers revocation of shared vault access and loss of access to the password manager entirely; export uses an encrypted method.

B.2.6 UC-6: Hardware-Based Password Manager Risk Assessment

B.2.6.1 Threat Profile

Primary Threat Actors: Physical thieves, border security, forensic analysts, hardware hackers.

Attack Vectors:

- Physical theft or loss.
- Side-channel attacks (power, EM, timing).
- Firmware vulnerabilities.
- Supply chain tampering.
- Forensic extraction.
- Coercion/rubber hose cryptanalysis.

B.2.6.2 Impact Analysis**Table B.2.6.2-1**

Impact Category	Security Profile	Justification
Appropriate level of cybersecurity	High	Firmware in hardware-specific functions (clause B.1.2.9) including the secure element and USB stack may carry latent flaws across the device's lifetime; physical and side-channel exposure significant but bounded.
No known exploitable vulnerabilities	Normal	Firmware code subject to pre-deployment KEV testing; CIAA-impacting flaws on the assets in clauses B.1.1.1 to B.1.1.4 are out of scope at first use.
Secure by default configuration	Normal	Default configuration enforces master-password / PIN complexity and masked entry; vault data (clause B.1.1.1) decrypted only within the secure element.
Security updates	Critical	Firmware updates via update and maintenance functions (clause B.1.2.8) authenticated and rollback-resistant; monotonic version counter and authorised rollback apply (UC6 in scope of clause 5.5.3).
Authentication and access control	High	Hardware-specific functions (clause B.1.2.9) enforce on-device PIN or biometric authentication (clause B.1.2.3) with lockout after failed attempts before releasing key material (clause B.1.1.2); least-privilege and per-operation authorisation enforced.
Confidentiality protection	Critical	Physical access does not enable plaintext readout of vault data (clause B.1.1.1) or key material (clause B.1.1.2); unique salts, transport encryption to host, encrypted backups where applicable, perfect forward secrecy by default where remote communication exists.
Integrity protection	Normal	Physical tampering of hardware-specific functions (clause B.1.2.9) addressed by tamper detection; input validation of imported data applies.
Data minimisation	Normal	Constrained storage limits vault data (clause B.1.1.1) and configuration data (clause B.1.1.3); no network connectivity eliminates collection of identity and device data (clause B.1.1.4) and operational data (clause B.1.1.5).
Availability protection	Normal	Physical theft, loss or hardware failure is a single point of failure for vault data (clause B.1.1.1) and hardware-bound keys (clause B.1.1.2); recovery processes are brute-force resistant.
Non-interference	Normal	Product does not degrade host availability and does not interfere with other products unless configured by the user.
Attack surface minimisation	Normal	Primary vectors target hardware-specific functions (clause B.1.2.9) through the physical interface (USB, NFC, Bluetooth®), host communication protocol and physical attacks on the hardware.
Exploit mitigation	Normal	Autofill operations validate the target system identifier where applicable; transient data (clause B.1.1.6) cleared from RAM promptly.
Monitoring	Normal	Limited on-device logging of operational data (clause B.1.1.5); basic access logs maintained where storage permits.
Factory reset and data portability	Normal	User can factory reset to wipe vault data (clause B.1.1.1) and key material (clause B.1.1.2); export uses dedicated secure platform APIs or an encrypted method.

Annexes C to J:
Void

Annex K (normative): Generic cryptographic requirements and assessment

K.1 Cryptography

K.1.1 Requirement

The product's default configuration shall only use cryptographic mechanisms that meet at least one of the following criteria:

- 1) ACM-listed: the cryptographic mechanism is listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [6];
- 2) ACM-extended: the cryptographic mechanism is not listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [6] and meets at least one of the following conditions:
 - a) the cryptographic mechanism is listed in clause K.3.2 as an ACM-extended cryptographic mechanism for the specific product function(s);
 - b) where the cryptographic mechanism is not listed in clause K.3.2, the cryptographic mechanism meets all the following criteria:
 - i) the cryptographic mechanism, or where applicable the ACM-listed cryptographic mechanism on which it is based, is not deprecated per the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [6];
 - ii) the cryptographic mechanism has been specified, developed or maintained through a transparent process by a recognised European, international or sector-specific standards development organisation, or by an industry specification organisation accountable for the relevant specification, including CEN, CENELEC, ETSI, ISO, IEC, ISO/IEC JTC 1, IETF, IRTF, IEEE, ITU-T, NIST, W3C, FIDO Alliance, OIDF, SECG, AAIF, OASIS; or the cryptographic mechanism is listed as suitable in a publicly available cryptographic catalogue maintained by a recognised national or governmental cybersecurity authority, where the catalogue is maintained under a documented revision and retirement process, including those listed in clause K.3.2.6;
 - iii) the cryptographic mechanism is described in a valid, publicly available and uniquely referenceable specification;
 - iv) the cryptographic properties of the cryptographic mechanism are known;
 - v) no known weakness affects the cryptographic mechanism in a way that affects its cryptographic properties;
 - vi) the cryptographic mechanism is required for a specific set of product functions;
- 3) Interoperability-based: the cryptographic mechanism is listed in clause K.3.2 as an interoperability-based cryptographic mechanism for specific product function(s) and external specification(s) or external requirement(s).

NOTE 1: The reference to the product's default configuration is intended to define a clear and assessable baseline, corresponding to the configuration in which the product is placed on the market. The product can provide several configurations that fulfil the requirement.

NOTE 2: For products supplied as hardware platforms or components to be configured by an integrator, references in this annex to the product's default configuration refer to the configuration specified for the intended operational use of the product after integration, including the relevant integration assumptions and configuration constraints.

NOTE 3: The applicable ACM catalogue version is identified in the normative references of the present document. The lifecycle treatment of mechanisms affected by ACM deprecation dates, expiry dates, migration conditions or usage limitations is addressed in clause K.2.

NOTE 4: In this clause, an external specification or external requirement means a specification or requirement that is imposed on the product, and which requires the use of a specific cryptographic mechanism for the product to interoperate with an identified system, platform or operational context. An external requirement can be a regulatory requirement, operational constraint, technical interoperability constraint, or platform compatibility requirement.

NOTE 5: Inclusion of a cryptographic mechanism under the interoperability-based criterion does not classify that mechanism as state-of-the-art cryptography.

EXAMPLE: Examples of product functions include secure communication based on TLS 1.3; authenticated encryption of communicated data based on AES-GCM; storage confidentiality based on AES-XTS; firmware signature verification based on Ed25519; and key derivation based on HKDF.

K.1.2 Assessment of product cryptographic configuration

K.1.2.0 General

The assessment in clause K.1.2 verifies the cryptographic mechanisms used in the product's default configuration against clause K.1.1.

For ACM-extended cryptographic mechanisms, the assessment verifies that the cryptographic mechanism is either listed in clause K.3.2 or fulfils the criteria specified in clause K.1.1 item 2.b. For interoperability-based cryptographic mechanisms, the assessment verifies that the cryptographic mechanism is listed in clause K.3.2. The assessment also verifies that the product uses the cryptographic mechanism in accordance with the relevant characteristics, product functions, use cases where applicable, external specifications or external requirements, and conditions specified in the present document.

K.1.2.1 Assessment of ACM-listed cryptographic mechanisms

K.1.2.1.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause K.1.1 item 1) and used in the product's default configuration are listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [6].

K.1.2.1.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause K.1.1 item 1), including the related product function, relevant parameters where applicable, and the relevant ACM entry.

K.1.2.1.3 Assessment activities

The assessment shall include verification that:

- each cryptographic mechanism claimed under clause K.1.1 item 1) is identified by reference to a relevant ACM entry;
- the ACM entry corresponds to the cryptographic mechanism used in the product's default configuration, including relevant parameters where applicable;
- where the ACM entry includes lifecycle information, such as expiry date, deprecation date, migration condition or usage limitation, this information is reflected in the documentation.

K.1.2.1.4 Assessment evidence

The assessment evidence shall include, as applicable:

- description of the product's default configuration;

- list of cryptographic mechanisms claimed under clause K.1.1 item 1);
- references to the relevant ACM entries;
- relevant parameters, profiles, cipher suites or configuration constraints, where applicable;
- relevant lifecycle information from the ACM catalogue, where applicable.

K.1.2.1.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.1.1 item 1).
- The verdict FAIL shall be assigned otherwise.

K.1.2.2 Assessment of ACM-extended cryptographic mechanisms

K.1.2.2.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause K.1.1 item 2) and used in the product's default configuration are either listed as ACM-extended cryptographic mechanisms in clause K.3.2 or fulfil the criteria specified in clause K.1.1 item 2.b, and are used for the claimed product function(s).

K.1.2.2.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause K.1.1 item 2), including the related product function, use case where applicable, relevant parameters where applicable, and at least one of the following:
 - a) the relevant entry in clause K.3.2; or
 - b) evidence that the cryptographic mechanism fulfils all applicable criteria in clause K.1.1 item 2.b.

K.1.2.2.3 Assessment activities

The assessment shall include verification that:

- a) each cryptographic mechanism claimed under clause K.1.1 item 2) is either listed in clause K.3.2 as an ACM-extended cryptographic mechanism or supported by evidence demonstrating fulfilment of the applicable criteria in clause K.1.1 item 2.b;
- b) the cryptographic mechanism used by the product corresponds to the mechanism listed in clause K.3.2 or described in the evidence provided under clause K.1.1 item 2.b;
- c) the product function using the cryptographic mechanism, and the use case where applicable, correspond to the related product function and use case specified in clause K.3.2 or justified under clause K.1.1 item 2.b;
- d) the relevant characteristics, parameters, profiles, cipher suites or configuration constraints of the cryptographic mechanism correspond to those specified in clause K.3.2 or justified under clause K.1.1 item 2.b, where applicable;
- e) where clause K.3.2 or the justification under clause K.1.1 item 2.b defines conditions or limitations for the use of the cryptographic mechanism, these conditions or limitations are reflected in the product's default configuration;
- f) where technically feasible, the cryptographic mechanism, parameters and configuration identified in the documentation correspond to the assessed product configuration.

K.1.2.2.4 Assessment evidence

The assessment evidence shall include, as applicable:

- a) description of the product's default configuration;
- b) list of cryptographic mechanisms claimed under clause K.1.1 item 2);
- c) reference to the relevant entry in clause K.3.2, where the mechanism is listed in clause K.3.2;
- d) evidence that the cryptographic mechanism fulfils the criteria in clause K.1.1 item 2.b, where compliance with clause K.1.1 item 2 is claimed on the basis of those criteria;
- e) identification of the related product function using the cryptographic mechanism and the use case where applicable;
- f) relevant characteristics, parameters, profiles, cipher suites or configuration constraints, where applicable;
- g) evidence that the cryptographic mechanism is used in accordance with the conditions or limitations specified in clause K.3.2 or in the justification under clause K.1.1 item 2.b, where applicable.

K.1.2.2.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.1.1 item 2).
- The verdict FAIL shall be assigned otherwise.

K.1.2.3 Assessment of interoperability-based cryptographic mechanisms

K.1.2.3.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause K.1.1 item 3) and used in the product's default configuration are listed as interoperability-based cryptographic mechanisms in clause K.3.2 and are used in accordance with the characteristics, product functions, use cases where applicable, external specifications or external requirements, and conditions specified in clause K.3.2.

K.1.2.3.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause K.1.1 item 3), including the related product function, use case where applicable, relevant parameters where applicable, the external specification or external requirement requiring its use, and the relevant entry in clause K.3.2.

K.1.2.3.3 Assessment activities

The assessment shall include verification that:

- a) each cryptographic mechanism claimed under clause K.1.1 item 3) is listed in clause K.3.2 as an interoperability-based cryptographic mechanism;
- b) the cryptographic mechanism used by the product corresponds to the cryptographic mechanism listed in clause K.3.2;
- c) the product function using the cryptographic mechanism, and the use case where applicable, correspond to the related product function and use case specified in clause K.3.2;
- d) the external specification or external requirement requiring the use of the cryptographic mechanism corresponds to the external specification or external requirement specified in clause K.3.2;

- e) the relevant characteristics, parameters, profiles, cipher suites or configuration constraints of the cryptographic mechanism correspond to those specified in clause K.3.2, where applicable;
- f) the conditions or limitations specified in clause K.3.2 for the use of the cryptographic mechanism are reflected in the product's default configuration;
- g) where technically feasible, the cryptographic mechanism, parameters and configuration identified in the documentation correspond to the assessed product configuration.

K.1.2.3.4 Assessment evidence

The assessment evidence shall include, as applicable:

- a) description of the product's default configuration;
- b) list of cryptographic mechanisms claimed under clause K.1.1 item 3);
- c) reference to the relevant entry in clause K.3.2;
- d) identification of the related product function using the cryptographic mechanism and the use case where applicable;
- e) identification of the external specification or external requirement requiring use of the cryptographic mechanism;
- f) relevant characteristics, parameters, profiles, cipher suites or configuration constraints, where applicable;
- g) evidence that the cryptographic mechanism is used in accordance with the conditions or limitations specified in clause K.3.2.

K.1.2.3.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.1.1 item 3).
- The verdict FAIL shall be assigned otherwise.

NOTE 1: The assessment of the external specification or external requirement itself is outside the scope of this assessment case. The assessment verifies that the external specification or external requirement is identified in clause K.3.2 and that the cryptographic mechanism is used by the product for the related product function.

NOTE 2: Documentation review is a minimum assessment activity under the present annex. Functional and/or resistance testing activities can be added by vertical standards where relevant for the product category, product function or cryptographic mechanism.

K.2 Crypto agility

K.2.1 Requirement

Where the product's default configuration uses a cryptographic mechanism for which the ACM catalogue, or the present document, specifies a deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product, the product shall provide means for addressing the affected cryptographic mechanism by one or more of the following:

- a) updating the cryptographic mechanism;
- b) using another cryptographic mechanism that complies with clause K.1.1 and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation;
- c) disabling the use of the affected cryptographic mechanism; or

- d) limiting the use of the affected product functions accordingly.

EXAMPLE: Where a security mechanism uses a hybrid cryptographic construction, for example a hybrid key-encapsulation mechanism combining a classical and a post-quantum primitive, the lifecycle status of each constituent primitive is relevant to the lifecycle status of the construction. Hybridization can be used as part of a planned migration strategy where permitted by the ACM catalogue or by the present document. However, hybridization does not, by itself, extend the recommended usage lifetime of a constituent primitive that has been deprecated.

NOTE 1: Where a hybrid cryptographic construction includes multiple cryptographic primitives, the lifecycle status of each constituent primitive is relevant to the lifecycle status of the construction. Hybridization is not assumed to mitigate the deprecation of a constituent primitive unless the ACM catalogue or the present document classifies the hybrid construction as suitable for the corresponding product function.

NOTE 2: Crypto agility supports maintaining appropriate cryptographic protection within the intended lifetime of the product, in addition to the capability of updating cryptographic mechanisms on the product in accordance with secure update and secure communication mechanisms.

NOTE 3: Deprecation information from sources other than the ACM catalogue or the present document can be considered as input to vulnerability management or security risk assessment but does not by itself trigger the requirement in clause K.2.1.

NOTE 4: Where the product provides cryptographic capabilities for use by other products, components or layers, the mechanism required by clause K.2.1 can consist of update, configuration, disabling, deprecation or limitation capabilities usable by the integrating product, system operator or user, where applicable.

NOTE 5: The applicability condition of this requirement can express exceptions based on product characteristics, e.g. cryptographic implementation based on immutable hardware co-processor(s) or hardware-based root of trust, or long-lived silicon used in a long-lived non-updateable environment.

K.2.2 Assessment of crypto-agility

K.2.2.1 Assessment objective

The purpose of this assessment case is to verify whether, where the product's default configuration uses a cryptographic mechanism for which the ACM catalogue, or the present document, specifies a deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product, the product provides means to address the affected cryptographic mechanism in accordance with clause K.2.1.

K.2.2.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall identify:
 - a) the intended lifetime of the product;
 - b) the cryptographic mechanisms used in the product's default configuration;
 - c) the related product function(s) for each cryptographic mechanism;
 - d) the lifecycle information applicable to each cryptographic mechanism, where specified by the ACM catalogue or the present document, including any deprecation date, expiry date, migration condition or usage limitation.

K.2.2.3 Assessment activities

The assessment shall include verification that:

- a) for each cryptographic mechanism used in the product's default configuration, the lifecycle information specified by the ACM catalogue or the present document has been identified, where such information is specified;
- b) where the ACM catalogue or the present document specifies a deprecation date, expiry date, migration condition or usage limitation for a cryptographic mechanism, this information is reflected in the documentation;
- c) where a deprecation date, expiry date, migration condition or usage limitation falls within the intended lifetime of the product, the product provides an applicable mechanism for updating the cryptographic mechanism, using another cryptographic mechanism that complies with clause K.1.1 and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation, disabling the use of the affected cryptographic mechanism, or limiting the use of the affected product functions accordingly;
- d) where another cryptographic mechanism is used, that cryptographic mechanism complies with clause K.1.1 and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation.

K.2.2.4 Assessment evidence

The assessment evidence shall include, as applicable:

- a) documentation of the intended lifetime of the product;
- b) list of cryptographic mechanisms used in the product's default configuration;
- c) identification of the related product function(s) for each cryptographic mechanism;
- d) references to the ACM catalogue entry or to the provision of the present document used to determine lifecycle information, where applicable;
- e) identification of any deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product;
- f) description of the means provided by the product, such as update of the cryptographic mechanism, use of another cryptographic mechanism that complies with clause K.1.1 and is not subject to the relevant lifecycle constraint, disabling the use of the affected cryptographic mechanism, or limitation of the use of the affected product functions.

K.2.2.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.2.1.
- The verdict FAIL shall be assigned otherwise.

K.3 ACM-extended cryptographic mechanisms

K.3.1 Requirement

Where the product's default configuration uses ACM-extended cryptographic mechanisms, these mechanisms shall comply with the ACM-extended criterion in clause K.1.1 item 2.

K.3.2 List of ACM-extended cryptographic mechanisms

K.3.2.1 Symmetric atomic primitives

K.3.2.1.1 Stream ciphers

Table K.3.2.1.1-1: State of the art stream ciphers

Primitive	Notes	Reference
ChaCha20	A modern stream cipher used in TLS 1.3. Preferred for devices without AES hardware acceleration.	IETF RFC 8439 [i.11]
XChaCha20	A variant of ChaCha20 with an extended 192-bit nonce to mitigate nonce collisions.	draft-arciszewski-xchacha-03 [i.12]
Salsa20	Salsa20 is the basis from which the ChaCha20 variant emerged.	Salsa20 specification [i.13] Salsa20/12 . [i.42]
XSalsa20	A variant of Salsa20 with an extended 192-bit nonce to mitigate nonce collisions.	Extending the Salsa20 nonce . [i.14]

K.3.2.1.2 Hash Functions

Table K.3.2.1.2-1: State of the art hash functions

Primitive	Notes	Reference
BLAKE2b	A modern cryptographic hash function which targets 64-bit platforms.	IETF RFC 7693 [i.15] NIST IR 7896 [i.16]
BLAKE2s	A modern cryptographic hash function which targets 8- to 32-bit platforms.	IETF RFC 7693 [i.15] NIST IR 7896 [i.16]
BLAKE3	A modern cryptographic hash function that is an evolution from BLAKE2, but much faster.	draft-aumasson-blake3-00 [i.17] C2SP/BLAKE3
SHAKE128	Extendable-output function (XOF) in the SHA-3 family.	FIPS 202 [i.18]
SHAKE256	Extendable-output function (XOF) in the SHA-3 family.	FIPS 202 [i.18]

K.3.2.2 Symmetric constructions

K.3.2.2.1 Integrity modes: message authentication codes

Table K.3.2.2.1-1: State of the art message authentication codes

Scheme	Notes	Reference
Poly1305		IETF RFC 8439 [i.11]
BLAKE2b	BLAKE2b supports a keyed mode which makes it a suitable MAC.	IETF RFC 7693 [i.15] NIST IR 7896 [i.16]
BLAKE2s	BLAKE2s supports a keyed mode which makes it a suitable MAC.	IETF RFC 7693 [i.15] NIST IR 7896 [i.16]
BLAKE3	BLAKE3 supports a keyed mode which makes it a suitable MAC.	draft-aumasson-blake3-00 [i.17] C2SP/BLAKE3

K.3.2.2.2 Authenticated encryption

Table K.3.2.2.2-1: State of the art authentication encryption schemes

Scheme	Notes	Reference
AES-GCM-SIV	Mode of operation with nonce misuse resistance.	IETF RFC 8452 [i.19] BSI TR-0210 2-1 [i.20]
ChaCha20-Poly1305	Standard AEAD for TLS 1.3.	IETF RFC 8439 [i.11]
XChaCha20-Poly1305	Variant of ChaCha20-Poly1305 with an extended 192-bit nonce to mitigate nonce collisions.	draft-arciszewski-xchacha-03 [i.12]
Salsa20-Poly1305	Common AEAD in various cryptographic libraries.	Cryptography in NaCl [i.43]
XSalsa20-Poly1305	Variant of Salsa20-Poly1305 with an extended 192-bit nonce to mitigate nonce collisions.	Cryptography in NaCl [i.43]

K.3.2.2.3 Key derivation functions

Table K.3.2.2.3-1: State of the art key derivation functions

Scheme	Notes	Reference
BLAKE2b	BLAKE2b supports a keyed mode which makes it a suitable key derivation function.	IETF RFC 7693 [i.15] NIST IR 7896 [i.16]
BLAKE2s	BLAKE2s supports a keyed mode which makes it a suitable key derivation function.	IETF RFC 7693 [i.15] NIST IR 7896 [i.16]
BLAKE3	BLAKE3 has support for a key derivation mode.	draft-aumasson-blake3-00 [i.17] C2SP/BLAKE3

K.3.2.2.4 Password protection/password hashing mechanisms

Table K.3.2.2.4-1: State of the art Password protection/password hashing mechanisms

Primitive	Parameters	Notes	Reference
Argon2id	Refer to 4. <i>Parameter Choice</i> in IETF RFC 9106 and the ACN's guidance.	A resource intensive hash function to protect passwords. Can also be used as a KDF to derive secret keys from passwords. Generated entropy depends on the entropy of the password.	IETF RFC 9106 [i.21] BSI-TR-0210 2-1 [i.20] ACN
Argon2d	Refer to 4. <i>Parameter Choice</i> in IETF RFC 9106.	Stronger resistance to GPU/ASIC cracking than Argon2id.	IETF RFC 9106 [i.21]
Argon2i	Refer to 4. <i>Parameter Choice</i> in IETF RFC 9106.	Stronger resistance to side channels than Argon2d but weaker against time-memory tradeoff attacks.	IETF RFC 9106 [i.21]
script	Refer to 2. <i>script Parameters</i> in IETF RFC 7914 and the ACN's guidance.	A resource intensive hash function to protect passwords. Can also be used as a KDF to derive secret keys from passwords. Generated entropy depends on the entropy of the password.	IETF RFC 7914 [i.22]

K.3.2.3 Asymmetric atomic primitives

K.3.2.3.1 Discrete logarithm in elliptic curves

Table K.3.2.3.1-1: Additional elliptic curve parameters agreed as state of the art

Curve	Notes	Reference
Curve25519		IETF RFC 7748 [i.23]
Curve448		IETF RFC 7748 [i.23]
Edwards25519		IETF RFC 7748 [i.23]
Edwards448		IETF RFC 7748 [i.23]
Ristretto255	Prime-order group implemented using edwards2559.	IETF RFC 9496 [i.24]
Decaf448	Prime-order group implemented using edwards448.	IETF RFC 9496 [i.24]

K.3.2.4 Asymmetric constructions

K.3.2.4.1 Asymmetric encryption scheme

Table K.3.2.4.1-1: State of the art asymmetric encryption schemes

Scheme	Notes	Reference
ECIES		SEC-1 Version 2.0 BSI TR-0210 2-1 [i.20]
HPKE	Hybrid Public Key Encryption scheme.	IETF RFC 9180 [i.25]

K.3.2.4.2 Digital signature scheme

Table K.3.2.4.2-1: State of the art digital signature schemes

Scheme	Notes	Reference
Ed25519	Uses the EdDSA framework.	IETF RFC 8032 [i.26] FIPS 186-5 [i.27]
Ed448	Uses the EdDSA framework.	IETF RFC 8032 [i.26] FIPS 186-5 [i.27]

K.3.2.4.3 Key establishment and key encapsulation

Table K.3.2.4.3-1: State of the art key establishment and key encapsulation schemes

Scheme	Notes	Reference
X25519	ECDH with Curve25519. Default in TLS 1.3.	IETF RFC 7748 [i.23]
X448	ECDH with Curve448.	IETF RFC 7748 [i.23]
X-Wing	A general-purpose post-quantum/traditional hybrid key encapsulation mechanism (PQ/T KEM) built on X25519 and ML-KEM-768	draft-conolly-cfrg-xwing-kem-10 [i.28]
X25519MLKEM768	Post-quantum hybrid key agreement for TLS 1.3.	draft-ietf-tls-ecdhe-mlkem-05 [i.29]

K.3.2.5 Protocols

K.3.2.5.1 Password-authenticated key agreement

Table K.3.2.5.1-1: State of the art password-authenticated key agreement

Scheme	Notes	Reference
SRP		IETF RFC 2945 [i.30]
CPace		draft-irtf-cfrg-pace-21 [i.31]
OPAQUE		IETF RFC 9807 [i.32]
SPAKE2+		IETF RFC 9383 [i.33]

K.3.2.5.2 Transport and authenticated channels

Table K.3.2.5.2-1: State of the art transport and authenticated channel protocols

Scheme	Notes	Reference
Noise Protocol Framework		Noise protocol framework [i.34]

K.3.2.6 List of cryptographic catalogues

Table K.3.2.6-1: Accepted cryptographic catalogues

Cryptographic catalogue	Version
BSI TR-02102-1 [i.35] "Cryptographic Mechanisms: Recommendations and Key Lengths"	2026-01
BSI TR-02102-2 [i.36] "Cryptographic Mechanisms: Recommendations and Key Lengths: Use of Transport Layer Security (TLS)"	2026-01
BSI TR-02102-4 [i.37] "Cryptographic Mechanisms: Recommendations and Key Lengths - Use of Secure Shell (SSH)"	2026-1
ANSSI-PG-083 [i.38] "Règles et recommandations concernant le choix et le dimensionnement des mécanismes cryptographiques"	3.00 (2026-03-20)
ACN "Linee Guida Funzioni Crittografiche Cifatura Autenticata"[i.39]	1.0 (2025-02-26)
ACN "Linee Guida Funzioni Crittografiche Funzioni di Hash" [i.40]	1.0 (2023-12-07)
ACN "Linee Guida Funzioni Crittografiche Conservazione delle Password" [i.41]	1.0 (2023-12-07)

K.3.3 Assessment

Compliance with the ACM-extended criterion in clause K.1.1 item 2 is assessed in clause K.1.2.2.

Annexes L to Q:
Void

Annex R (normative): Remote Data Processing Solutions

R.1 Scope & Applicability

This annex specifies additional technical requirements and assessment provisions for products with digital elements that rely on Remote Data Processing Solutions ("RDPS") for the provision or support of one or more product functions.

The requirements applicable to the product functions themselves remain specified in the core part of the concerned standard and continue to apply to the product as a whole, including where a product function is performed locally, supported by an RDPS, or performed in part through an RDPS.

This annex specifies supplementary requirements and assessment provisions for the product-facing RDPS boundary, i.e. for the additional attack surface, interactions, and dependency conditions introduced where a product function is performed or supported across the local product side and the RDPS side.

Where the product does not rely on remote data processing solutions for the provision or support of any product function, this annex is not applicable.

This annex does not extend to the full remote service environment or underlying third-party infrastructure, except to the extent necessary to define assumptions, dependencies, and assessment conditions relevant to the product-facing RDPS boundary and the secure operation of the RDPS-dependent product function.

R.2 RDPS as a product-boundary extension

When a product relies on RDPS for the provision or support of one or more product functions, the use of RDPS is considered, for the purposes of the present annex, to introduce an additional product-facing boundary and interface between the local product side and the RDPS side.

The present annex does not restate or replace the requirements applicable to the product function as such. It specifies only the supplementary requirements needed to address the increased attack surface introduced by the RDPS boundary.

The present annex therefore addresses the security implications introduced by that additional boundary and interface, including:

- a) the exchanged interactions across the RDPS boundary;
- b) the relevant product-side and RDPS-side endpoints; and
- c) the dependency conditions arising where the secure operation of the product function relies on interactions across that boundary.

The scope of the present annex is limited to the RDPS interface between the local product side and the RDPS side. For the purposes of the present annex:

- local product side means the product elements within the product boundary that participate in the interaction with the RDPS;
- RDPS means the remote data processing solution performing or supporting operations relevant to the RDPS-dependent product function;
- RDPS interface means the communication boundary between the product-side endpoint and the RDPS-side endpoint.

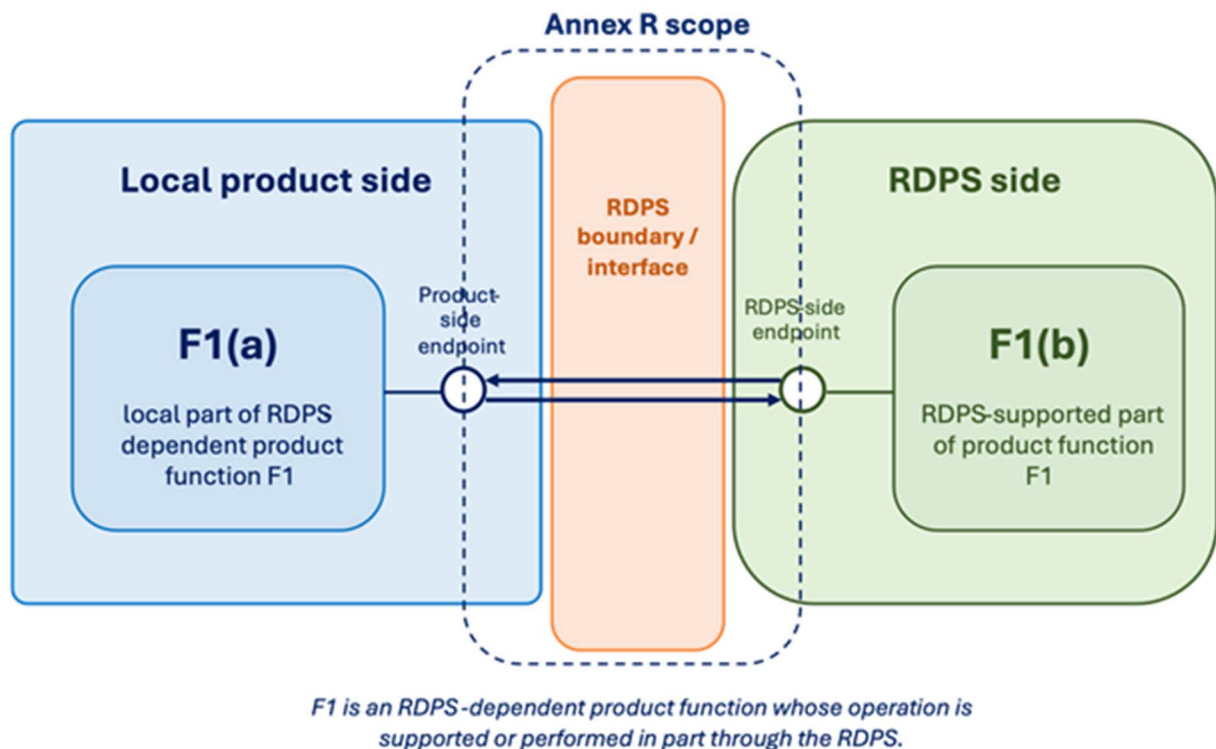


Figure R.2-1: RDPS model for Annex R - scope focused on the product ↔ RDPS boundary

R.3 Threat Model

R.3.0 Introduction

This clause does not restate or replace threats for local product components that are already defined in the main clauses of the standard. Instead, it focuses on:

- threats introduced by the local product ↔ RDPS interface, and
- threats introduced by the RDPS as a remote service capability.

The threat model:

- identifies RDPS assets; and
- defines a set of threats applicable to RDPS.

R.3.1 Assets

The threat model considers the following assets:

DA-RDPS-001 - RDPS interaction content: The information exchanged across the RDPS boundary, including, as applicable, requests, commands, responses, decisions, configuration data, secrets, update-related data, and personal data where such data is exchanged.

For the purposes of DA-RDPS-001, Table R.3.1-1 identifies categories of RDPS interaction content and the security properties that are relevant to them.

For the purposes of DA-RDPS-001, Table R.3.1-1 identifies potential categories of RDPS interaction content and indicates the security properties to be considered for each category when determining the applicable Annex R requirement families.

Table R.3.1-1: Security properties for DA-RDPS-001

Content type	Data authenticity	Integrity	Confidentiality
Commands / requests & Responses / decisions	X	X	
Configuration data	X	X	
Secrets (e.g. keys)	X	X	X
Code or update data	X	X	
Confidential code or update data	X	X	X
Personal data		X	X

NOTE: In Table R.3.1-1, "data authenticity" refers to the authenticity or trusted origin of the exchanged interaction content. It does not refer to authentication of the RDPS boundary endpoint.

DA-RDPS-002 - RDPS-dependent product function: product function for which one or more operations depend on an RDPS, including the associated security-relevant state, decisions, outputs, or configuration.

For the purposes of DA-RDPS-002, Table R.3.1-2 identifies the security property relevant to the RDPS-dependent product function.

Table R.3.1-2: Security property for DA-RDPS-002

Content type	Availability
RDPS-dependent product function	X

R.3.2 Threat catalogue

The following threats constitute the baseline threat set considered for the RDPS boundary within the scope of Annex R, covering the RDPS interaction content exchanged across the boundary and the availability of the RDPS-dependent product function.

T-RDPS-01 Loss of data authenticity of interactions across the RDPS boundary

An attacker causes an endpoint to accept interaction content across the RDPS boundary whose claimed source or origin is not genuine.

Threat type: Spoofing / impersonation

Security impact: The receiving endpoint may rely on interaction content that does not originate from the intended source, which can affect the behaviour, state, configuration, or security of the RDPS-dependent product function.

T-RDPS-02 Loss of integrity of interactions across the RDPS boundary

An interaction exchanged across the RDPS boundary is modified, substituted, injected, corrupted, or replayed before it is processed by the receiving endpoint.

Threat type: Tampering

Security impact: The receiving endpoint may act upon interaction content whose contents no longer correspond to what was sent or intended by the legitimate source, which can affect the behaviour, state, configuration, or security of the RDPS-dependent product function.

T-RDPS-03 Unauthorised disclosure of interactions across the RDPS boundary

Data exchanged across the RDPS boundary is disclosed to an unauthorised party.

Threat type: Information disclosure

Security impact: An attacker may obtain interaction content whose disclosure can affect the security or secure operation of the RDPS-dependent product function.

T-RDPS-04 Unavailability, unacceptable delay, or intolerable degradation of interactions across the RDPS boundary

The local product side or the RDPS side is unable to send, receive, or process interactions across the RDPS boundary, or receives them only after an unacceptable delay, or experiences degradation of communication performance across the RDPS boundary to an extent that is not tolerable for the successful operation of the RDPS-dependent product function.

Threat type: Denial of service

Security impact: The RDPS-dependent product function may fail to operate as intended, may operate with incomplete, outdated, or degraded information, may remain blocked, or may continue without the required interaction being available when needed.

R.3.3 Assets ↔ Threats mapping

Table R.3.3-1: Threats ↔ Assets mapping

Threat ID	Threat title	Related asset(s)
T-RDPS-01	Loss of data authenticity of interactions across the RDPS boundary	DA-RDPS-001
T-RDPS-02	Loss of integrity of interactions across the RDPS boundary	DA-RDPS-001
T-RDPS-03	Unauthorised disclosure of interactions across the RDPS boundary	DA-RDPS-001
T-RDPS-04	Unavailability, unacceptable delay, or intolerable degradation of interactions across the RDPS boundary	DA-RDPS-002

R.4 Security Requirements

R.4.1 General and guidance for requirement-structure selection

The requirements in the present clause are organised by requirement family. The requirement families address the primary security properties identified for the assets in clause R.3.1, namely data authenticity, integrity, confidentiality, and availability.

R.4.2 Applicability of Annex R requirements

The requirements in the present clause address the protection of the security properties identified for the assets in clause R.3.1.

Where a security property is identified as relevant for a given asset in the asset tables of clause R.3.1, the corresponding requirement family or families in the present clause shall be considered for applicability to that asset.

For DA-RDPS-001, the primary requirement families considered for applicability are:

- a) data authenticity of interactions;
- b) integrity of interactions; and
- c) confidentiality of exchanged data.

For DA-RDPS-002, the primary requirement family considered for applicability is availability.

Table R.4.2-1 maps each Annex R requirement family (data authenticity, integrity, confidentiality and availability across the local product side and the RDPS side) to the use cases identified in clause 4.6 and analysed in clause B.2. The cell value indicates the security profile (Normal, High or Critical) at which the corresponding REQ-RDPS-{L|R}-* requirement family applies. In contrast with the instructions from clause 5.1, security profiles for RDPS are not additive: assignment of High does not need the assessment of the Normal requirements, and assignment of Critical

implies neither Normal nor High. Use cases for which RDPS is not part of the baseline architecture are marked N/A; the Annex R requirements do not apply.

Table R.4.2-1: Applicability of Annex R requirements per use case

Annex R clause	Side	Security property	Requirement family (N / H / C)	UC1 B.2.1 Local	UC2 B.2.2 Remote	UC3 B.2.3 Hybrid	UC4 B.2.4 Browser ext.	UC5 B.2.5 Enterprise	UC6 B.2.6 Hardware
R.4.3.1	Local product	Data authenticity of interactions received from RDPS	REQ-RDPS-L-AUTH-{N H C}	N/A	Critical	High	High	Critical	N/A
R.4.3.2	Local product	Integrity of interactions received from RDPS	REQ-RDPS-L-INTEG-{N H C}	N/A	Critical	Critical	High	Critical	N/A
R.4.3.3	Local product	Confidentiality of data exchanged with RDPS	REQ-RDPS-L-CONF-{N H C}	N/A	Critical	Critical	Critical	Critical	N/A
R.4.3.4	Local product	Availability of the RDPS-to-product channel	REQ-RDPS-L-AVAIL-{N H C}	N/A	High	Normal	Normal	Critical	N/A
R.4.4.1	RDPS	Data authenticity of interactions received from local product	REQ-RDPS-R-AUTH-{N H C}	N/A	Critical	High	High	Critical	N/A
R.4.4.2	RDPS	Integrity of interactions received from local product	REQ-RDPS-R-INTEG-{N H C}	N/A	Critical	Critical	High	Critical	N/A
R.4.4.3	RDPS	Confidentiality of data exchanged with local product	REQ-RDPS-R-CONF-{N H C}	N/A	Critical	Critical	Critical	Critical	N/A
R.4.4.4	RDPS	Availability of the product-to-RDPS channel	REQ-RDPS-R-AVAIL-{N H C}	N/A	High	Normal	Normal	Critical	N/A

NOTE 1: UC1 (Local password manager) and UC6 (Hardware-based password manager) do not include a Remote Data Processing Solution in their baseline architecture; Annex R requirements do not apply. Where a UC1 or UC6 product is delivered with optional cloud sync or companion-application backends, the applicable column for the comparable use case (UC3 or UC2) is to be applied to the optional RDPS scope.

NOTE 2: The Confidentiality family (REQ-RDPS-{L|R}-CONF-*) is at Critical across all RDPS-using use cases because vault data exchanged with the RDPS boundary contains primary assets (clause B.1.1.1 vault data, clause B.1.1.2 key material).

NOTE 3: The Availability family (REQ-RDPS-{L|R}-AVAIL-*) is High for UC2 (no local fallback for vault management functions clause B.1.2.1), Critical for UC5 (enterprise SLA on vault management and enterprise administration functions clause B.1.2.6) and Normal for UC3/UC4 where local-side fallbacks for vault management and autofill (clauses B.1.2.1 and B.1.2.2) preserve essential function during RDPS outage.

NOTE 4: The Data Authenticity and Integrity families are routed to Critical for UC2 (server-pushed update / server-mediated synchronisation with no local cross-check) and UC5 (organisation-wide blast radius). UC3 (Hybrid) carries Critical Integrity because of anti-replay needs in synchronisation functions clause B.1.2.4; UC4 (Browser extension) carries High because the browser sandbox provides partial mitigation.

R.4.3 Local product side requirements

R.4.3.1 Data authenticity of interactions received from the RDPS side

REQ-RDPS-L-AUTH-NORM-001

The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, that the interaction originates from the intended RDPS-side endpoint.

Rationale: This requirement protects against acceptance of interaction content whose claimed source or origin is not genuine.

REQ-RDPS-L-AUTH-HIGH-002

The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, the data authenticity of that interaction using cryptographic endpoint authentication, an authenticated communication channel, or an equivalent cryptographic mechanism that provides assurance of the origin of the interaction.

Rationale: This requirement strengthens protection against spoofed or falsely originated interaction content by requiring cryptographic assurance of origin.

REQ-RDPS-L-AUTH-CRIT-003

The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, that:

- a) the cryptographic authenticity of the interaction is bound to the intended RDPS-side endpoint; and
- b) replayed or stale interactions are detected and rejected where replay or reuse could affect the secure operation of the RDPS-dependent product function.

Rationale: This requirement provides stronger protection by requiring source-bound authenticity and replay protection.

R.4.3.2 Integrity of interactions received from the RDPS side

REQ-RDPS-L-INTEG-NORM-001

The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, that the interaction has not been modified, substituted, corrupted, or injected.

Rationale: This requirement protects against loss of integrity of received interaction content.

REQ-RDPS-L-INTEG-HIGH-002

The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, the integrity of that interaction using a cryptographic integrity-protection mechanism.

Rationale: This requirement strengthens protection against unauthorised modification or substitution of received interactions.

REQ-RDPS-L-INTEG-CRIT-002

The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, that the interaction is protected by a cryptographic integrity-protection mechanism bound to the authenticated source of the interaction.

Rationale: This requirement provides stronger protection by requiring cryptographic integrity protection bound to the authenticated source.

R.4.3.3 Confidentiality of data exchanged with the RDPS side

REQ-RDPS-L-CONF-NORM-001

Where disclosure of data exchanged with the RDPS side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the local product side shall protect the confidentiality of that data during exchange with the RDPS side.

Rationale: Confidentiality is not required for every exchange. However, where disclosure of data exchanged with the RDPS side could affect the security or secure operation of the RDPS-dependent product function, confidentiality protection is required.

REQ-RDPS-L-CONF-HIGH-002

Where disclosure of data exchanged with the RDPS side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the local product side shall protect the confidentiality of that data during exchange with the RDPS side using cryptographic confidentiality protection.

Rationale: This requirement strengthens confidentiality protection by requiring cryptographic protection of exchanged data where disclosure would create unacceptable cybersecurity risk.

REQ-RDPS-L-CONF-CRIT-003

Where disclosure of data exchanged with the RDPS side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the local product side shall use cryptographic confidentiality protection that is established with the intended RDPS-side endpoint and that prevents disclosure of the exchanged data to endpoints other than that intended endpoint.

Rationale: This requirement provides stronger protection by ensuring that confidential exchanged data is disclosed only to the intended peer endpoint.

R.4.3.4 Availability

REQ-RDPS-L-AVAIL-NORM-001

Where the availability or timeliness of interactions received from the RDPS side is necessary for the secure operation of the RDPS-dependent product function, the local product side shall:

- a) detect unavailability of the RDPS side, unacceptable delay of expected interactions, or intolerable degradation of the interaction;
- b) use timeout or equivalent timeliness controls for expected RDPS-side interactions; and
- c) apply a defined behaviour for the RDPS-dependent product function.

Rationale: This requirement ensures that loss, delay, or degradation of RDPS-side interactions is detected and handled in a defined manner before it adversely affects the secure operation of the RDPS-dependent product function.

REQ-RDPS-L-AVAIL-HIGH-002

Where the availability or timeliness of interactions received from the RDPS side is necessary for the secure operation of the RDPS-dependent product function, the local product side shall:

- a) detect unavailability of the RDPS side, unacceptable delay of expected interactions, or intolerable degradation of the interaction;
- b) use timeout or equivalent timeliness controls for expected RDPS-side interactions;
- c) apply a defined degraded behaviour or secure state when the required RDPS-side interactions are unavailable, delayed beyond the acceptable time, or degraded beyond acceptable limits; and
- d) support recovery of the RDPS-dependent product function using locally maintained state, configuration, or other recovery information where such information is necessary to restore secure operation.

Rationale: This requirement strengthens protection by requiring controlled degraded operation or transition to a secure state, together with support for restoration of secure operation.

REQ-RDPS-L-AVAIL-CRIT-003

Where the availability or timeliness of interactions received from the RDPS side is necessary for the secure operation of the RDPS-dependent product function, the local product side shall:

- a) detect unavailability of the RDPS side, unacceptable delay of expected interactions, or intolerable degradation of the interaction;
- b) use timeout or equivalent timeliness controls for expected RDPS-side interactions;
- c) apply a defined degraded behaviour or secure state when the required RDPS-side interactions are unavailable, delayed beyond the acceptable time, or degraded beyond acceptable limits;
- d) support recovery of the RDPS-dependent product function using locally maintained state, configuration, or other recovery information where such information is necessary to restore secure operation;
- e) support continuity of operation through failover, redundancy, or an equivalent resilience mechanism where such a mechanism is necessary.

Rationale: This requirement provides stronger protection by requiring resilience measures.

R.4.4 RDPS side requirements

R.4.4.1 Data authenticity of interactions received from the local product side

REQ-RDPS-R-AUTH-NORM-001

The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, that the interaction originates from the intended local product-side endpoint.

Rationale: This requirement protects against acceptance of interaction content whose claimed source or origin is not genuine.

REQ-RDPS-R-AUTH-HIGH-002

The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, the data authenticity of that interaction using cryptographic endpoint authentication, an authenticated communication channel, or an equivalent cryptographic mechanism that provides assurance of the origin of the interaction.

Rationale: This requirement strengthens protection against spoofed or falsely originated interaction content by requiring cryptographic assurance of origin.

REQ-RDPS-R-AUTH-CRIT-003

The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, that:

- a) the cryptographic authenticity of the interaction is bound to the intended local product-side endpoint; and
- b) replayed or stale interactions are detected and rejected where replay or reuse could affect the secure operation of the RDPS-dependent product function.

Rationale: This requirement provides stronger protection by requiring source-bound authenticity and replay protection.

R.4.4.2 Integrity of interactions received from the local product side

REQ-RDPS-R-INTEG-NORM-001

The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, that the interaction has not been modified, substituted, corrupted, or injected.

Rationale: This requirement protects against loss of integrity of received interaction content.

REQ-RDPS-R-INTEG-HIGH-002

The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, the integrity of that interaction using a cryptographic integrity-protection mechanism.

Rationale: This requirement strengthens protection against unauthorised modification or substitution of received interactions.

REQ-RDPS-R-INTEG-CRIT-003

The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, that the interaction is protected by a cryptographic integrity-protection mechanism bound to the authenticated source of the interaction.

Rationale: This requirement provides stronger protection by requiring cryptographic integrity protection bound to the authenticated source.

R.4.4.3 Confidentiality of data exchanged with the local product side

REQ-RDPS-R-CONF-NORM-001

Where disclosure of data exchanged with the local product side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the RDPS side shall protect the confidentiality of that data during exchange with the local product side.

Rationale: This requirement ensures confidentiality where disclosure of exchanged data could affect the security or secure operation of the RDPS-dependent product function.

REQ-RDPS-R-CONF-HIGH-002

Where disclosure of data exchanged with the local product side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the RDPS side shall protect the confidentiality of that data during exchange with the local product side using cryptographic confidentiality protection.

Rationale: This requirement strengthens confidentiality protection by requiring cryptographic protection during exchange.

REQ-RDPS-R-CONF-CRIT-003

Where disclosure of data exchanged with the local product side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the RDPS side shall use cryptographic confidentiality protection that is established with the intended local product-side endpoint and that prevents disclosure of the exchanged data to endpoints other than that intended endpoint.

Rationale: This requirement provides stronger protection by ensuring that confidential exchanged data is disclosed only to the intended peer endpoint.

R.4.4.4 Availability

REQ-RDPS-R-AVAIL-NORM-001

Where the availability or timeliness of interactions received from the local product side is necessary for the secure operation of the RDPS-dependent product function, the RDPS side shall:

- a) detect unavailability of the local product side, unacceptable delay of expected interactions, or intolerable degradation of the interaction;
- b) use timeout or equivalent timeliness controls for expected local product-side interactions; and
- c) apply a defined behaviour for the RDPS-dependent product function.

Rationale: This requirement ensures that loss, delay, or degradation of local product-side interactions is detected and handled in a defined manner before it adversely affects the secure operation of the RDPS-dependent product function.

REQ-RDPS-R-AVAIL-HIGH-002

Where the availability or timeliness of interactions received from the local product side is necessary for the secure operation of the RDPS-dependent product function, the RDPS side shall:

- a) detect unavailability of the local product side, unacceptable delay of expected interactions, or intolerable degradation of the interaction;
- b) use timeout or equivalent timeliness controls for expected local product-side interactions;
- c) apply a defined degraded behaviour or secure state when the required local product-side interactions are unavailable, delayed beyond the acceptable time, or degraded beyond acceptable limits; and
- d) support recovery of the RDPS-dependent product function using maintained state, configuration, or other recovery information where such information is necessary to restore secure operation.

Rationale: This requirement strengthens protection by requiring controlled degraded operation or transition to a secure state, together with support for restoration of secure operation.

REQ-RDPS-R-AVAIL-CRIT-003

Where the availability or timeliness of interactions received from the local product side is necessary for the secure operation of the RDPS-dependent product function, the RDPS side shall:

- a) detect unavailability of the local product side, unacceptable delay of expected interactions, or intolerable degradation of the interaction;
- b) use timeout or equivalent timeliness controls for expected local product-side interactions;
- c) apply a defined degraded behaviour or secure state when the required local product-side interactions are unavailable, delayed beyond the acceptable time, or degraded beyond acceptable limits;
- d) support recovery of the RDPS-dependent product function using maintained state, configuration, or other recovery information where such information is necessary to restore secure operation;
- e) support continuity of operation through failover, redundancy, or an equivalent resilience mechanism where such a mechanism is necessary; and

Rationale: This requirement provides stronger protection by requiring resilience measures.

R.4.5 Threats ↔ Requirements mapping

Table R.4.5-1: Threats ↔ Requirements mapping

Threat ID	Requirement(s) - Local product side	Requirement(s) - RDPS side
T-RDPS-01	REQ-RDPS-L-AUTH-NORM-001 REQ-RDPS-L-AUTH-HIGH-002 REQ-RDPS-L-AUTH-CRIT-003	REQ-RDPS-R-AUTH-NORM-001 REQ-RDPS-R-AUTH-HIGH-002 REQ-RDPS-R-AUTH-CRIT-003
T-RDPS-02	REQ-RDPS-L-INTEG-NORM-001 REQ-RDPS-L-INTEG-HIGH-002 REQ-RDPS-L-INTEG-CRIT-002	REQ-RDPS-R-INTEG-NORM-001 REQ-RDPS-R-INTEG-HIGH-002 REQ-RDPS-R-INTEG-CRIT-003
T-RDPS-03	REQ-RDPS-L-CONF-NORM-001 REQ-RDPS-L-CONF-HIGH-002 REQ-RDPS-L-CONF-CRIT-003	REQ-RDPS-R-CONF-NORM-001 REQ-RDPS-R-CONF-HIGH-002 REQ-RDPS-R-CONF-CRIT-003
T-RDPS-04	REQ-RDPS-L-AVAIL-NORM-001 REQ-RDPS-L-AVAIL-HIGH-002 REQ-RDPS-L-AVAIL-CRIT-003	REQ-RDPS-R-AVAIL-NORM-001 REQ-RDPS-R-AVAIL-HIGH-002 REQ-RDPS-R-AVAIL-CRIT-003

R.5 Conformity assessment

R.5.1 Introduction

The assessment cases in the present clause are aligned with the requirements in clause R.4. Each assessment case follows a common structure: assessment reference, assessment objective, assessment preparation, assessment activities, assessment verdict, and assessment evidence.

R.5.1 Local product side requirements

R.5.1.1 Assessment case for REQ-RDPS-L-AUTH-NORM-001

1. Assessment Reference

Requirement: REQ-RDPS-L-AUTH-NORM-001

2. Assessment objective

The objective of the assessment is to verify that the local product side verifies, before acting upon a relevant received interaction, that the interaction originates from the intended RDPS-side endpoint.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the interactions received from the RDPS side that can influence the behaviour, state, configuration, or security of that function;
- the intended RDPS-side endpoint for those interactions; and
- the mechanism used by the local product side to determine the origin of the received interaction.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the mechanism used by the local product side to determine the origin of the relevant interaction;
- verify that the origin of the interaction is checked before the interaction is acted upon;
- verify that interactions from the intended RDPS-side endpoint are accepted; and

- verify that interactions not originating from the intended RDPS-side endpoint are rejected or not acted upon.

5. Assessment verdict

Pass:

- the local product side verifies the origin of the relevant interaction before acting upon it; and
- interactions from endpoints other than the intended RDPS-side endpoint are rejected or not acted upon.

Fail:

- the local product side acts upon a relevant interaction without verifying its origin; or
- the local product side accepts and acts upon a relevant interaction not originating from the intended RDPS-side endpoint.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design or configuration evidence describing how origin of the interaction is determined;
- evidence showing acceptance of interactions from the intended RDPS-side endpoint; and
- evidence showing rejection or non-processing of interactions from other endpoints.

R.5.1.2 Assessment case for REQ-RDPS-L-AUTH-HIGH-002

1. Assessment Reference

Requirement: REQ-RDPS-L-AUTH-HIGH-002

2. Assessment objective

The objective of the assessment is to verify that the local product side verifies the data authenticity of relevant received interactions using cryptographic endpoint authentication, an authenticated communication channel, or an equivalent cryptographic mechanism providing assurance of origin.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the cryptographic mechanism used to provide assurance of origin; and
- the conditions under which the local product side accepts or rejects those interactions.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic mechanism used to provide assurance of origin;
- verify that the local product side checks the authenticity-protection status of the interaction before acting upon it;
- verify that a valid interaction protected by the intended mechanism is accepted; and
- verify that an interaction lacking valid cryptographic assurance of origin is rejected or not acted upon.

5. Assessment verdict

Pass:

- the local product side uses a cryptographic mechanism providing assurance of origin for relevant received interactions;
- the local product side verifies that protection before acting upon the interaction; and

- interactions without valid assurance of origin are rejected or not acted upon.

Fail:

- the local product side acts upon a relevant interaction without verifying cryptographic assurance of origin; or
- the local product side accepts and acts upon an interaction for which the required authenticity mechanism is absent or invalid.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic authenticity mechanism;
- traces or logs showing successful acceptance of valid protected interactions; and
- traces or logs showing rejection or non-processing of interactions without valid assurance of origin.

R.5.1.3 Assessment case for REQ-RDPS-L-AUTH-CRIT-003

1. Assessment Reference

Requirement: REQ-RDPS-L-AUTH-CRIT-003

2. Assessment objective

The objective of the assessment is to verify that the local product side verifies that the cryptographic authenticity of the received interaction is bound to the intended RDPS-side endpoint and that replayed or stale interactions are detected and rejected where replay or reuse could affect secure operation.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the mechanism used to bind authenticity to the intended RDPS-side endpoint; and
- the replay or freshness protection mechanism, where applicable.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the mechanism that binds the authenticity of the interaction to the intended RDPS-side endpoint;
- inspect the design and configuration of the freshness, anti-replay, or equivalent mechanism used;
- verify that a valid interaction bound to the intended RDPS-side endpoint is accepted;
- verify that an interaction with valid-looking authenticity protection but not bound to the intended RDPS-side endpoint is rejected or not acted upon; and
- where replay or reuse could affect secure operation, verify that replayed or stale interactions are detected and rejected.

5. Assessment verdict

Pass:

- the local product side verifies that authenticity is bound to the intended RDPS-side endpoint; and
- replayed or stale interactions are rejected where replay or reuse could affect secure operation.

Fail:

- the local product side accepts and acts upon an interaction whose cryptographic authenticity is not bound to the intended RDPS-side endpoint; or
- the local product side fails to detect and reject replayed or stale interactions where such protection is required.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for source binding and anti-replay/freshness controls;
- evidence showing acceptance of valid bound interactions; and
- evidence showing rejection of misbound, replayed, or stale interactions.

R.5.1.4 Assessment case for REQ-RDPS-L-INTEG-NORM-001

1. Assessment Reference

Requirement: REQ-RDPS-L-INTEG-NORM-001

2. Assessment objective

The objective of the assessment is to verify that the local product side checks that a relevant received interaction has not been modified, substituted, corrupted, or injected before acting upon it.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions; and
- the mechanism used by the local product side to detect modification, substitution, corruption, or injection.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the integrity-checking mechanism;
- verify that integrity is checked before the interaction is acted upon;
- verify that an unmodified valid interaction is accepted; and
- verify that modified, substituted, corrupted, or injected interactions are rejected or not acted upon.

5. Assessment verdict

Pass:

- the local product side checks the integrity of relevant received interactions before acting upon them; and
- modified, substituted, corrupted, or injected interactions are rejected or not acted upon.

Fail:

- the local product side acts upon a relevant interaction without verifying its integrity; or
- the local product side accepts and acts upon an altered, substituted, corrupted, or injected interaction.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design or configuration evidence of the integrity-checking mechanism;
- evidence showing acceptance of valid interactions; and
- evidence showing rejection or non-processing of altered or injected interactions.

R.5.1.5 Assessment case for REQ-RDPS-L-INTEG-HIGH-002

1. Assessment Reference

Requirement: REQ-RDPS-L-INTEG-HIGH-002

2. Assessment objective

The objective of the assessment is to verify that the local product side verifies the integrity of relevant received interactions using a cryptographic integrity-protection mechanism.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions; and
- the cryptographic integrity-protection mechanism used for those interactions.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic integrity-protection mechanism;
- verify that integrity verification takes place before the interaction is acted upon;
- verify that a valid cryptographically protected interaction is accepted; and
- verify that an interaction with missing or invalid integrity protection is rejected or not acted upon.

5. Assessment verdict

Pass:

- the local product side uses cryptographic integrity protection for relevant received interactions;
- integrity verification is performed before the interaction is acted upon; and
- interactions with invalid or missing integrity protection are rejected or not acted upon.

Fail:

- the local product side does not use cryptographic integrity verification where required; or
- the local product side accepts and acts upon an interaction whose integrity protection is missing or invalid.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic integrity mechanism;
- evidence showing acceptance of valid protected interactions; and
- evidence showing rejection of interactions with invalid or missing integrity protection.

R.5.1.6 Assessment case for REQ-RDPS-L-INTEG-CRIT-002

1. Assessment Reference

Requirement: REQ-RDPS-L-INTEG-CRIT-002

2. Assessment objective

The objective of the assessment is to verify that the local product side verifies that the relevant received interaction is protected by a cryptographic integrity-protection mechanism bound to the authenticated source of the interaction.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the authenticated source of those interactions; and
- the mechanism used to bind integrity protection to that authenticated source.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the mechanism that binds integrity protection to the authenticated source;
- verify that a valid interaction whose integrity protection is correctly bound to the authenticated source is accepted;
- verify that an interaction with integrity protection not bound to the authenticated source is rejected or not acted upon; and
- verify that integrity verification and source binding checks are performed before the interaction is acted upon.

5. Assessment verdict

Pass:

- the local product side verifies that the interaction is protected by cryptographic integrity protection bound to the authenticated source; and
- interactions not correctly bound to that source are rejected or not acted upon.

Fail:

- the local product side accepts and acts upon a relevant interaction whose integrity protection is not bound to the authenticated source; or
- the local product side acts upon the interaction before performing the required checks.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for integrity binding to authenticated source;
- evidence showing acceptance of correctly bound interactions; and
- evidence showing rejection of misbound interactions.

R.5.1.7 Assessment case for REQ-RDPS-L-CONF-NORM-001

1. Assessment Reference

Requirement: REQ-RDPS-L-CONF-NORM-001

2. Assessment objective

The objective of the assessment is to verify that, where disclosure of exchanged data could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the local product side protects the confidentiality of that data during exchange with the RDPS side.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the categories of exchanged data for which disclosure could lead to unacceptable cybersecurity risk; and

- the mechanism used by the local product side to protect confidentiality during exchange.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the confidentiality-protection mechanism;
- verify that the identified data is protected during exchange with the RDPS side; and
- verify that data designated as requiring confidentiality is not exchanged in an unprotected manner.

5. Assessment verdict

Pass:

- the local product side protects the confidentiality of exchanged data where disclosure could lead to unacceptable cybersecurity risk; and
- such data is not exchanged in an unprotected manner.

Fail:

- the local product side does not protect the confidentiality of exchanged data where such protection is required; or
- identified confidential data is exchanged without appropriate confidentiality protection.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design or configuration evidence identifying the protected data and the means of protection; and
- evidence showing that relevant exchanged data is protected during exchange.

R.5.1.8 Assessment case for REQ-RDPS-L-CONF-HIGH-002

1. Assessment Reference

Requirement: REQ-RDPS-L-CONF-HIGH-002

2. Assessment objective

The objective of the assessment is to verify that the local product side protects the confidentiality of relevant exchanged data using cryptographic confidentiality protection.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the exchanged data requiring confidentiality protection; and
- the cryptographic confidentiality-protection mechanism used during exchange.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic confidentiality-protection mechanism;
- verify that the identified exchanged data is protected by that mechanism during exchange; and
- verify that exchange of such data without the required cryptographic confidentiality protection is prevented.

5. Assessment verdict

Pass:

- relevant exchanged data is protected using cryptographic confidentiality protection; and

- exchange without the required cryptographic protection is prevented.

Fail:

- the local product side exchanges relevant confidential data without cryptographic confidentiality protection; or
- the configured confidentiality mechanism is not effectively applied to the relevant data exchange.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic confidentiality mechanism; and
- evidence showing protected exchange of the relevant data.

R.5.1.9 Assessment case for REQ-RDPS-L-CONF-CRIT-003

1. Assessment Reference

Requirement: REQ-RDPS-L-CONF-CRIT-003

2. Assessment objective

The objective of the assessment is to verify that the local product side uses cryptographic confidentiality protection established with the intended RDPS-side endpoint and preventing disclosure of exchanged data to endpoints other than that intended endpoint.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the exchanged data requiring stronger confidentiality protection;
- the intended RDPS-side endpoint; and
- the cryptographic mechanism used to establish confidentiality protection with that endpoint.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic confidentiality mechanism and its association with the intended RDPS-side endpoint;
- verify that protected exchange is established with the intended RDPS-side endpoint;
- verify that the local product side does not disclose the protected data to other endpoints under the same exchange context; and
- verify that exchanges not established with the intended RDPS-side endpoint are rejected or do not result in disclosure of the protected data.

5. Assessment verdict

Pass:

- confidentiality protection is established with the intended RDPS-side endpoint;
- protected data is disclosed only to that intended endpoint; and
- exchanges with other endpoints do not result in disclosure of the protected data.

Fail:

- the local product side discloses protected data without establishing confidentiality protection with the intended RDPS-side endpoint; or
- the local product side discloses the protected data to endpoints other than the intended RDPS-side endpoint.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for endpoint-associated confidentiality protection;
- evidence showing protected disclosure to the intended RDPS-side endpoint; and
- evidence showing prevention of disclosure to other endpoints.

R.5.1.10 Assessment case for REQ-RDPS-L-AVAIL-NORM-001

1. Assessment Reference

Requirement: REQ-RDPS-L-AVAIL-NORM-001

2. Assessment objective

The objective of the assessment is to verify that the local product side detects unavailability, unacceptable delay, or intolerable degradation of required RDPS-side interactions, uses timeout or equivalent timeliness controls, and applies a defined behaviour for the RDPS-dependent product function.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required RDPS-side interactions;
- the acceptable timing or service conditions for those interactions; and
- the defined behaviour to be applied when the required interactions are unavailable, delayed, or degraded.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the timeout, timeliness, or equivalent detection controls;
- verify that unavailability, unacceptable delay, or intolerable degradation of required interactions is detected;
- verify that a defined behaviour is applied when such conditions occur; and
- verify that, under normal conditions, expected interactions are processed without triggering the fault-handling behaviour.

5. Assessment verdict

Pass:

- the local product side detects the specified failure, delay, or degradation conditions;
- timeout or equivalent timeliness controls are used; and
- a defined behaviour is applied when the identified conditions occur.

Fail:

- the local product side does not detect the relevant failure, delay, or degradation condition; or
- the required defined behaviour is not applied when such a condition occurs.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for detection and timeliness controls;
- evidence showing detection of failure, delay, or degradation; and
- evidence showing application of the defined behaviour.

R.5.1.11 Assessment case for REQ-RDPS-L-AVAIL-HIGH-002

1. Assessment Reference

Requirement: REQ-RDPS-L-AVAIL-HIGH-002

2. Assessment objective

The objective of the assessment is to verify that the local product side applies a defined degraded behaviour or secure state when required RDPS-side interactions are unavailable, delayed, or degraded, and supports recovery of the RDPS-dependent product function where needed.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required RDPS-side interactions;
- the degraded behaviour or secure state defined for failure conditions; and
- any locally maintained state, configuration, or other recovery information required to restore secure operation.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the degraded behaviour or secure-state mechanism;
- inspect the design and configuration of the recovery mechanism, where applicable;
- verify that when required interactions become unavailable, delayed beyond the acceptable time, or degraded beyond acceptable limits, the local product side applies the defined degraded behaviour or secure state; and
- verify that recovery support is available and can be used to restore secure operation where such support is required.

5. Assessment verdict

Pass:

- the local product side applies the defined degraded behaviour or secure state under the relevant failure conditions; and
- recovery support is available and usable where necessary to restore secure operation.

Fail:

- the local product side does not apply the defined degraded behaviour or secure state under the relevant failure conditions; or
- required recovery support is absent or ineffective.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for degraded behaviour, secure state, and recovery support; and
- evidence showing activation of degraded behaviour / secure state and restoration of secure operation where applicable.

R.5.1.12 Assessment case for REQ-RDPS-L-AVAIL-CRIT-003

1. Assessment Reference

Requirement: REQ-RDPS-L-AVAIL-CRIT-003

2. Assessment objective

The objective of the assessment is to verify that the local product side supports higher resilience, including continuity of operation through failover, redundancy, or equivalent resilience mechanisms where necessary.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required RDPS-side interactions;
- the defined degraded behaviour or secure state;
- the recovery support; and
- the failover, redundancy, or equivalent resilience mechanism, where required.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the resilience mechanism used to support continuity of operation;
- verify that the defined degraded behaviour or secure state is applied under the relevant failure conditions;
- verify that recovery support is available where required;
- where failover, redundancy, or equivalent resilience is required, verify that continuity of operation is supported when the primary interaction path becomes unavailable, delayed, or degraded.

5. Assessment verdict

Pass:

- the local product side supports the required resilience mechanism where necessary;
- defined degraded behaviour or secure state is applied under the relevant conditions; and
- continuity of operation is supported in accordance with the design where resilience is required.

Fail:

- a required resilience mechanism is absent or ineffective; or
- the local product side fails to support continuity of operation where such support is required.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for resilience, degraded behaviour, and recovery support; and
- evidence showing failover, redundancy, or equivalent continuity support where required.

R.5.2 RDPS side requirements

R.5.2.1 Assessment case for REQ-RDPS-R-AUTH-NORM-001

1. Assessment Reference

Requirement: REQ-RDPS-R-AUTH-NORM-001

2. Assessment objective

The objective of the assessment is to verify that the RDPS side verifies, before acting upon a relevant received interaction, that the interaction originates from the intended local product-side endpoint.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;

- the interactions received from the local product side that can influence the behaviour, state, configuration, or security of that function;
- the intended local product-side endpoint for those interactions; and
- the mechanism used by the RDPS side to determine the origin of the received interaction.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the mechanism used by the RDPS side to determine the origin of the relevant interaction;
- verify that the origin of the interaction is checked before the interaction is acted upon;
- verify that interactions from the intended local product-side endpoint are accepted; and
- verify that interactions not originating from the intended local product-side endpoint are rejected or not acted upon.

5. Assessment verdict

Pass:

- the RDPS side verifies the origin of the relevant interaction before acting upon it; and
- interactions from endpoints other than the intended local product-side endpoint are rejected or not acted upon.

Fail:

- the RDPS side acts upon a relevant interaction without verifying its origin; or
- the RDPS side accepts and acts upon a relevant interaction not originating from the intended local product-side endpoint.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design or configuration evidence describing how origin of the interaction is determined;
- evidence showing acceptance of interactions from the intended local product-side endpoint; and
- evidence showing rejection or non-processing of interactions from other endpoints.

R.5.2.2 Assessment case for REQ-RDPS-R-AUTH-HIGH-002

1. Assessment Reference

Requirement: REQ-RDPS-R-AUTH-HIGH-002

2. Assessment objective

The objective of the assessment is to verify that the RDPS side verifies the data authenticity of relevant received interactions using cryptographic endpoint authentication, an authenticated communication channel, or an equivalent cryptographic mechanism providing assurance of origin.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the cryptographic mechanism used to provide assurance of origin; and
- the conditions under which the RDPS side accepts or rejects those interactions.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic mechanism used to provide assurance of origin;
- verify that the RDPS side checks the authenticity-protection status of the interaction before acting upon it;
- verify that a valid interaction protected by the intended mechanism is accepted; and
- verify that an interaction lacking valid cryptographic assurance of origin is rejected or not acted upon.

5. Assessment verdict

Pass:

- the RDPS side uses a cryptographic mechanism providing assurance of origin for relevant received interactions;
- the RDPS side verifies that protection before acting upon the interaction; and
- interactions without valid assurance of origin are rejected or not acted upon.

Fail:

- the RDPS side acts upon a relevant interaction without verifying cryptographic assurance of origin; or
- the RDPS side accepts and acts upon an interaction for which the required authenticity mechanism is absent or invalid.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic authenticity mechanism;
- traces or logs showing successful acceptance of valid protected interactions; and
- traces or logs showing rejection or non-processing of interactions without valid assurance of origin.

R.5.2.3 Assessment case for REQ-RDPS-R-AUTH-CRIT-003

1. Assessment Reference

Requirement: REQ-RDPS-R-AUTH-CRIT-003

2. Assessment objective

The objective of the assessment is to verify that the RDPS side verifies that the cryptographic authenticity of the received interaction is bound to the intended local product-side endpoint and that replayed or stale interactions are detected and rejected where replay or reuse could affect secure operation.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the mechanism used to bind authenticity to the intended local product-side endpoint; and
- the replay or freshness protection mechanism, where applicable.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the mechanism that binds the authenticity of the interaction to the intended local product-side endpoint;
- inspect the design and configuration of the freshness, anti-replay, or equivalent mechanism used;

- verify that a valid interaction bound to the intended local product-side endpoint is accepted;
- verify that an interaction with valid-looking authenticity protection but not bound to the intended local product-side endpoint is rejected or not acted upon; and
- where replay or reuse could affect secure operation, verify that replayed or stale interactions are detected and rejected.

5. Assessment verdict

Pass:

- the RDPS side verifies that authenticity is bound to the intended local product-side endpoint; and
- replayed or stale interactions are rejected where replay or reuse could affect secure operation.

Fail:

- the RDPS side accepts and acts upon an interaction whose cryptographic authenticity is not bound to the intended local product-side endpoint; or
- the RDPS side fails to detect and reject replayed or stale interactions where such protection is required.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for source binding and anti-replay/freshness controls;
- evidence showing acceptance of valid bound interactions; and
- evidence showing rejection of misbound, replayed, or stale interactions.

R.5.2.4 Assessment case for REQ-RDPS-R-INTEG-NORM-001

1. Assessment Reference

Requirement: REQ-RDPS-R-INTEG-NORM-001

2. Assessment objective

The objective of the assessment is to verify that the RDPS side checks that a relevant received interaction has not been modified, substituted, corrupted, or injected before acting upon it.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions; and
- the mechanism used by the RDPS side to detect modification, substitution, corruption, or injection.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the integrity-checking mechanism;
- verify that integrity is checked before the interaction is acted upon;
- verify that an unmodified valid interaction is accepted; and
- verify that modified, substituted, corrupted, or injected interactions are rejected or not acted upon.

5. Assessment verdict

Pass:

- the RDPS side checks the integrity of relevant received interactions before acting upon them; and

- modified, substituted, corrupted, or injected interactions are rejected or not acted upon.

Fail:

- the RDPS side acts upon a relevant interaction without verifying its integrity; or
- the RDPS side accepts and acts upon an altered, substituted, corrupted, or injected interaction.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design or configuration evidence of the integrity-checking mechanism;
- evidence showing acceptance of valid interactions; and
- evidence showing rejection or non-processing of altered or injected interactions.

R.5.2.5 Assessment case for REQ-RDPS-R-INTEG-HIGH-002

1. Assessment Reference

Requirement: REQ-RDPS-R-INTEG-HIGH-002

2. Assessment objective

The objective of the assessment is to verify that the RDPS side verifies the integrity of relevant received interactions using a cryptographic integrity-protection mechanism.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions; and
- the cryptographic integrity-protection mechanism used for those interactions.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic integrity-protection mechanism;
- verify that integrity verification takes place before the interaction is acted upon;
- verify that a valid cryptographically protected interaction is accepted; and
- verify that an interaction with missing or invalid integrity protection is rejected or not acted upon.

5. Assessment verdict

Pass:

- the RDPS side uses cryptographic integrity protection for relevant received interactions;
- integrity verification is performed before the interaction is acted upon; and
- interactions with invalid or missing integrity protection are rejected or not acted upon.

Fail:

- the RDPS side does not use cryptographic integrity verification where required; or
- the RDPS side accepts and acts upon an interaction whose integrity protection is missing or invalid.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic integrity mechanism;

- evidence showing acceptance of valid protected interactions; and
- evidence showing rejection of interactions with invalid or missing integrity protection.

R.5.2.6 Assessment case for REQ-RDPS-R-INTEG-CRIT-003

1. Assessment Reference

Requirement: REQ-RDPS-R-INTEG-CRIT-003

2. Assessment objective

The objective of the assessment is to verify that the RDPS side verifies that the relevant received interaction is protected by a cryptographic integrity-protection mechanism bound to the authenticated source of the interaction.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the authenticated source of those interactions; and
- the mechanism used to bind integrity protection to that authenticated source.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the mechanism that binds integrity protection to the authenticated source;
- verify that a valid interaction whose integrity protection is correctly bound to the authenticated source is accepted;
- verify that an interaction with integrity protection not bound to the authenticated source is rejected or not acted upon; and
- verify that integrity verification and source binding checks are performed before the interaction is acted upon.

5. Assessment verdict

Pass:

- the RDPS side verifies that the interaction is protected by cryptographic integrity protection bound to the authenticated source; and
- interactions not correctly bound to that source are rejected or not acted upon.

Fail:

- the RDPS side accepts and acts upon a relevant interaction whose integrity protection is not bound to the authenticated source; or
- the RDPS side acts upon the interaction before performing the required checks.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for integrity binding to authenticated source;
- evidence showing acceptance of correctly bound interactions; and
- evidence showing rejection of misbound interactions.

R.5.2.7 Assessment case for REQ-RDPS-R-CONF-NORM-001

1. Assessment Reference

Requirement: REQ-RDPS-R-CONF-NORM-001

2. Assessment objective

The objective of the assessment is to verify that, where disclosure of exchanged data could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the RDPS side protects the confidentiality of that data during exchange with the local product side.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the categories of exchanged data for which disclosure could lead to unacceptable cybersecurity risk; and
- the mechanism used by the RDPS side to protect confidentiality during exchange.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the confidentiality-protection mechanism;
- verify that the identified data is protected during exchange with the local product side; and
- verify that data designated as requiring confidentiality is not exchanged in an unprotected manner.

5. Assessment verdict

Pass:

- the RDPS side protects the confidentiality of exchanged data where disclosure could lead to unacceptable cybersecurity risk; and
- such data is not exchanged in an unprotected manner.

Fail:

- the RDPS side does not protect the confidentiality of exchanged data where such protection is required; or
- identified confidential data is exchanged without appropriate confidentiality protection.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design or configuration evidence identifying the protected data and the means of protection; and
- evidence showing that relevant exchanged data is protected during exchange.

R.5.2.8 Assessment case for REQ-RDPS-R-CONF-HIGH-002

1. Assessment Reference

Requirement: REQ-RDPS-R-CONF-HIGH-002

2. Assessment objective

The objective of the assessment is to verify that the RDPS side protects the confidentiality of relevant exchanged data using cryptographic confidentiality protection.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the exchanged data requiring confidentiality protection; and

- the cryptographic confidentiality-protection mechanism used during exchange.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic confidentiality-protection mechanism;
- verify that the identified exchanged data is protected by that mechanism during exchange; and
- verify that exchange of such data without the required cryptographic confidentiality protection is prevented.

5. Assessment verdict

Pass:

- relevant exchanged data is protected using cryptographic confidentiality protection; and
- exchange without the required cryptographic protection is prevented.

Fail:

- the RDPS side exchanges relevant confidential data without cryptographic confidentiality protection; or
- the configured confidentiality mechanism is not effectively applied to the relevant data exchange.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic confidentiality mechanism; and
- evidence showing protected exchange of the relevant data.

R.5.2.9 Assessment case for REQ-RDPS-R-CONF-CRIT-003

1. Assessment Reference

Requirement: REQ-RDPS-R-CONF-CRIT-003

2. Assessment objective

The objective of the assessment is to verify that the RDPS side uses cryptographic confidentiality protection established with the intended local product-side endpoint and preventing disclosure of exchanged data to endpoints other than that intended endpoint.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the exchanged data requiring stronger confidentiality protection;
- the intended local product-side endpoint; and
- the cryptographic mechanism used to establish confidentiality protection with that endpoint.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic confidentiality mechanism and its association with the intended local product-side endpoint;
- verify that protected exchange is established with the intended local product-side endpoint;
- verify that the RDPS side does not disclose the protected data to other endpoints under the same exchange context; and
- verify that exchanges not established with the intended local product-side endpoint are rejected or do not result in disclosure of the protected data.

5. Assessment verdict

Pass:

- confidentiality protection is established with the intended local product-side endpoint;
- protected data is disclosed only to that intended endpoint; and
- exchanges with other endpoints do not result in disclosure of the protected data.

Fail:

- the RDPS side discloses protected data without establishing confidentiality protection with the intended local product-side endpoint; or
- the RDPS side discloses the protected data to endpoints other than the intended local product-side endpoint.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for endpoint-associated confidentiality protection;
- evidence showing protected disclosure to the intended local product-side endpoint; and
- evidence showing prevention of disclosure to other endpoints.

R.5.2.10 Assessment case for REQ-RDPS-R-AVAIL-NORM-001

1. Assessment Reference

Requirement: REQ-RDPS-R-AVAIL-NORM-001

2. Assessment objective

The objective of the assessment is to verify that the RDPS side detects unavailability, unacceptable delay, or intolerable degradation of required local product-side interactions, uses timeout or equivalent timeliness controls, and applies a defined behaviour for the RDPS-dependent product function.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required local product-side interactions;
- the acceptable timing or service conditions for those interactions; and
- the defined behaviour to be applied when the required interactions are unavailable, delayed, or degraded.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the timeout, timeliness, or equivalent detection controls;
- verify that unavailability, unacceptable delay, or intolerable degradation of required interactions is detected;
- verify that a defined behaviour is applied when such conditions occur; and
- verify that, under normal conditions, expected interactions are processed without triggering the fault-handling behaviour.

5. Assessment verdict

Pass:

- the RDPS side detects the specified failure, delay, or degradation conditions;
- timeout or equivalent timeliness controls are used; and

- a defined behaviour is applied when the identified conditions occur.

Fail:

- the RDPS side does not detect the relevant failure, delay, or degradation condition; or
- the required defined behaviour is not applied when such a condition occurs.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for detection and timeliness controls;
- evidence showing detection of failure, delay, or degradation; and
- evidence showing application of the defined behaviour.

R.5.2.11 Assessment case for REQ-RDPS-R-AVAIL-HIGH-002

1. Assessment Reference

Requirement: REQ-RDPS-R-AVAIL-HIGH-002

2. Assessment objective

The objective of the assessment is to verify that the RDPS side applies a defined degraded behaviour or secure state when required local product-side interactions are unavailable, delayed, or degraded, and supports recovery of the RDPS-dependent product function where needed.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required local product-side interactions;
- the degraded behaviour or secure state defined for failure conditions; and
- any maintained state, configuration, or other recovery information required to restore secure operation.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the degraded behaviour or secure-state mechanism;
- inspect the design and configuration of the recovery mechanism, where applicable;
- verify that when required interactions become unavailable, delayed beyond the acceptable time, or degraded beyond acceptable limits, the RDPS side applies the defined degraded behaviour or secure state; and
- verify that recovery support is available and can be used to restore secure operation where such support is required.

5. Assessment verdict

Pass:

- the RDPS side applies the defined degraded behaviour or secure state under the relevant failure conditions; and
- recovery support is available and usable where necessary to restore secure operation.

Fail:

- the RDPS side does not apply the defined degraded behaviour or secure state under the relevant failure conditions; or
- required recovery support is absent or ineffective.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for degraded behaviour, secure state, and recovery support; and
- evidence showing activation of degraded behaviour / secure state and restoration of secure operation where applicable.

R.5.2.12 Assessment case for REQ-RDPS-R-AVAIL-CRIT-003

1. Assessment Reference

Requirement: REQ-RDPS-R-AVAIL-CRIT-003

2. Assessment objective

The objective of the assessment is to verify that the RDPS side supports higher resilience, including continuity of operation through failover, redundancy, or equivalent resilience mechanisms where necessary.

3. Assessment preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required local product-side interactions;
- the defined degraded behaviour or secure state;
- the recovery support; and
- the failover, redundancy, or equivalent resilience mechanism, where required.

4. Assessment activities

The assessment shall include the following activities:

- inspect the design and configuration of the resilience mechanism used to support continuity of operation;
- verify that the defined degraded behaviour or secure state is applied under the relevant failure conditions;
- verify that recovery support is available where required;
- where failover, redundancy, or equivalent resilience is required, verify that continuity of operation is supported when the primary interaction path becomes unavailable, delayed, or degraded.

5. Assessment verdict

Pass:

- the RDPS side supports the required resilience mechanism where necessary;
- defined degraded behaviour or secure state is applied under the relevant conditions; and
- continuity of operation is supported in accordance with the design where resilience is required.

Fail:

- a required resilience mechanism is absent or ineffective; or
- the RDPS side fails to support continuity of operation where such support is required.

6. Assessment evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for resilience, degraded behaviour, and recovery support; and
- evidence showing failover, redundancy, or equivalent continuity support where required.

History

Version	Date	Status
V0.2.2	June 2026	SRdAP process EV 20260920: 2026-06-22 to 2026-09-21